

TokTickIT

CPE334 Lab 3 — Authentication, IT Staff Operations and User Management

Student	Thawat Boonsuk
Student ID	67070501024
GitHub	Chessuker
Repository	https://github.com/Chessuker/TokTickIT
Built from	docs/lab-03-final-evidence at 34eadf5 (with uncommitted changes)
Tests	970 passing — 656 backend, 231 frontend, 83 end-to-end; none skipped
Test run	docs/lab-03-final-evidence @ 34eadf5 + uncommitted docs/artifacts only (code = this commit) · 2026-09-27T08:30:12.195Z

1. Answer Part 1: Git Use with Engineering Workflow
2. Answer Part 2: Spec-Driven Development
3. Answer Part 3: Test-Driven Development and Traceability
4. Answer Part 4: AI Use with Reflection
5. Answer Part 5: Working Login and Password Change UI
6. Answer Part 6: Working IT Staff Ticket Queue UI
7. Answer Part 7: Working IT Staff Ticket Detail UI
8. Answer Part 8: Working Administrator User Management UI
9. Answer Part 9: Zen Green UI and Responsive Evidence

Answer Part 1:

Git Use with Engineering Workflow · 10 points

Answer Part 1 — Git Use with Engineering Workflow

Repository: <https://github.com/Chessuker/TokTickIT> · Branch flow: `feature/<issue>-<slug>` → pull request → `lab3-staging` → release pull request → `main`.

1. Commit history: feature branches → `lab3-staging` → `main`

Every Lab 3 change reached `lab3-staging` through a pull request from its own feature branch; `git log --first-parent lab3-staging` contains nothing but those merges. The release pull request then merges `lab3-staging` into `main`.

Issue	Pull request	Branch	Merged into <code>lab3-staging</code>
#36 Sprint 3 engineering contract	#43	<code>feature/36-lab3-spec-docs</code>	2026-09-18 12:52 · <code>4ad5d2e</code>
#37 Authentication foundation	#44	<code>feature/37-auth-foundation</code>	2026-09-19 12:32 · <code>05f2133</code>
#38 Requester regression, comments, resolution	#45	<code>feature/38-requester-comments</code>	2026-09-19 18:31 · <code>42e7ccf</code>
#39 IT Staff Ticket Queue	#46	<code>feature/39-staff-queue</code>	2026-09-22 22:44 · <code>acd96bd</code>
#40 IT Staff Ticket operations	#47	<code>feature/40-staff-ticket-ops</code>	2026-09-25 13:44 · <code>f835755</code>
#41 Administrator user management	#48	<code>feature/41-admin-users</code>	2026-09-26 · <code>91e5178</code>
#42 E2E, visual inspection, release	#49	<code>feature/42-e2e-release</code>	2026-09-26 21:34 · <code>ac1f845</code>
Release Lab 3	#50	<code>lab3-staging</code> → <code>main</code>	2026-09-27 · <code>34eadf5</code> (into <code>main</code>)

```

TokTickIT - Branch and merge history

$ git log --graph --oneline --decorate -n 60
# docs/lab-03-final-evidence @ 3eadf5 + uncommitted docs/artifacts only (code = this commit)

* 3eadf5 2026-09-27 Merge pull request #50 from Chessuker/lab3-staging (HEAD -> docs/lab-03-final-evidence, origin/main, origin/HEAD)
| \
| * ac1f845 2026-09-26 Merge pull request #49 from Chessuker/feature/42-e2e-release (origin/lab3-staging, lab3-staging)
| | \
| | * 475900e 2026-09-26 feat (#42): E2E-07 visual pass, evidence capture, submission PDF (origin/feature/42-e2e-release, feature/42-e2e-release)
| | | \
| | | * 91e3178 2026-09-26 Merge pull request #48 from Chessuker/feature/41-admin-users
| | | | \
| | | | * 8a29f97 2026-09-25 feat (#41): Administrator user management (origin/feature/41-admin-users, feature/41-admin-users)
| | | | | \
| | | | * f35755 2026-09-25 Merge pull request #47 from Chessuker/feature/40-staff-ticket-ops
| | | | | \
| | | | * e2d89ae 2026-09-25 feat (#40): IT Staff ticket operations - workflow matrix, staff detail, internal notes (origin/feature/40-staff-ticket-ops, feature/40-staff-ticket-ops)
| | | | | \
| | | | * aad96bd 2026-09-22 Merge pull request #46 from Chessuker/feature/39-staff-queue
| | | | | \
| | | | * e565ade 2026-09-19 feat (#39): IT Staff Ticket Queue - staff routes, queue query, seeded tickets, StaffTicketQueue (origin/feature/39-staff-queue, feature/39-staff-queue)
| | | | | \
| | | | * 42e7ccf 2026-09-19 Merge pull request #45 from Chessuker/feature/38-requester-comments
| | | | | \
| | | | * 5af6971 2026-09-19 docs (#38): requester ticket detail screenshots for the FR (origin/feature/38-requester-comments, feature/38-requester-comments)
| | | | * cfe6a4d 2026-09-19 feat (#38): Public Comments and "Problem appears resolved" on the Requester Ticket Detail
| | | | | \
| | | | * 052133 2026-09-19 Merge pull request #44 from Chessuker/feature/37-auth-foundation
| | | | | \
| | | | * 8386add 2026-09-19 feat (#37): authentication foundation - sessions, roles, login/change-password, migration and seed (origin/feature/37-auth-foundation, feature/37-auth-foundation)
| | | | | \
| | | | * 4ad5d2e 2026-09-19 Merge pull request #43 from Chessuker/feature/36-lab3-spec-docs
| | | | | \
| | | | * 82122d 2026-09-19 chore: move lab1 screenshots under docs/lab-01, untrack lab sheet and .claude tooling config (origin/feature/36-lab3-spec-docs, feature/36-lab3-spec-docs)
| | | | * e1f3aa2 2026-09-19 docs (lab-03): address review on #43 - auth matrix, BR-31, BR-07/10/11, AC-31
| | | | * 8a84d4c 2026-09-19 docs (lab-03): address review on #43 - auth matrix, BR-31, BR-07/10/11, AC-31
| | | | * 3b0d0ce 2026-09-19 docs (lab-03): fill GitHub Issues numbers #36-#42
| | | | * 492d490 2026-09-19 docs (lab-03): Sprint 3 engineering contract
| | | | | \
| | | | * ab33c4d 2026-09-09 Merge pull request #35 from Chessuker/docs/lab-02-final-evidence (main)
| | | | | \
| | | | * 6a8b079 2026-09-05 docs (lab-02) (origin/docs/lab-02-final-evidence)
| | | | * d56b79a 2026-09-05 Merge pull request #34 from Chessuker/docs/lab-02-final-evidence
| | | | | \
| | | | * 08e34bb 2026-09-05 docs (lab-02)
| | | | | \
| | | | * 993b6dc 2026-09-05 Merge pull request #33 from Chessuker/lab2-staging
| | | | | \
| | | | * 226659e 2026-09-05 Merge pull request #32 from Chessuker/feature/7-ui-responsive-e2e (origin/lab2-staging)
| | | | | \
| | | | * daa3b88 2026-09-05 feature 7: refine zen green UI, responsive styles, and implement Playwright E2E tests (origin/feature/7-ui-responsive-e2e)
| | | | | \
| | | | * f097031 2026-09-04 Merge pull request #31 from Chessuker/feature/6-ticket-detail-attachments
| | | | | \
| | | | * 4db72b0 2026-09-04 fix MIME check (origin/feature/6-ticket-detail-attachments)
| | | | * f72a07 2026-09-04 feature 5: implement ticket detail view, attachment upload, download, soft removal, and ownership guards
| | | | | \
| | | | * aacbb70 2026-08-30 Merge pull request #30 from Chessuker/feature/5-my-tickets-list
| | | | | \
| | | | * 91a7d0b 2026-08-29 feature 5: implement My Tickets listing with search, filtering, pagination, and empty/no-results states (origin/feature/5-my-tickets-list)
| | | | | \
| | | | * 7f597a1 2026-08-29 Merge pull request #29 from Chessuker/feature/4-create-ticket
| | | | | \
| | | | * 8fbcdbb 2026-08-29 feature 4: implement ticket creation API, resilient create form UI, and automated tests (origin/feature/4-create-ticket, feature/4-create-ticket)
| | | | * f8d1155 2026-08-28 Merge pull request #28 from Chessuker/feature/3-requester-context
| | | | | \ \ \
| | | | | | \
| | | | | | | \
| | | | | | | * | 3a7601 2026-08-28 feature 3: implement requester context, selector screen, and change requester shell action (origin/feature/3-requester-context, feature/3-requester-context)
| | | | | | | | \
| | | | | | | * | d20a79e 2026-08-27 Merge pull request #27 from Chessuker/feature/2-db-schema-seed (lab2-staging)
| | | | | | | | \
| | | | | | | * | 1ae37ec 2026-08-26 resolve feature2 (origin/feature/2-db-schema-seed)
| | | | | | | * | b97f8de 2026-08-26 Merge branch 'lab2-staging' into feature/2-db-schema-seed
| | | | | | | | \
| | | | | | | | | \
| | | | | | | | | * | 7a8224c 2026-08-23 Merge pull request #26 from Chessuker/feature/1-spec-docs
| | | | | | | | | | \
| | | | | | | | | | * | 61089de 2026-08-23 add api_spec and reviewer md (origin/feature/1-spec-docs, feature/1-spec-docs)
| | | | | | | | | | * | a7dbd1f 2026-08-23 fix md (feature/2-db-schema-seed)
| | | | | | | | | | * | f28024c 2026-08-22 edit gitignore
| | | | | | | | | | * | 279398e 2026-08-22 feature2: implement database schema, idempotent seed data, and unit tests
| | | | | | | | | | | \
| | | | | | | | | | | * | de7ca3 2026-08-22 docs: complete sprint engineering spec, ui-spec, test plan, and ai-use tracking
| | | | | | | | | | | * | 5096b1d 2026-08-22 docs: complete sprint engineering spec, ui-spec, test plan, and ai-use tracking
| | | | | | | | | | | | \
| | | | | | | | | | | | | \
| | | | | | | | | | | | | * | 4d334fa 2026-08-14 Fix repository link in README
| | | | | | | | | | | | | | \
| | | | | | | | | | | | | | * | 08d187f 2026-08-14 Merge pull request #15 from Chessuker/edit-md-lab1
| | | | | | | | | | | | | | | \
| | | | | | | | | | | | | | | * | 8086598 2026-08-14 Merge branch 'main' into edit-md-lab1 (origin/edit-md-lab1)
| | | | | | | | | | | | | | | | \
| | | | | | | | | | | | | | | | | \
| | | | | | | | | | | | | | | | | * | 62c044d 2026-08-14 Refactor README for better readability and structure
| | | | | | | | | | | | | | | | | * | 83cFbf5 2026-08-13 Merge pull request #14 from Chessuker/edit-md-lab1
| | | | | | | | | | | | | | | | | | \
| | | | | | | | | | | | | | | | | | * | 64b3f12 2026-08-14 README fixed
| | | | | | | | | | | | | | | | | | | \
| | | | | | | | | | | | | | | | | | | * | 8f3dd2f 2026-08-13 edit md lab1
| | | | | | | | | | | | | | | | | | | * | a77cdd3 2026-08-11 add md-lab1
| | | | | | | | | | | | | | | | | | | * | 4e0ce31 2026-08-11 add md-lab1
| | | | | | | | | | | | | | | | | | | | \
| | | | | | | | | | | | | | | | | | | | * | 5924b38 2026-08-09 Clean up README by removing unnecessary content
| | | | | | | | | | | | | | | | | | | | * | 6b3ba4b 2026-08-09 chore: add comprehensive README
| | | | | | | | | | | | | | | | | | | | * | 3e56aac 2026-08-09 Merge branch 'lab1-staging'
| | | | | | | | | | | | | | | | | | | | | \
| | | | | | | | | | | | | | | | | | | | | * | 849b788 2026-08-09 Merge pull request #12 from Chessuker/feature/4-category-list (origin/lab1-staging)
| | | | | | | | | | | | | | | | | | | | | | \
| | | | | | | | | | | | | | | | | | | | | | * | c096b22 2026-08-09 initial feature 4 (origin/feature/4-category-list)

```

git log --graph --oneline --decorate -n 60 — 1 of 2

```

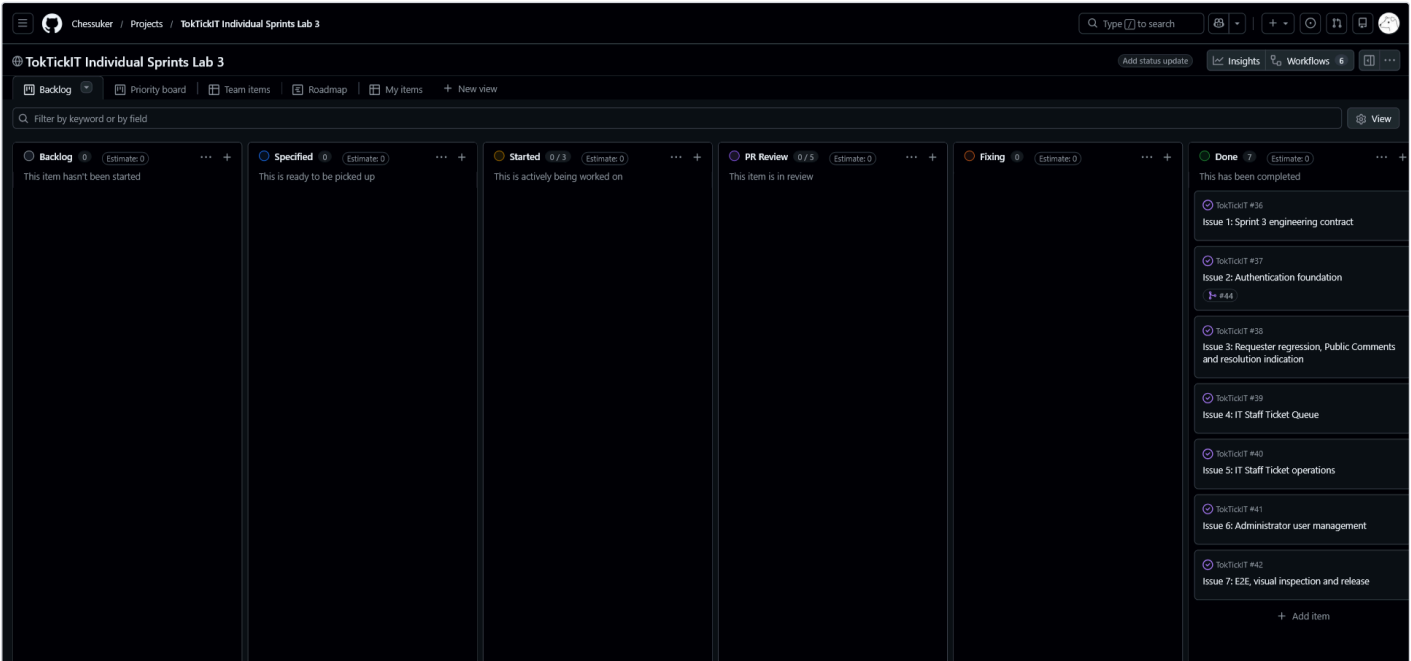
| * de27ca3 2026-08-22 docs: complete sprint engineering spec, ui-spec, test plan, and ai-use tracking
| * 5096b1d 2026-08-22 docs: complete sprint engineering spec, ui-spec, test plan, and ai-use tracking
| /
* 4d334fa 2026-08-14 Fix repository link in README
| * 08d187f 2026-08-14 Merge pull request #15 from Chessuker/edit-md-lab1
| \
| * 8086598 2026-08-14 Merge branch 'main' into edit-md-lab1 (origin/edit-md-lab1)
| | \
| | | \
| | | /
| | /
| /
* | 62c044d 2026-08-14 Refactor README for better readability and structure
* | 83cFbf5 2026-08-13 Merge pull request #14 from Chessuker/edit-md-lab1
| \ \
| | * 64b3f12 2026-08-14 README fixed
| | /
| * 8f3dd2f 2026-08-13 edit md lab1
| * a77cdd3 2026-08-11 add md-lab1
| * 4e0ce31 2026-08-11 add md-lab1
| /
* 5924b38 2026-08-09 Clean up README by removing unnecessary content
* 6b3ba4b 2026-08-09 chore: add comprehensive README
* 3e56aac 2026-08-09 Merge branch 'lab1-staging'
| \
| * 849b788 2026-08-09 Merge pull request #12 from Chessuker/feature/4-category-list (origin/lab1-staging)
| | \
| | * c096b22 2026-08-09 initial feature 4 (origin/feature/4-category-list)

```

git log --graph --oneline --decorate -n 60 — 2 of 2

The image is the verbatim output of the command at its top, saved in [test-runs/git-history.txt](#).

2. GitHub Project / Kanban — all Issues in Done



Final Kanban board

3. Peer review

The rendered `reviewer.md` follows this page: reviewer identity, the pull-request links above, comments given and received, responses, and approvals.

4. README and .gitignore

`README.md` documents the Lab 3 features, setup, migration (including upgrading a Lab 2 database), the seed and its local development accounts, and the test commands. It is rendered in full after `reviewer.md`.

`.gitignore` keeps secrets, dependencies, build output, uploaded files, test reports and the course lab sheets out of the repository — `.env` is ignored and no `.env` file is tracked; only `server/.env.example` is:

```
node_modules/
.env
.env.local
.env.*.local
dist/
build/
*.tsbuildinfo
logs/
*.log
.vscode/
.idea/
.claude/
Lab_3_sheet.pdf
*_labsheet.pdf
server/uploads/
e2e/report/
test-results/
playwright/.cache/
```

5. Repository structure (Lab 3 increment)

The layout the lab sheet (§12) requires, as it is on `main`, plus the extra suites this sprint added:

```
docs/lab-03/
├── specification.md api-spec.md ui-spec.md tests.md
├── reviewer.md ai-use.md issues.md README.md
├── answer-part1 ... answer-part9 *.md
├── build-submission-pdf.mjs
├── scripts/          capture-evidence.mjs · capture-api-authorization.mjs · capture-test-runs.mjs
└── test-runs/        server.txt · client.txt · e2e.txt · api-authorization.txt · git-history.txt

server/tests/lab-03/
├── auth.api.test.ts          authorization.api.test.ts
├── staff-queue.api.test.ts   staff-ticket-detail.api.test.ts
├── comments-notes.api.test.ts users-admin.api.test.ts
└── passwordPolicy · loginThrottle · session · queueQuery · ticketWorkflow (.test.ts, unit)

client/src/components/lab-03/
├── Login · ChangePassword · StaffTicketQueue · StaffTicketDetail · UserManagement (.tsx + .test.tsx)
└── RequireAuth · Badges · CommentsPanel (tests), ThreadPanel · InternalNotesPanel · PasswordField

e2e/lab-03/
├── authentication.spec.ts staff-ticket-flow.spec.ts user-administration.spec.ts
└── requester-comments.spec.ts staff-queue.spec.ts visual.spec.ts

artifacts/lab-03/screenshots/
├── authentication/ staff-queue/ staff-ticket-detail/ user-management/
└── requester/ evidence/
```

Lab 3 — Peer Review Documentation

Record of the peer review performed on this sprint: who reviewed, which pull requests, what was raised, and how it was resolved. Every row below links to the GitHub review it summarises.

1. Peer Reviewer Information

Field	Detail
Name	Theehathat
Student ID	67070501019
GitHub Username	TeekhathatTT
Their repository, which I reviewed	https://github.com/TeekhathatTT/CPE334-TokTickIT
My repository, which they reviewed	https://github.com/Chessuker/TokTickIT

My Information

Field	Detail
Name	Thawat Boonsuk
Student ID	67070501024
GitHub Username	Chessuker

2. Reviewed PR Links

One row per pull request. Base branch is `lab3-staging` for feature PRs and `main` for the release PR.

#	Issue	PR	Branch	Base	Reviewed By	Merged	Outcome
1	#36 Sprint 3 engineering contract	#43	feature/36-lab3-spec-docs	lab3-staging	TeekhathatTT	2026-09-18 (4ad5d2e)	Changes requested (5) → fixed → Approved
2	#37 Authentication foundation	#44	feature/37-auth-foundation	lab3-staging	TeekhathatTT	2026-09-19 (05f2133)	Approved
3	#38 Requester regression, comments, resolution	#45	feature/38-requester-comments	lab3-staging	TeekhathatTT	2026-09-19 (42e7ccf)	Approved
4	#39 IT Staff Ticket Queue	#46	feature/39-staff-queue	lab3-staging	TeekhathatTT	2026-09-22 (acd96bd)	Approved

#	Issue	PR	Branch	Base	Reviewed By	Merged	Outcome
5	#40 IT Staff Ticket operations	#47	feature/40-staff-ticket-ops	lab3-staging	TeekhathatTT	2026-09-25 (f835755)	Approved
6	#41 Administrator user management	#48	feature/41-admin-users	lab3-staging	TeekhathatTT	2026-09-26 (91e5178)	Approved
7	#42 E2E, visual inspection, release	#49	feature/42-e2e-release	lab3-staging	TeekhathatTT	2026-09-26 (ac1f845)	Changes requested (1) → fixed → Approved
8	Release Lab 3	#50	lab3-staging	main	TeekhathatTT		Approved

3. Comments on My PRs (received)

PR	Comment (summary)	My response	Outcome
#43	Changes requested. (1) Authorization matrix: "view own ticket" must be <code>✓ read</code> for IT Staff / Administrator, not <code>-</code> (conflicted with BR-14 and api-spec). (2) Add BRs for rules that lived only in api-spec: no owner / IT Priority change on Closed / Cancelled, no unassign while In Progress, assigning a New ticket sets Open. (3) BR-10 / BR-11: Change Password must revoke the user's other sessions. (4) AC-31: "each former requester" → one active requester, and MIG-01 checks this before the seed. (5) BR-07: the throttle counts only <code>INVALID_CREDENTIALS</code> , not the inactive <code>403</code> .	Fixed all five in the specification and api-spec, then asked for a re-review.	Approved
#44	Approved. Checked against the spec: 32-byte session token stored only as a SHA-256 hash; <code>httpOnly</code> / <code>SameSite=Lax</code> / 24 h cookie; <code>requesterId</code> taken only from the session; dummy-hash bcrypt compare against timing attacks; throttle of 5 failures / 15 min counting only <code>401</code> ; migration verify script; the <code>?from=</code> race fix has its own test; the David Lee seed deviation is written back into the spec.	Acknowledged; merged.	Approved, no changes
#45	Approved. Administrator blocked with <code>403</code> before the lookup; resolution indication is idempotent and never touches status; comments render as plain JSX text (no <code>dangerouslySetInnerHTML</code> , so no XSS); badges unified. Re-ran the suites: client 139/139; server 229 passed, with the 13 seed tests limited by the reviewer's own sandbox.	Acknowledged; merged.	Approved, no changes
#46	Approved with a checklist: both staff endpoints, Requester <code>403</code> before the query, search, multi-status OR, filters, 10 sort orders, pagination, invalid query → <code>400</code> , Administrator read-only, 24 seeded tickets, idempotent seed, status enum order, three layouts, URL as state, all four test levels.	Merged.	Approved, no changes
#47	Approved. <code>ticketWorkflow.ts</code> is the single source of truth — enforcement and the <code>permittedTransitions</code> the API returns use the same function, and an Administrator always gets <code>[]</code> . <code>PATCH /owner</code> refuses unassign on In Progress and changes on terminal statuses, and accepts only active IT Staff. Internal Notes block Requesters at the router. The Administrator view renders values, not disabled inputs.	Acknowledged; merged.	Approved, no changes
#48	Approved, checked against the specification, api-spec, ui-spec, tests and the Lab 3 handout: list, search and role filter, create with one role and <code>mustChangePassword</code> , duplicate email <code>409</code> under the field, self-deactivation and last-Administrator <code>409</code> on the server, session revocation, new initial password, no Delete control (BR-27), non-Administrator <code>403</code> before lookup, no <code>passwordHash</code> exposed, three layouts, API-40 ... 48, UI-21 ... 24, E2E-06.	Acknowledged; merged.	Approved, no changes
#49	Changes requested. The code matches the specification (E2E, responsive / visual, accessibility, error handling), but the PR description claimed all evidence was complete when part of the final evidence was not. Fix the description only, not the implementation.	Rewrote the description : test logs and API transcript marked as a pre-release snapshot (91e5178 + uncommitted changes), PDF marked as a draft, an "Evidence status" table of what remains, Definition of Done stated as 13 / 16. No code changed.	Approved
#50	Approved. Everything is complete; what remains for submission is the test / evidence run on <code>main</code> , the Kanban with #36 – #42 in Done plus its screenshot, and the peer review in <code>reviewer.md</code> — none of it touches the features.	Addressed in the <code>docs/Lab-03-final-evidence</code> PR: evidence re-run on <code>main</code> , Kanban captured, this file completed.	Approved

4. Comments I Gave on My Partner's PRs

Repository: [TeekhathatTT/CPE334-TokTickIT](#). All five Lab 3 pull requests target `lab3-staging`.

PR	Comment (summary)	Their response	Outcome
#32 Authentication and requester authorization	Changes requested. (1) <code>cors()</code> default while the client sends <code>credentials</code> : "include" → <code>cors({ origin: APP_ORIGIN, credentials: true })</code> and drop the duplicate manual Origin check. (2) Confirm the cookie config: <code>SameSite=None; Secure</code> only if truly cross-site. (3) Document that the in-memory session Map is lost on restart. (4) Grep for leftover <code>x-requester-id</code> logic.	Fixed all four; a second reviewer confirmed each item.	Merged 2026-09-15 (fd99f78); approved
#34 Staff queue and auth compatibility	Changes requested. (1) <code>requireAuth</code> removed from <code>/api/categories</code> , <code>/api/requesters</code> , <code>/api/related-systems</code> . (2) <code>x-requester-id</code> lets a caller impersonate a requester — gate it behind an environment flag. (3) <code>staff.ts</code> reads <code>requester.email</code> / <code>role</code> that a legacy DB may lack. (4) <code>ticket.category.name</code> / <code>relatedSystem.name</code> without null checks. (5) Assignment race: use a conditional update and <code>409</code> . Optional : transition tests, wire the real <code>StaffQueue</code> component, log staff actions, fewer <code>any</code> .	Fixed . On my follow-up (public endpoints intended?, explicit flag instead of <code>NODE_ENV</code> , a two-staff assignment <code>409</code> test) they declined; those were optional.	Merged 2026-09-18 (cfdb5f0); approved

PR	Comment (summary)	Their response	Outcome
#40 Database migration	Changes requested. (1) The seed deletes <code>PublicComment</code> / <code>InternalNote</code> rows — breaks append-only history; use deterministic ids or upsert. (2) Dropping <code>PENDING</code> breaks Lab 2 consumers. Second round : the <code>specification.md</code> the migration cites is not in the repo — add it or summarise the requirements.	Fixed the seed and the enum; pointed to the specification already in the repo.	Merged 2026-09-25 (<code>0f0d881</code>); approved — I had missed the document on the second round and said so
#42 Authentication and requester regression	Changes requested. (1) A newly created Requester cannot create a ticket — <code>createTicket</code> answers <code>500</code> . (2) No Origin / CSRF check on state-changing requests, which api-spec §0 / §7 require. (3) Change Password leaves the user's other sessions alive. (4) PR description still has template placeholders. Optional: login timing reveals which emails exist, client ignores a mid-session <code>401</code> , three duplicated session loaders, "Problem appears resolved" allowed on Closed / Cancelled, the legacy-id <code>OR</code> in <code>ownedTicketFilter</code> .	Fixed items 1 – 4 in <code>16aa8b6</code> ; skipped the optional ones.	Merged 2026-09-26 (<code>7975e47</code>); approved , suggesting tests for the three fixes and <code>P2002</code> instead of a message regex
#44 IT Staff queue and ticket operations	Changes requested. (1) IT Priority not initialised from Requested Priority (BR-12). (2) Reassign asks the user to type a user id, but ui-spec §6 requires selecting active IT Staff. (3) PR description did not match the code (roles, route names, menu label). Optional: status race, the resolved flag not cleared on Reopened, no Administrator <code>403</code> tests.	Fixed all three: IT Priority default with a test, an active-IT-Staff dropdown via <code>GET /api/staff/users</code> , corrected description.	Merged 2026-09-26 (<code>548cc59</code>); approved
#46 Administrator user management	Changes requested. (1) The search box loses focus on every keystroke, and stale responses are not discarded. Further items: tickets of demoted / deactivated IT Staff stay assigned, the last-Administrator rule is racy, a concurrent duplicate email (<code>P2002</code>) is not a <code>409</code> , a leftover <code>reset-password</code> route and password-field alias.	Fixed items 1 – 5: 300 ms debounce with stale responses dropped, unassign in the same transaction, a Serializable transaction for the last-Administrator rule, <code>P2002</code> → <code>409</code> , the alias removed.	Merged 2026-09-27 (<code>b713514</code>); approved

TokTickIT

TokTickIT is a full-stack IT ticketing portal built with a React + Express + PostgreSQL stack. Requesters sign in, raise tickets with attachments and follow them; IT Staff and Administrators get their own areas. Every request is authorised on the server from a session cookie.

Table of contents

- [Features](#)
- [Tech stack](#)
- [Project structure](#)
- [Requirements](#)
- [Installation](#)
- [Configuration](#)
- [Usage](#)
- [Available scripts](#)
- [Tests](#)
- [Lab documentation](#)
- [Contact](#)

Features

- **Authentication (Lab 3)** — email + password login, bcrypt-hashed passwords, an `httpOnly` session cookie backed by a `Session` table, logout that revokes the session, login throttling, and a forced password change for accounts on an initial password. Every protected endpoint checks the session and role on the server.
- **Roles** — Requester, IT Staff and Administrator, each with its own navigation and home screen; the wrong role gets a Forbidden state in the UI and a `403` from the API.
- **Requester ticketing (Lab 2)** — create tickets, list and search your own tickets, open a read-only detail view, and attach, download or soft-remove files. Ownership is enforced from the session identity.
- **Public Comments and "Problem appears resolved" (Lab 3)** — a Requester comments on their own ticket and IT Staff on any ticket; the thread is readable by all three roles, newest first, and bodies are stored and rendered as plain text. A Requester can flag an open ticket as "appears resolved" (`requesterResolvedAt`) without touching its status.
- **IT Staff Ticket Queue (Lab 3)** — every ticket in the system with search, status / IT priority / owner / category filters, sortable columns and pagination, all done server-side (`GET /api/staff/tickets`). The queue state lives in the URL so a filtered view can be shared or returned to. Administrators see the same list read-only.
- **IT Staff ticket operations (Lab 3)** — claim, assign or unassign an owner, set an IT Priority independent of what the requester asked for, and move the ticket through a server-enforced status workflow (`New` → `Open` → `In Progress` → ... → `Closed`, with `Reopened` and `Cancelled`). Public Comments reach the requester; Internal Notes never do. Administrators see the same screen read-only.
- **Administrator user management (Lab 3)** — one screen to search the directory, filter by role, create an account with a one-time initial password, edit name, email, role and activation, and hand out a new initial password. Nobody is ever deleted: deactivation retires an account and signs it out immediately, and the server refuses both self-deactivation and removing the last active administrator.
- **Live health check** — `GET /api/health` runs `SELECT 1` against Postgres and returns `200 / ok` or `503 / error` based on real DB connectivity.

Tech stack

Layer	Technology
Frontend	React 19, TypeScript, Vite, Bootstrap 5

Layer	Technology
Backend	Node.js, Express, TypeScript
Database / ORM	PostgreSQL, Prisma
Testing	Vitest, React Testing Library (frontend), Vitest + Supertest (backend)
Linting	oxlint

Project structure

```
TokTickIT/
├── client/                # React + Vite frontend
│   └── src/
│       ├── App.tsx
│       └── components/CategoryList.tsx
├── server/               # Express + Prisma backend
│   ├── src/
│   │   ├── app.ts        # Express app & routes
│   │   ├── index.ts      # Entrypoint
│   │   ├── db.ts         # Prisma client
│   │   └── seed.ts       # DB seed script
│   ├── prisma/schema.prisma
│   └── tests/app.test.ts
├── e2e/                  # Playwright end-to-end suites (lab-02 flows + lab-03/)
├── docs/lab-0N/          # CPE334 lab write-ups (specification, API/UI spec, tests, AI usage, review)
└── package.json          # Root scripts that fan out to client/server
```

Requirements

- Node.js >= 18 (developed on v24)
- npm >= 10
- PostgreSQL >= 13 — either a local instance, a hosted connection string, or Docker (a `docker-compose.yml` is included)

Installation

```
git clone https://github.com/Chessuker/TokTickIT.git
cd TokTickIT
npm --prefix client install
npm --prefix server install
```

Configuration

Start a local PostgreSQL with Docker (listens on host port **5433** so it does not clash with an existing 5432 instance):

```
docker compose up -d
```

Then copy the example env file and fill in real values:

```
cp server/.env.example server/.env
```

`server/.env`:

```
PORT=5000
DATABASE_URL="postgres://postgres:postgres@localhost:5433/toktickit?schema=public"
CLIENT_ORIGIN=http://localhost:5173
```

The database value matches the bundled `docker-compose.yml`. Point it at your own instance if you are not using Docker. `CLIENT_ORIGIN` is the browser origin allowed to send the session cookie (CORS with credentials); change it only if the Vite dev server runs somewhere other than port 5173.

The frontend reads `VITE_API_URL` (defaults to `http://localhost:5000` if unset) — set it in a `client/.env` file if your API isn't running on the default port.

Then generate the Prisma client, apply the migrations, and seed the database. The seed is idempotent — running it again never duplicates rows:

```
npm run prisma:generate
npm run prisma:migrate
npm run prisma:seed
```

Usage

Run backend and frontend in separate terminals:

```
npm run dev:server # http://localhost:5000
npm run dev:client # http://localhost:5173
```

Open `http://localhost:5173` in a browser and sign in with one of the accounts below.

Local development accounts

The seed creates these accounts for local development only (never use them anywhere else). Re-running the seed resets each of them to the password and state listed here.

Name	Email	Password	Role	State
Jennifer Anderson	<code>jennifer.anderson@kmutt.ac.th</code>	<code>Requester1!</code>	Requester	ready
David Lee	<code>david.lee@kmutt.ac.th</code>	<code>Requester2!</code>	Requester	ready
Sarah Johnson	<code>sarah.johnson@kmutt.ac.th</code>	<code>Welcome123!</code>	Requester	must change password at first login
Michael Brown	<code>michael.brown@kmutt.ac.th</code>	<code>Welcome123!</code>	Requester	must change password at first login
Alex Smith	<code>alex.smith@kmutt.ac.th</code>	<code>Welcome123!</code>	Requester	inactive — login refused
Nattapong Srisuk	<code>nattapong.srisuk@kmutt.ac.th</code>	<code>Staff1!pass</code>	IT Staff	ready
Priya Raman	<code>priya.raman@kmutt.ac.th</code>	<code>Staff1!pass</code>	IT Staff	ready
Chen Wei	<code>chen.wei@kmutt.ac.th</code>	<code>Staff1!pass</code>	IT Staff	ready
Robert Wilson	<code>robert.wilson@kmutt.ac.th</code>	<code>Staff1!pass</code>	IT Staff	inactive — login refused
System Administrator	<code>admin@toktickit.xyz</code>	<code>Admin1!pass</code>	Administrator	ready

Requesters migrated from a Lab 2 database receive `Welcome123!` as their initial password once the seed has run, and must change it at first login.

The seed also creates 24 sample tickets numbered `TKT-2026-900001 ... TKT-2026-900024` across the four active Requesters, covering every status and priority, about a third unassigned and the rest owned by the three active IT Staff. That range is reserved: user-created tickets keep counting from `TKT-2026-000001`, and re-running the seed resets the sample tickets without touching anything else. Each worked ticket also carries a short Public Comment thread and, where IT Staff are involved, one or two Internal Notes.

Upgrading a Lab 2 database

The Lab 3 migration renames `RequesterUser` to `User` in place, so existing tickets and attachments keep their owners. To verify that on a database holding Lab 2 data:

```
npm --prefix server exec tsx scripts/verify-lab03-migration.ts before # snapshot counts on the Lab 2 schema
npm run prisma:migrate
npm --prefix server exec tsx scripts/verify-lab03-migration.ts after # compare, before seeding
npm run prisma:seed
```

Available scripts

Run from the repo root (each forwards to the relevant workspace):

Script	Description
<code>npm run dev:client</code>	Start the Vite dev server
<code>npm run dev:server</code>	Start the Express server with <code>tsx watch</code>
<code>npm run build:client</code>	Type-check and build the frontend
<code>npm run build:server</code>	Compile the backend with <code>tsc</code>
<code>npm run test:client</code>	Run frontend tests (Vitest)
<code>npm run test:server</code>	Run backend tests (Vitest + Supertest)
<code>npm run prisma:generate</code>	Regenerate the Prisma client
<code>npm run prisma:db:push</code>	Push <code>schema.prisma</code> to the database
<code>npm run prisma:migrate</code>	Apply pending migrations (<code>prisma migrate deploy</code>)
<code>npm run prisma:seed</code>	Seed reference data and local accounts — safe to re-run
<code>npm run test:e2e</code>	Run the Playwright suites against a migrated, seeded database

Additional server-only scripts (`npm --prefix server run ...`): `prisma:migrate`, `prisma:seed`.

Tests

```
npm run test:server # Supertest against Express, Prisma mocked - no live DB needed
npm run test:client # Vitest + React Testing Library
```

Both suites run without a database. The Playwright end-to-end suite (`npm run test:e2e`) needs PostgreSQL migrated and seeded, and starts the API and Vite itself. See [docs/lab-03/tests.md](#) for what each test covers.

Lab documentation

This repo doubles as the CPE334 lab submissions. Each lab's contract and evidence live under `docs/` :

- [docs/lab-03/](#) — specification, API spec, UI spec, test plan, issues, AI usage, review (current sprint)
- [docs/lab-02/](#) — Requester ticketing sprint
- [docs/lab-01/](#) — project foundation

Contact

Project author: [Chessuker](#) — repo: github.com/Chessuker/TokTickIT

Answer Part 2:

Spec-Driven Development · 5 points

Answer Part 2 — Spec-Driven Development

Link: [docs/lab-03/specification.md](#) — rendered in full after this page, with its companions [api-spec.md](#), [ui-spec.md](#) and [tests.md](#).

1. What the specification contains

Required by the lab sheet	Where
Numbered requirements	§4 — FR-01 ... FR-14 (scope in §3)
Business rules	§5 — BR-01 ... BR-31 (authentication, ownership and roles, status workflow, comments and notes, administrator safety, migration)
Authorization matrix or rules	§5 "Authorization matrix" — every operation × Requester / IT Staff / Administrator; §5 "Status workflow" — the transition matrix with the owner rule and the confirmations
Acceptance criteria	§9 — AC-01 ... AC-34, each in Given / When / Then form and each traced to tests in tests.md §3
Migration decisions	§7 "Data Changes" and "Migration strategy" — <code>RequesterUser</code> renamed to <code>User</code> in place so ids and ticket ownership survive; the documented initial password; <code>itPriority</code> copied from <code>priority</code> ; the seed plan; verification procedure in AC-31
Product Definition of Done	§10.1 (product) and §10.2 (course delivery), each item with its evidence
Design decisions	§11 — AD-01 ... AD-14 (session table over JWT, two tables for comments vs notes, server-computed <code>permittedTransitions</code> , ...)

2. Evidence the specification came before the implementation

The contract was committed, reviewed and merged before the first line of Lab 3 implementation was committed:

```
$ git log --format="%h %ad %s" --date=format:"%Y-%m-%d %H:%M" -- docs/lab-03/specification.md docs/lab-03/api-spec.md ...
492dd30 2026-09-15 00:46 docs(lab-03): Sprint 3 engineering contract
39cabce 2026-09-15 15:30 docs(lab-03): fill GitHub Issue numbers #36-#42
8c84d4c 2026-09-18 12:37 docs(lab-03): address review on #43 - auth matrix, BR-31, BR-07/10/11, AC-31

$ git log --merges --first-parent lab3-staging
4ad5d2e 2026-09-18 12:52 Merge pull request #43 from Chessuker/feature/36-lab3-spec-docs      ← contract merged
05f2133 2026-09-19 12:32 Merge pull request #44 from Chessuker/feature/37-auth-foundation  ← first implementation merged

$ git log --format="%h %ad %s" -- server/src/auth.ts      # the first Lab 3 implementation file
35986d0 2026-09-18 21:26 feat(#37): authentication foundation - ...      ← first implementation commit
```

Event	When
Contract first committed (492dd30)	2026-09-15 00:46
Contract revised after peer review on PR #43 (8c84d4c)	2026-09-18 12:37
Contract merged into lab3-staging (PR #43)	2026-09-18 12:52
First implementation commit (35986d0 , Issue #37)	2026-09-18 21:26
First implementation merged (PR #44)	2026-09-19 12:32

Later implementation issues edited the specification only to record a decision made while building (each in the same PR as the code, and named in its description) — for example the status enum reordered into workflow order for `sort=status` (#39), and in the release issue the Cancelled badge colour, darkened after the contrast check measured it at 4.39:1.

Lab 3 — Sprint Engineering Specification

Field	Detail
Project	TokTickIT
Sprint / Lab	CPE334 Lab 3 — Users, Roles, IT Staff Ticketing, and Admin Screens
Author	Thawat Boonsuk (67070501024)
Status	Draft — contract for Sprint 3, written before implementation
Last updated	2026-09-15

Field	Detail
Extends	Lab 2 specification — everything there stays in force unless a section below changes it
Related documents	api-spec.md , ui-spec.md , tests.md , reviewer.md , ai-use.md

1. Sprint Goal

Replace the Lab 2 Development Requester selector with real email/password authentication and three server-enforced roles (Requester, IT Staff, Administrator). IT Staff get a Ticket Queue and an operational Ticket Detail where they claim or reassign tickets, set IT Priority, move tickets through a defined status workflow, talk to the Requester through Public Comments and keep private Internal Notes. Administrators get one minimalist User Management screen. Every Lab 2 Requester function keeps working on the authenticated identity, and no existing Ticket or Attachment data is lost by the migration.

2. Stakeholder Request Interpretation

- **Who the users are now:** three kinds of people share one application. Requesters (as in Lab 2) submit and follow their own tickets. IT Staff work the queue. One or more Administrators keep the account list correct.
- **What problem they have today:** anyone can pick any requester from a dropdown, nobody can work a ticket after it is created, and there is no way to add a user without editing the seed. The system has no notion of who is allowed to do what.
- **What they expect after this sprint:**
 - Sign in with an email and password. A user given an initial password by an Administrator must pick a new one before seeing anything else.
 - See only the navigation and actions their role permits, and be refused by the server, not just the UI, when they try anything else.
 - Requesters keep creating and managing their own tickets and attachments exactly as in Lab 2, now under their own account, and can comment on a ticket and say "this looks fixed".
 - IT Staff find work in a searchable, filterable, sortable, paginated queue; open a ticket; take it or hand it to a colleague; set an IT Priority separate from what the Requester asked for; move it through New → ... → Closed; and write comments the Requester sees and notes the Requester never sees.
 - Administrators list, search, create, edit, activate/deactivate users, give them one role, and reset an initial password. Nothing more.
- **What "good" looks like:** the same Zen Green screens, extended rather than replaced; a Requester who tampers with a request still only ever sees their own data; an Administrator cannot lock everyone out by deactivating the last Administrator; a wrong password and an unknown email produce the same answer.
- **What I read as out of scope, and why:** everything in §3.2. In particular Actions Taken, SLA, notifications and any email delivery are named as later sprints by the handout, and self-registration would contradict "Administrators create accounts".

3. Scope

3.1 Included

- Login, logout, current-user retrieval, mandatory first-login password change (FR-01 ... FR-03).
- Server-side role-based authorization and Requester ownership checks on every protected endpoint (FR-04).
- Migration of `RequesterUser` into a real `User` model with credentials, role and activation state; removal of the Development Requester selector and its client state (FR-05, FR-14).
- All Lab 2 Requester functions (Create Ticket, My Tickets, Ticket Detail, attachment lifecycle) on the authenticated identity (FR-05).
- Public Comments on a ticket and the Requester's "Problem Appears Resolved" indication (FR-06, FR-07).
- IT Staff Ticket Queue with search, filters, sorting and pagination (FR-08).
- IT Staff Ticket Detail: ownership (claim/assign/reassign/unassign), IT Priority, permitted status transitions, Internal Notes, read access to attachments (FR-09 ... FR-12).
- Minimalist Administrator User Management: list, search, optional role filter, create, edit, one-role assignment, activate/deactivate, set a new initial password, with the safety rules in §5 (FR-13).
- Idempotent seed covering all three roles, active and inactive accounts, realistic tickets, comments and notes (FR-14).
- Zen Green extensions: Login and Change Password screens, role-aware application shell, status/priority/role badges, Public-vs-Internal visual distinction (ui-spec.md).

3.2 Excluded

ID	Excluded	Why
X-01	Email invitations, password-reset email, MFA, social login, SSO	Handout §4.2
X-02	Self-registration and Requester-created accounts	Accounts come only from an Administrator (handout §3)
X-03	Actions Taken by IT Staff, and the rule blocking resolution while actions are incomplete	Deferred to Lab 4 (handout §4.5)
X-04	SLA calculation, escalation, notification services	Handout §4.2
X-05	Dashboards or KPI analytics beyond queue counts	Handout §4.2
X-06	Multi-tenant organisations, departments, customer administration	Handout §4.2. The existing <code>department</code> column is kept but is read-only and not editable by anyone

ID	Excluded	Why
X-07	Production deployment or cloud infrastructure	Handout §4.2
X-08	Multiple roles per user, role history, account audit history	One <code>role</code> column (handout §5.1)
X-09	User deletion, bulk operations, import/export	Deactivation replaces deletion (handout §4.4)
X-10	Profile photo, extended profile fields	Handout §4.2
X-11	Account unlocking UI, administrator approval workflows	Login throttling is time-based and self-clearing (BR-07), so nothing needs unlocking
X-12	Mandatory pagination, multi-column sorting or multiple simultaneous filters on the user list	Handout §8.5 "not required"; the list is small and one search + one optional role filter is enough
X-13	Editing or deleting a Public Comment or Internal Note	Append-only in Lab 3 (handout §4.6)
X-14	IT Staff or Administrator creating tickets on a Requester's behalf	Not requested; keeps ownership rules simple
X-15	Requester reopening a Resolved/Closed ticket	Requester can only <i>indicate</i> resolution (BR-05); reopening is an IT Staff transition

4. Functional Requirements

ID	Requirement	Description	Priority
FR-01	Login	A user signs in with email and password. On success the server establishes an authenticated session and returns the user's identity and role. On failure the response is generic; an inactive account receives a distinct but non-revealing message.	Must
FR-02	Mandatory password change	A user flagged <code>mustChangePassword</code> is routed to a Change Password screen after login and cannot reach any other screen or data endpoint until a new valid password is saved.	Must
FR-03	Current user, shell and logout	The application shell shows the authenticated user's name and role, role-specific navigation, and Logout. Logout invalidates the session on the server; direct access afterwards is refused.	Must
FR-04	Server-side authorization	Every protected endpoint checks authentication, role and (for Requesters) ownership on the server. Hidden or disabled UI controls are feedback only.	Must
FR-05	Requester regression	Create Ticket, My Tickets, Ticket Detail and the attachment lifecycle from Lab 2 work unchanged for a logged-in Requester, using the session identity. The Development Requester selector, the <code>X-Requester-Id</code> header and the Change Requester action are removed.	Must
FR-06	Public Comments	A Requester (own ticket) or IT Staff (any ticket) appends a Public Comment; Requester, IT Staff and Administrator can read them, newest first, with author and time.	Must
FR-07	Problem Appears Resolved	A Requester marks their own non-terminal ticket as "appears resolved". The ticket records the time; IT Staff see an indicator; the status does not change.	Must
FR-08	IT Staff Ticket Queue	IT Staff see all tickets in a paginated list with search, filters (status, IT priority, owner, category), sorting, ownership and status badges, and an Open action. Administrators see the same list read-only.	Must
FR-09	Ticket ownership	IT Staff claim an unassigned ticket, assign or reassign it to an active IT Staff user, or unassign it.	Must
FR-10	IT Priority	IT Staff change a ticket's IT Priority (Low/Medium/High) independently of the Requested Priority, which stays as submitted.	Must
FR-11	Status workflow	IT Staff move a ticket only along the transitions in §5 (Transition matrix). Terminal-looking moves ask for confirmation in the UI; the server rejects anything not in the matrix.	Must
FR-12	Internal Notes	IT Staff append Internal Notes to a ticket; IT Staff and Administrators read them; Requesters are refused without seeing any content.	Must
FR-13	Administrator user management	An Administrator lists users (Name, Email, Role, Status, Edit), searches by name or email, optionally filters by role, creates a user with one role and an initial password, edits name/email/role/activation, and sets a new initial password. Safety rules BR-24 ... BR-27 apply.	Must
FR-14	Migration and seed	Existing <code>RequesterUser</code> rows become <code>User</code> rows with role Requester and a documented initial password; all Lab 2 tickets and attachments keep their owner. The seed is idempotent and creates the accounts, tickets, comments and notes listed in §7.	Must

5. Business Rules

BR-01 ... BR-05 are the handout's mandatory rules, kept verbatim.

Authentication and session

ID	Rule
BR-01	Only an active user with valid credentials may authenticate.

ID	Rule
BR-02	A user marked as requiring a password change cannot enter the normal application until a new valid password is saved.
BR-03	The authenticated user identity, not a requesterId supplied by the client, determines ownership of Requester operations.
BR-04	Public Comments are visible to the Requester, IT Staff, and Administrator. Internal Notes are visible only to IT Staff and Administrator.
BR-05	A Requester may indicate that the problem appears resolved, but cannot formally set the Ticket to Resolved or Closed.
BR-06	A failed login (unknown email or wrong password) answers 401 INVALID_CREDENTIALS with the same message in both cases. Only when the credentials are correct and the account is inactive does the server answer 403 ACCOUNT_INACTIVE , so an attacker cannot learn whether an email exists without already knowing its password.
BR-07	After 5 failed logins for the same email within 15 minutes the server answers 429 TOO_MANY_ATTEMPTS for that email until the window passes. Only 401 INVALID_CREDENTIALS responses count; a 403 ACCOUNT_INACTIVE answer (correct password, inactive account) does not increment the counter. The counter is in-memory (local lab), resets on a successful login, and is never shown to the user beyond "try again later".
BR-08	Password policy: 8–72 characters, at least one upper-case letter, one lower-case letter, one digit and one non-alphanumeric character. Applies to Change Password and to any initial password an Administrator sets.
BR-09	Passwords are stored only as bcrypt hashes (cost 10). A password or hash never appears in any API response, log line or seed output.
BR-10	A session is a random 256-bit token stored hashed in the Session table and delivered in an httpOnly , SameSite=Lax cookie. It expires 8 hours after login. Logout deletes the session row; an expired or deleted session answers 401 UNAUTHORIZED . Deactivating a user, changing their role, or setting a new initial password deletes all of that user's sessions; a successful Change Password deletes all of that user's sessions except the current one (BR-11).
BR-11	Change Password requires the current password, a new password satisfying BR-08 that differs from the current one, and a matching confirmation. Success clears mustChangePassword , keeps the current session and deletes every other session of that user, so a stolen cookie stops working once the password is changed.
BR-12	Email addresses are unique case-insensitively and stored lower-cased and trimmed. Login matching is case-insensitive.
BR-13	Every user has exactly one role: Requester , ITStaff or Administrator .

Ownership and roles

ID	Rule
BR-14	All Lab 2 ticket and attachment operations remain owner-scoped: a Requester reaching another Requester's ticket or attachment is answered 403 FORBIDDEN exactly as in Lab 2 (BR-04 there), with no ticket, attachment or note content in the body. IT Staff and Administrators may read any ticket and download any active attachment but may not add or remove attachments.
BR-15	A Ticket has zero or one owner. The owner must be an active user with role ITStaff . Claim sets the caller as owner; assign/reassign sets another active IT Staff; unassign clears the owner. An inactive or non-IT-Staff target is rejected with 400 VALIDATION_FAILED .
BR-16	itPriority is copied from the Requested Priority when a ticket is created (and by the migration for existing tickets). Only IT Staff may change it afterwards. The Requested Priority is immutable once the ticket exists.
BR-17	Administrators have read-only access to the queue, ticket detail, comments and internal notes. Any ticket mutation by an Administrator is 403 FORBIDDEN .
BR-31	Owner and IT Priority changes follow the ticket status: claim, assign, reassign, unassign and Set IT Priority are all 409 INVALID_TRANSITION on a Closed or Cancelled ticket; unassigning an InProgress ticket is 409 INVALID_TRANSITION (it must first move to another status or be reassigned); claiming or assigning a New ticket sets its status to Open in the same operation.

Status workflow

ID	Rule
BR-18	Statues are New , Open , InProgress , WaitingForRequester , Resolved , Closed , Reopened , Cancelled . A status change is accepted only if the pair appears in the transition matrix below; anything else is 409 INVALID_TRANSITION . Only IT Staff may change status.
BR-19	Moving to InProgress or Resolved requires an owner (409 INVALID_TRANSITION otherwise). Claiming a New ticket sets it to Open in the same operation.
BR-20	Resolved stamps resolvedAt ; Closed stamps closedAt ; Reopened clears resolvedAt , closedAt and requesterResolvedAt . Cancelled is terminal.
BR-21	The Requester's "appears resolved" indication sets requesterResolvedAt on an owned ticket whose status is not Resolved , Closed or Cancelled . Repeating it is a no-op (200 , same timestamp). On a terminal ticket it is 409 INVALID_TRANSITION .

Transition matrix (rows = current status, ✓ = permitted for IT Staff; ⚠ = UI asks for confirmation first):

From \ To	Open	InProgress	WaitingForRequester	Resolved	Closed	Reopened	Cancelled
New	✓	✓ (owner)	–	–	–	–	⚠
Open	–	✓ (owner)	✓	⚠ (owner)	–	–	⚠
InProgress	–	–	✓	⚠ (owner)	–	–	⚠

From \ To	Open	InProgress	WaitingForRequester	Resolved	Closed	Reopened	Cancelled
WaitingForRequester	–	✓ (owner)	–	⚠ (owner)	–	–	⚠
Resolved	–	–	–	–	⚠	✓	–
Closed	–	–	–	–	–	✓	–
Reopened	–	✓ (owner)	✓	⚠ (owner)	–	–	⚠
Cancelled	–	–	–	–	–	–	–

Comments and notes

ID	Rule
BR-22	Public Comments and Internal Notes are append-only. Body is trimmed, must be 1–2000 characters, and is stored and rendered as plain text (never interpreted as HTML). Author and creation time are set by the server.
BR-23	A Requester may comment only on their own ticket; IT Staff may comment on any ticket; an Administrator may read but not create comments. Internal Notes are created by IT Staff only and read by IT Staff and Administrators; a Requester calling any Internal Note endpoint is answered <code>403 FORBIDDEN</code> with no note content, count or existence hint.

Administrator safety

ID	Rule
BR-24	An Administrator creates a user with name, unique email, exactly one role, activation state and an initial password; the new user has <code>mustChangePassword = true</code> . A duplicate email is <code>409 CONFLICT</code> ; an unknown role is <code>400 VALIDATION_FAILED</code> .
BR-25	An Administrator may edit only name, email, role and <code>isActive</code> . An Administrator cannot deactivate their own account (<code>409 CONFLICT</code>).
BR-26	The system always keeps at least one active Administrator: deactivating the last active Administrator or changing their role is <code>409 CONFLICT</code> .
BR-27	Setting a new initial password stores its hash, sets <code>mustChangePassword = true</code> and deletes the user's sessions, so the user must sign in with it and change it. Users are never deleted; deactivation is the only way to retire an account, and a deactivated user's existing sessions are deleted immediately.

Regression, migration and safety

ID	Rule
BR-28	The migration renames <code>RequesterUser</code> to <code>User</code> in place: ids, emails, names, <code>department</code> and <code>isActive</code> are preserved, every migrated row gets role <code>Requester</code> , <code>mustChangePassword = true</code> , and the documented local initial password. Ticket and attachment counts and <code>requesterId</code> values are identical before and after.
BR-29	The seed is idempotent (upsert by <code>email</code> / <code>ticketNumber</code>) and never deletes. Seeded credentials are for local development only and are listed in the README, never in a response.
BR-30	Every protected endpoint distinguishes <code>401</code> (no valid session), <code>403</code> (authenticated but not permitted, or password change pending), <code>400</code> (invalid input), <code>404</code> (missing resource the caller could otherwise access), <code>409</code> (conflict or invalid transition) and <code>500</code> (generic message with a correlation id). <code>500</code> bodies never contain stack traces, SQL or file paths.

Authorization matrix

Operation	Requester	IT Staff	Administrator
Login / logout / <code>GET me</code> / change password	✓	✓	✓
Create ticket, list own tickets	✓ owner	–	–
View ticket detail (<code>GET /api/tickets/:id</code>)	✓ owner	✓ read	✓ read
Add / remove attachment	✓ owner	–	–
View / download attachment	✓ owner	✓ read	✓ read
Read Public Comments	✓ owner	✓	✓
Create Public Comment	✓ owner	✓	–
Indicate problem appears resolved	✓ owner	–	–
Ticket Queue, staff Ticket Detail	–	✓	✓ read
Claim / assign / reassign / unassign	–	✓	–
Set IT Priority	–	✓	–
Change status	–	✓	–
Read Internal Notes	– (403, no content)	✓	✓
Create Internal Note	–	✓	–
List / search users, create, edit, set initial password	–	–	✓

6. UI Specification Summary

Full details live in [ui-spec.md](#). Summary:

- **Theme:** unchanged Zen Green tokens. New pill badges for the eight statuses, IT Priority (same scale as Requested Priority, labelled "IT"), and the three roles.
- **Shell:** header shows the app name, role-specific navigation (Requester: My Tickets, Create Ticket · IT Staff: Queue · Administrator: Users, Queue), and a Profile menu with the user's name, role badge, Change Password and Logout. The Development Requester block and Change Requester button are gone.
- **Screens:** Login; Change Password (also reachable voluntarily from the Profile menu); Requester Ticket Detail gains a Public Comments panel and a "Problem appears resolved" action; IT Staff Ticket Queue (desktop table, tablet/mobile cards); IT Staff Ticket Detail with editable operational fields, tabs for Public Comments / Internal Notes / Attachments; Administrator Users list with a side panel for create/edit.
- **Modes and feedback:** every screen names its loading, saving, success, validation, empty, no-results, forbidden, not-found, conflict and safe-failure feedback in ui-spec.md §3, and the visual checklist V-01 ... V-14 is run at 1280 / 820 / 375 px.
- **Public vs Internal:** Internal Notes use an amber left border, an "Internal" label and a distinct composer heading so a private note is not typed into the public box.

7. Data Changes

PostgreSQL via Prisma. One migration, `20260915000000_lab03_users_roles_workflow`, written by hand so that existing rows are transformed rather than recreated.

User (renamed from RequesterUser ; legacy Lab 1 User table dropped)

Field	Type	Notes
id	String @id @default(uuid())	Unchanged — the same ids that <code>Ticket.requesterId</code> already points at
name	String	Editable by Administrator
email	String @unique	Lower-cased, trimmed (BR-12)
department	String?	Kept from Lab 2, read-only in Lab 3
role	Role @default(Requester)	<code>enum Role { Requester, ITStaff, Administrator }</code>
passwordHash	String	bcrypt. Migration fills existing rows with the hash of the documented initial password (BR-28)
mustChangePassword	Boolean @default(true)	Set by create-user, set-initial-password and the migration; cleared by Change Password
isActive	Boolean @default(true)	Unchanged
lastLoginAt	DateTime?	Stamped on successful login
createdAt , updatedAt	DateTime	Unchanged
relations	<code>tickets Ticket[] @relation("TicketRequester") , ownedTickets Ticket[] @relation("TicketOwner") , sessions Session[] , comments TicketComment[] , internalNotes TicketInternalNote[]</code>	

The legacy Lab 1 `User` table (id, email, name) held only the seed row `admin@toktickit.xyz` and was served by `/api/users`, which no screen uses. It is dropped in the same migration; its email is reused as the seeded Administrator.

Session (new)

Field	Type	Notes
id	String @id @default(uuid())	
tokenHash	String @unique	SHA-256 of the raw cookie token; the raw token is never stored
userId	String	FK → <code>User</code> , onDelete: Cascade
expiresAt	DateTime	login time + 8 h (BR-10)
createdAt	DateTime @default(now())	

Ticket (changed)

Field	Change
status	<code>TicketStatus</code> enum extended to <code>New</code> , <code>Open</code> , <code>InProgress</code> , <code>WaitingForRequester</code> , <code>Resolved</code> , <code>Closed</code> , <code>Reopened</code> , <code>Cancelled</code> . Existing rows stay <code>New</code>
priority	Unchanged; it is the Requested Priority and is immutable after create (BR-16). The API exposes it as <code>requestedPriority</code> on staff endpoints and keeps <code>priority</code> on Lab 2 endpoints
itPriority	New <code>TicketPriority</code> ; migration runs <code>UPDATE "Ticket" SET "itPriority" = "priority"</code>
ownerId	New <code>String?</code> , FK → <code>User</code> @relation("TicketOwner") , onDelete: SetNull
requesterResolvedAt	New <code>DateTime?</code> (BR-21)

Field	Change
resolvedAt , closedAt	New DateTime? (BR-20)
requester	Relation target renamed to User (@relation("TicketRequester")); onDelete: Restrict unchanged

TicketComment and TicketInternalNote (new, identical shape)

Field	Type	Notes
id	String @id @default(uuid())	
ticketId	String	FK → Ticket, onDelete: Cascade
authorId	String	FK → User, onDelete: Restrict
body	String	1–2000 chars, plain text (BR-22)
createdAt	DateTime @default(now())	

Two tables rather than one with a visibility column: a query that forgets a where on visibility would leak notes to Requesters, whereas a query against TicketComment cannot return a note at all (AD-03).

Indexes

Model	Index	Serves
User	@@index([role, isActive])	Assignee list (active IT Staff), Admin role filter, "last active Administrator" check
Session	@@index([userId]), @@index([expiresAt])	Delete-all-for-user on deactivation; expiry sweep
Ticket	@@index([ownerId, status]), @@index([itPriority]), @@index([updatedAt])	Queue filters "mine / unassigned", IT-priority filter, default queue ordering. Lab 2 indexes stay
TicketComment, TicketInternalNote	@@index([ticketId, createdAt])	Newest-first listing per ticket

Migration strategy (BR-28)

- 1. DROP TABLE "User" (legacy, no FKs point at it).
- 2. ALTER TABLE "RequesterUser" RENAME TO "User"; rename its indexes and the FK constraint on Ticket.requesterId.
- 3. Create enum Role; add role, passwordHash (default ''), mustChangePassword (default true), lastLoginAt to User.
- 4. ALTER TYPE "TicketStatus" ADD VALUE ... for the seven new statuses.
- 5. Add itPriority (nullable), UPDATE SET "itPriority" = "priority", then SET NOT NULL; add ownerId, requesterResolvedAt, resolvedAt, closedAt, FK and indexes.
- 6. Create Session, TicketComment, TicketInternalNote.
- 7. The seed (not the migration) writes the real bcrypt hash for every user whose passwordHash is '', so no hash is hard-coded in SQL. Until the seed runs, a migrated user cannot log in ('' never matches), which is the safe default.

Seed data (idempotent, BR-29)

Set	Rows	Notes
Requesters	4 active (Jennifer Anderson, Sarah Johnson, David Lee, Michael Brown), 1 inactive (Alex Smith)	The five Lab 2 rows, upserted by email. Jennifer (Requester1!) and David (Requester2!) are seeded with mustChangePassword = false so the Lab 2 ownership E2E can sign in as two requesters without a forced change; Sarah, Michael and Alex keep Welcome123! + mustChangePassword = true (first-login E2E uses Sarah)
IT Staff	3 active (Nattapong Srisuk, Priya Raman, Chen Wei), 1 inactive (Robert Wilson)	Password Staff1!pass, mustChangePassword = false
Administrator	1 active (admin@toktickit.xyz , "System Administrator")	Password Admin1!pass, mustChangePassword = false
Categories, Related Systems	unchanged from Lab 2	
Tickets	24 across the four active Requesters; every status at least twice; every priority; ~1/3 unassigned, the rest spread over the three active IT Staff	Upserted by ticketNumber (TKT-2026-9000xx), so they never collide with user-created tickets
Public Comments	~2 per non- New ticket, alternating Requester / owner	Plain, non-sensitive text
Internal Notes	1–2 on InProgress / WaitingForRequester / Resolved tickets	Plain, non-sensitive text

All seeded passwords are documented in README.md under "Local development accounts" and nowhere else.

8. API Contract

Full request/response shapes, validation and error codes are in [api-spec.md](#). Summary:

Area	Method and path	Roles
Auth	POST /api/auth/login · POST /api/auth/logout · GET /api/auth/me · POST /api/auth/change-password	any (login: anonymous)
Requester (Lab 2, now session-scoped)	POST /api/tickets · GET /api/tickets · GET /api/tickets/:id · POST /api/tickets/:id/attachments · GET /api/attachments/:id · GET /api/attachments/:id/download · PATCH /api/attachments/:id/remove	Requester (owner); attachment reads also IT Staff / Administrator
Comments	GET /api/tickets/:id/comments · POST /api/tickets/:id/comments · POST /api/tickets/:id/resolution-indication	per authorization matrix
Staff queue and detail	GET /api/staff/tickets · GET /api/staff/tickets/:id · GET /api/staff/assignees	IT Staff, Administrator (read)
Staff operations	POST /api/staff/tickets/:id/claim · PATCH /api/staff/tickets/:id/owner · PATCH /api/staff/tickets/:id/it-priority · PATCH /api/staff/tickets/:id/status	IT Staff
Internal notes	GET /api/staff/tickets/:id/internal-notes · POST /api/staff/tickets/:id/internal-notes	read: IT Staff, Administrator · create: IT Staff
Admin	GET /api/admin/users · POST /api/admin/users · GET /api/admin/users/:id · PATCH /api/admin/users/:id · POST /api/admin/users/:id/initial-password	Administrator
Removed	GET /api/requesters · GET/POST /api/users	—

Authentication mechanism: opaque session token in an `httpOnly` cookie (`toktickit_session`), validated on every request by `requireAuth`; role gate `requireRole(...)`; ownership resolved by the existing `findTicketForRequester` helper now fed from the session user (BR-03).

Status code meanings

Code	Error code	Meaning
200 / 201 / 204	—	Success
400	VALIDATION_FAILED	Invalid body, query or path input; <code>fields</code> names each problem
401	UNAUTHORIZED · INVALID_CREDENTIALS	No valid session · login failed (generic)
403	FORBIDDEN · ACCOUNT_INACTIVE · PASSWORD_CHANGE_REQUIRED	Role or ownership refused · valid credentials but inactive · session valid but password change pending
404	NOT_FOUND	Resource missing (only where the caller could otherwise access it)
409	CONFLICT · INVALID_TRANSITION	Duplicate email, last-Administrator or self-deactivation guard · status/ownership rule violated
413 / 415	FILE_TOO_LARGE · UNSUPPORTED_MEDIA_TYPE	Unchanged from Lab 2
429	TOO_MANY_ATTEMPTS	Login throttled (BR-07)
500	INTERNAL_ERROR	Generic message + correlation id

9. Acceptance Criteria

AC-01 ... AC-04 are the handout's examples, kept verbatim.

ID	Criterion
AC-01	Given an active user with valid credentials, when the user logs in, then the backend establishes authenticated access and returns the permitted user identity and role.
AC-02	Given a user who must change the initial password, when login succeeds, then normal application screens remain unavailable until a valid new password is saved.
AC-03	Given an authenticated Requester, when the client supplies another requesterId, then the backend still applies the authenticated identity and does not return another Requester's data.
AC-04	Given a Requester account, when an Internal Note endpoint is requested, then the operation is rejected without exposing note content.
AC-05	Given an unknown email or a wrong password, when login is attempted, then the server answers <code>401 INVALID_CREDENTIALS</code> with an identical message for both cases and the UI shows "Invalid email or password".
AC-06	Given an inactive account with correct credentials, when login is attempted, then the server answers <code>403 ACCOUNT_INACTIVE</code> , no session is created, and the UI says the account is inactive and to contact an administrator.
AC-07	Given five failed logins for one email within 15 minutes, when a sixth attempt is made, then the server answers <code>429 TOO_MANY_ATTEMPTS</code> even with the correct password.
AC-08	Given a logged-in user, when they log out, then the session row is deleted, the cookie is cleared, <code>GET /api/auth/me</code> answers <code>401</code> , and navigating back to an application URL redirects to Login.
AC-09	Given the Change Password screen, when the new password breaks BR-08, equals the current password, or the confirmation differs, then the server answers <code>400</code> with field errors and the UI shows them under the correct fields.

ID	Criterion
AC-10	Given a user with <code>mustChangePassword</code> , when a valid new password is saved, then <code>mustChangePassword</code> is cleared, the same session continues, and the user lands on their role's home screen.
AC-11	Given any role, when the shell renders, then only that role's navigation is shown, and typing another role's URL shows a forbidden state without loading data.
AC-12	Given direct API calls, when a Requester calls a staff or admin endpoint, IT Staff calls an admin endpoint, an Administrator calls a ticket-mutation endpoint, or anyone calls a protected endpoint without a session, then the answers are <code>403</code> , <code>403</code> , <code>403</code> and <code>401</code> respectively with no resource data.
AC-13	Given a logged-in Requester, when they create a ticket, list My Tickets, open a detail and add/download/remove an attachment, then everything behaves as the Lab 2 acceptance criteria describe, no <code>X-Requester-Id</code> header is sent, and <code>/select-requester</code> no longer exists.
AC-14	Given a Requester on their own ticket, when they post a Public Comment, then it appears newest-first with their name and server time; an empty or whitespace body is <code>400</code> ; a comment on another Requester's ticket is <code>403</code> .
AC-15	Given a Requester on an own ticket that is not Resolved/Closed/Cancelled, when they click "Problem appears resolved", then <code>requesterResolvedAt</code> is set, the status is unchanged, IT Staff see the indicator, and any attempt by the Requester to set status is <code>403</code> .
AC-16	Given IT Staff on the Ticket Queue, when the page loads, then tickets of all Requesters are listed with Ticket No, Created, Summary, Category, Requested Priority, IT Priority, Status, Owner and Updated, 10 per page, newest-updated first, with page metadata.
AC-17	Given the queue, when search, a status/priority/owner/category filter, a sort or a page is applied, then the list updates accordingly; a filter matching nothing shows a no-results state distinct from the empty state; an invalid parameter is <code>400</code> .
AC-18	Given an unassigned <code>New</code> ticket, when IT Staff click Claim, then the owner becomes the caller and the status becomes <code>Open</code> .
AC-19	Given a ticket, when IT Staff reassign it to another active IT Staff, then the owner changes; reassigning to an inactive or non-IT-Staff user is <code>400</code> .
AC-20	Given a ticket, when IT Staff change the IT Priority, then it is saved and the Requested Priority is unchanged.
AC-21	Given a ticket, when IT Staff request a transition in the matrix, then it is applied (with a confirmation dialog for Resolved, Closed and Cancelled); a transition not in the matrix is <code>409</code> <code>INVALID_TRANSITION</code> and the UI keeps the previous status.
AC-22	Given an unassigned ticket, when IT Staff try <code>InProgress</code> or <code>Resolved</code> , then the server answers <code>409</code> and the UI explains an owner is required.
AC-23	Given a ticket, when IT Staff add an Internal Note, then it appears in the Internal Notes panel with author and time; an Administrator can read it; the note is absent from every Requester-facing response.
AC-24	Given a ticket with attachments, when IT Staff or an Administrator open the staff detail, then active attachments are listed and downloadable, removed ones are shown as removed, and no add or remove control is offered (a direct call is <code>403</code>).
AC-25	Given an Administrator on Users, when the list loads, searches by partial name or email, or filters by role, then matching users show Name, Email, Role badge, Active/Inactive badge and Edit.
AC-26	Given the Create User panel, when a valid user is saved, then it appears in the list with <code>mustChangePassword</code> ; a duplicate email is <code>409</code> shown under the email field; a missing field or unknown role is <code>400</code> shown under its field.
AC-27	Given the Edit User panel, when name, email, role or activation is changed and saved, then the list reflects it and a deactivated user's next request answers <code>401</code> .
AC-28	Given a user, when the Administrator sets a new initial password, then the user's next login succeeds only with it and is immediately routed to Change Password.
AC-29	Given the Administrator's own account or the last active Administrator, when deactivation (or, for the last Administrator, a role change) is attempted, then the server answers <code>409</code> <code>CONFLICT</code> and the UI shows the reason inline.
AC-30	Given a Requester or IT Staff, when they open <code>/admin/users</code> or call any <code>/api/admin/*</code> endpoint, then the UI shows a forbidden state and the API answers <code>403</code> with no user data.
AC-31	Given a Lab 2 database with tickets and attachments, when the Lab 3 migration and seed run, then ticket and attachment counts are unchanged, every <code>requesterId</code> still resolves, <code>itPriority</code> equals <code>priority</code> , and one active migrated requester (e.g. Sarah Johnson) can log in with the documented initial password and is forced to change it; inactive migrated users are refused (<code>403</code> <code>ACCOUNT_INACTIVE</code>).
AC-32	Given a seeded database, when the seed runs again, then it succeeds and creates no duplicate users, tickets, comments or notes.
AC-33	Given Login, Change Password, Queue, Staff Ticket Detail and Users at 1280 / 820 / 375 px, when each is inspected, then it matches ui-spec.md with no clipping or horizontal overflow.
AC-34	Given the backend is unreachable or answers <code>500</code> , when Login, the Queue, Staff Ticket Detail or Users is used, then a safe failure message is shown, entered values are preserved, and no stack trace or internal detail is displayed.

Every AC maps to at least one planned test in [tests.md](#) §3.

10. Definition of Done

Status recorded on 2026-09-26 in Issue #42. A ticked box names its evidence; an unticked one says what completes it.

10.1 Product

- ☒ FR-01 ... FR-14 implemented; BR-01 ... BR-31 enforced on the server. — every FR row in [tests.md](#) §3 traces to passing tests.

- ☒ AC-01 ... AC-34 verified by the tests named in `tests.md`; every test passes on `main` from the documented commands; none skipped, disabled or commented out. — all 109 test rows Pass; 970 / 970 tests, 0 skipped, on `main` at the release merge `34eadf5` (`docs/Lab-03/test-runs/`, 2026-09-27).
- ☒ Authorization matrix and transition matrix implemented exactly as in §5; direct-API evidence captured for each refused row. — `ticketWorkflow.test.ts` compares every (from, to) pair with an independent copy of the matrix; `docs/Lab-03/test-runs/api-authorization.txt`, 29 checks.
- ☒ Migration applied to a database holding Lab 2 data with counts and ownership verified (AC-31); seed re-run twice with identical row counts (AC-32). — `tests.md` §5 "Migration and regression evidence"; UNIT-07.
- ☒ No plaintext password, hash or session token in any response, log or committed file; secrets only in `.env` (git-ignored) with `.env.example` updated. — `.env` ignored and untracked; API tests assert no `passwordHash` in responses; seed prints counts only.
- ☒ Development Requester selector, `X-Requester-Id`, `/api/requesters`, `/api/users` and the `sessionStorage` requester key removed from client, server, tests and E2E helpers. — the only remaining mentions are tests asserting the header is absent; `/api/users` answers 404.
- ☒ Every screen in `ui-spec.md` §3 shows its loading, validation, success, empty/no-results, forbidden, not-found, conflict and safe-failure feedback; V-01 ... V-14 checked at the three viewports. — `ui-spec.md` §5; `p5-*` ... `p8-*` screenshots.
- ☒ No console errors on the happy path of each role; no unhandled promise rejections in the server log. — `visual.spec.ts` "Clean console" asserts it for all three roles; the server log shows no errors across the full E2E run.
- ☒ `README.md` documents setup, migration, seed, local accounts and test commands for Lab 3.

10.2 Course delivery

- ☒ Sprint decomposed into GitHub Issues (see Appendix) tracked on the Kanban; all in Done at submission. — Issues #36 ... #42 all in Done; board captured in `artifacts/lab-03/screenshots/evidence/kanban-final.png` (Answer Part 1).
- ☒ Every Issue delivered through `feature/<issue>-<slug>` → pull request → `lab3-staging`; one release pull request `lab3-staging` → `main`. No direct commits to `main` or `lab3-staging`. — `git log --first-parent lab3-staging` shows only PR merges #43 ... #49; the release PR #50 merged `lab3-staging` into `main` (`34eadf5`).
- ☒ Each pull request peer-reviewed; `reviewer.md` records reviewer identity, PR links, comments given and received, responses and approvals. — all eight PRs (#43 ... #50) reviewed and approved by TeekhathatTT; six of theirs reviewed in return, each row linked to its GitHub review.
- ☒ The contract (this file, `api-spec.md`, `ui-spec.md`, `tests.md`) merged before the first implementation PR; the merge is screenshotted as evidence for Answer Part 2. — PR #43 merged 2026-09-18 (`4ad5d2e`), before #44 on 2026-09-19.
- ☒ `ai-use.md` names the LLM and lists 6–10 key prompts with a reflection. — 10 prompts.
- ☒ Screenshots under `artifacts/lab-03/screenshots/{authentication,staff-queue,staff-ticket-detail,user-management}/` at desktop, tablet and mobile. — 73 screenshots plus `requester/` and `evidence/`.
- ☒ One PDF with "Answer Part 1" ... "Answer Part 9" in order, built from `docs/lab-03/answer-part*.md`. — `node docs/lab-03/build-submission-pdf.mjs`.

11. Assumptions and Decisions

ID	Assumption / Decision	Rationale
AD-01	Session = random token in an <code>httpOnly SameSite=Lax</code> cookie, stored hashed in a <code>Session</code> table, rather than a JWT.	Logout and deactivation must revoke access immediately (handout §6.1 "logout invalidation"); a server-side row makes that a <code>DELETE</code> , whereas a JWT would need a denylist to achieve the same. <code>SameSite=Lax</code> covers CSRF for the cookie because every mutating endpoint is a JSON <code>POST</code> / <code>PATCH</code> that a cross-site form cannot produce; the API also refuses non-JSON bodies.
AD-02	<code>RequesterUser</code> is renamed to <code>User</code> in place instead of creating a new table and copying rows.	Ticket ownership must stay correct (handout §5.2). Renaming keeps every id and foreign key untouched, so there is nothing to re-point and nothing to get wrong.
AD-03	Public Comments and Internal Notes are two tables.	The only difference is who may read them, and that difference is the security boundary. Separate tables make "return notes to a Requester" impossible by query shape rather than by remembering a filter.
AD-04	Administrators are read-only on tickets; the owner must be IT Staff.	The handout keeps the two roles "conceptually separate" and lets the matrix decide. Read access satisfies BR-04 (Administrators see Internal Notes) and lets an Administrator check what a user is asking about; write access would double every staff test for no requested benefit.
AD-05	Requested Priority keeps its column and Lab 2 API name <code>priority</code> ; <code>itPriority</code> is a new column.	Renaming would break every Lab 2 test and client call for a cosmetic gain. Staff endpoints expose both under unambiguous names (<code>requestedPriority</code> , <code>itPriority</code>).
AD-06	Claiming a <code>New</code> ticket sets <code>Open</code> automatically.	"Open" means "someone has looked at it". Claim is exactly that event, and it removes a second click from the most common action.
AD-07	Login throttling is in-memory per email, 5 failures per 15 minutes.	Handout §4.4 asks for a login-attempt rule; a table would be over-engineering for a single-process lab server. The limit is per email, not per IP, because the lab runs behind <code>localhost</code> . Restarting the server clears it, which is acceptable locally and documented as such.
AD-08	Password policy is the one shown in the handout's mockup (8+, upper, lower, digit, special) with a 72-byte ceiling.	Matches the reference screen; 72 bytes is bcrypt's input limit, so longer input would be silently truncated.
AD-09	Comment and note bodies are 1–2000 characters, rendered as text nodes.	Long enough for a paragraph of troubleshooting, short enough to keep a thread readable on a phone. React escapes by default; the spec forbids <code>dangerouslySetInnerHTML</code> so the limit is the only remaining control.
AD-10	Queue defaults: 10 per page (5/10/25/50 selectable), sorted <code>updatedAt desc</code> ; searchable fields are ticket number and summary.	Same page sizes as My Tickets for a consistent feel. "Recently touched" is what an IT Staff scanning for work wants first; ticket number and summary are the two fields people quote back.
AD-11	Other Requester's ticket by id stays <code>403</code> (Lab 2 behaviour) rather than <code>404</code> .	Lab 2 AC-03 and its tests already require <code>403</code> ; ids are UUIDs so confirming existence reveals nothing useful; and the body never contains the resource. Internal Note endpoints are the exception in the other direction: they answer <code>403</code> to Requesters regardless of ticket ownership.

ID	Assumption / Decision	Rationale
AD-12	Cross-origin cookies: server sets <code>Access-Control-Allow-Origin</code> to <code>CLIENT_ORIGIN</code> (default <code>http://localhost:5173</code>) with <code>credentials: true</code> ; the client sends <code>credentials: 'include'</code> .	Keeps the Lab 2 topology (Vite on 5173, API on 5000) without adding a proxy; <code>localhost</code> ports are same-site so <code>SameSite=Lax</code> still applies.
AD-13	The seed writes bcrypt hashes; the migration leaves <code>passwordHash = ''</code> .	No hash is committed in SQL, and a migrated-but-unseeded user simply cannot log in, which is the safe failure.
AD-14	<code>department</code> stays on <code>User</code> but is not exposed for editing.	Dropping the column would discard Lab 2 data for no reason; adding editing would expand the Administrator screen beyond the handout's "basic account information".

Appendix — GitHub Issue Traceability

Issues [#36](#) – [#42](#).

Issue	Title	Covers
#36	Sprint 3 engineering contract	This document, <code>api-spec.md</code> , <code>ui-spec.md</code> , <code>tests.md</code>
#37	Authentication foundation	FR-01 ... FR-05, FR-14, BR-01 ... BR-14, BR-28 ... BR-30, §7, AC-01 ... AC-13, AC-31, AC-32
#38	Requester regression, Public Comments and resolution indication	FR-05 ... FR-07, BR-21 ... BR-23, AC-13 ... AC-15
#39	IT Staff Ticket Queue	FR-08, AD-10, AC-16, AC-17, AC-34
#40	IT Staff Ticket operations	FR-09 ... FR-12, BR-15 ... BR-23, BR-31, AC-18 ... AC-24
#41	Administrator user management	FR-13, BR-24 ... BR-27, AC-25 ... AC-30
#42	E2E, visual inspection, release integration	AC-33, AC-34, <code>ui-spec.md</code> §5, <code>tests.md</code> §4–§5, <code>ai-use.md</code> , PDF

Answer Part 3:

Test-Driven Development and Traceability · 10 points

Answer Part 3 — Test-Driven Development and Traceability

Link: [docs/Lab-03/tests.md](#) — rendered in full after this page: the planned tests (UNIT, API, UI, E2E, MIG) with their actual file paths and final status (§2), the acceptance-criterion traceability matrix (§3), the responsive checklist (§4), and the commands and results (§5).

1. Final run — every suite, nothing skipped

Suite	Command	Files	Tests	Passed	Failed	Skipped
Backend — unit and API/integration	<code>npm run test:server</code>	16	656	656	0	0
Frontend — UI component	<code>npm run test:client</code>	12	231	231	0	0
End-to-end — Playwright	<code>npx playwright test</code>	9	83	83	0	0
Total		37	970	970	0	0

The verbatim output of each command is in `test-runs/` — `server.txt`, `client.txt`, `e2e.txt` — with terminal colour codes stripped and nothing else changed; each file's first two lines name the command, the branch and the commit it ran against: `main` at the release merge `34eadf5` (PR #50), with only documentation uncommitted. The images below are those files rendered by `scripts/capture-test-runs.mjs`.

The end-to-end suite runs against the real stack (PostgreSQL migrated and seeded, the API on :5000, Vite on :5173):

```
docker compose up -d && npm run prisma:migrate && npm run prisma:seed && npm run test:e2e
```

2. Coverage by test level

Level the sheet names	Where it lives	Tests
Unit	<code>ticketWorkflow</code> (every status pair of the matrix, owner rule, timestamps) 172 · <code>queueQuery</code> 28 · <code>passwordPolicy</code> 10 · <code>session</code> 6 · <code>loginThrottle</code> 5 · <code>seed</code> 24 · <code>ticketNumber</code> 8	253
API / integration	<code>auth</code> 36 · <code>staff-queue</code> 38 · <code>staff-ticket-detail</code> 52 · <code>comments-notes</code> 44 · <code>users-admin</code> 69 · <code>app</code> 9	248
Authorization	<code>authorization.api.test.ts</code> 52 — every protected route without a session, every staff and admin route as the wrong role, tampered <code>requesterId</code> , revoked sessions — plus the role cases inside each API suite above	52
Regression (Lab 2)	<code>tickets.api</code> 64 and <code>attachments.api</code> 39 re-run on the session cookie; the Lab 2 component suites (<code>CreateTicketForm</code> , <code>MyTickets</code> , <code>TicketDetail</code> , <code>AppShell</code>); the Lab 2 E2E journeys <code>create-ticket</code> , <code>attachments</code> , <code>ownership</code>	103 API + 9 E2E + component
UI	12 component suites, 231 tests — every Lab 3 screen, its validation, busy, empty/no-results, forbidden, conflict and safe-failure states	231
End-to-end	<code>authentication</code> 11 · <code>requester-comments</code> 6 · <code>staff-queue</code> 6 · <code>staff-ticket-flow</code> 6 · <code>user-administration</code> 6 · <code>visual</code> 39 · Lab 2 journeys 9	83

Every acceptance criterion AC-01 ... AC-34 maps to at least one of these tests (tests.md §3), and every one of the 109 planned test rows in tests.md §2 is **Pass**.

3. Backend — unit and API/integration

```
TokTickIT - Backend - unit and API tests (npm run test:server)

$ npm run test:server
# docs/lab-03-rinal-evidence 8 34eadf5 + uncommitted docs/artifacts only (node = this commit) · 2024-09-27T08:30:12.195Z

> toktickit@1.0.0 test:server
> npm --prefix server run test

> toktickit-server@1.0.0 test
> vitest run

RUN v3.2.7 D:\OpalFolder\RMUTT\CPE334\TokTickIT\server

✓ tests/lab-03/ticketWorkflow.test.ts (172 tests) 28ms
✓ tests/ticketNumber.test.ts (8 tests) 12ms
✓ tests/app.test.ts (8 tests) 12ms
✓ tests/lab-03/comments-notes.api.test.ts (44 tests) 230ms
✓ tests/lab-03/staff-ticket-detail.api.test.ts (52 tests) 247ms
✓ tests/lab-03/staff-queue.api.test.ts (38 tests) 255ms
✓ tests/lab-03/authorization.api.test.ts (52 tests) 276ms
✓ tests/tickets.api.test.ts (64 tests) 36ms
✓ tests/lab-03/queueQuery.test.ts (28 tests) 10ms
✓ tests/lab-03/session.test.ts (6 tests) 11ms
✓ tests/lab-03/passwordPolicy.test.ts (10 tests) 6ms
✓ tests/lab-03/loginThrottle.test.ts (5 tests) 3ms
✓ tests/seeds.test.ts (24 tests) 99ms
✓ seed > uses bcrypt by default, producing a hash that verifies the seeded password 947ms
✓ tests/lab-03/auth.api.test.ts (36 tests) 468ms
✓ tests/attachments.api.test.ts (38 tests) 67ms
✓ tests/lab-03/users-admin.api.test.ts (68 tests) 84ms

Test Files 16 passed (16)
Tests 656 passed (656)
Start at 15:30:10
Duration 1.90s (transform 1.23s, setup 0ms, collect 6.27s, tests 4.71s, environment 3ms, prepare 2.35s)

stderr | tests/app.test.ts > Express API Endpoints > GET /api/categories returns a safe 500 envelope when the database call fails
[3]SlowDown[k614q] GET /api/categories: Error: connection refused
at D:\OpalFolder\RMUTT\CPE334\TokTickIT\server\tests\app.test.ts:109:63
at file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:155:11
at file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:752:26
at file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1897:20
at new Promise (<anonymous>)
at runWithTimeout (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1863:10)
at runTest (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1574:12)
at processTicksAndRejections (node:internal/process/task_queues:104:5)
at runSuite (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1729:8)
at runSuite (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1729:8)

stderr | tests/tickets.api.test.ts > POST /api/tickets - failure handling (api-spec §1.3) > returns a safe 500 envelope when the insert fails
[6]x[6]SlowDown[k615b] POST /api/tickets: Error: relation "Ticket" does not exist
at D:\OpalFolder\RMUTT\CPE334\TokTickIT\server\tests\tickets.api.test.ts:285:58
at file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:155:11
at file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:752:26
at file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1897:20
at new Promise (<anonymous>)
at runWithTimeout (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1863:10)
at runTest (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1574:12)
at processTicksAndRejections (node:internal/process/task_queues:104:5)
at runSuite (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1729:8)
at runSuite (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1729:8)

stderr | tests/attachments.api.test.ts > GET /api/attachments/:id/download (API-11, AC-09, BR-09, BR-10) > answers 404 when the row exists
but the stored file is gone
[attachment-integrity] missing stored file d4e5fe67-1111-4222-8333-444455556666 Error: ENOENT: no such file or directory, open
'C:\Users\ADMIN\AppData\Local\Temp\toktickit-uploads-s12FF0\never-written.pdf'
at open (node:internal/fs/promises:1281:29)
at readFile (node:internal/fs/promises:1529:14)
at D:\OpalFolder\RMUTT\CPE334\TokTickIT\server\src\app.ts:610:17 {
  errno: -4058,
  code: 'ENOENT',
  syscall: 'open',
  path: 'C:\Users\ADMIN\AppData\Local\Temp\toktickit-uploads-s12FF0\never-written.pdf'
}

stderr | tests/tickets.api.test.ts > GET /api/tickets - search, filter, sort, pagination (API-06, AC-10) > returns a safe 500 envelope when
the query fails
[11]609[6]SlowDown[k615b] GET /api/tickets: Error: relation "Ticket" does not exist
at D:\OpalFolder\RMUTT\CPE334\TokTickIT\server\tests\tickets.api.test.ts:562:7
at file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:155:11
at file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:752:26
at file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1897:20
at new Promise (<anonymous>)
at runWithTimeout (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1863:10)
at runTest (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1574:12)
at processTicksAndRejections (node:internal/process/task_queues:104:5)
at runSuite (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1729:8)
at runSuite (file:///D:/OpalFolder/RMUTT/CPE334/TokTickIT/server/node_modules/@vitest/runner/dist/chunk-hooks.js:1729:8)

npm run test:server
```

4. Frontend — UI component tests

```
● TokTickIT - Frontend - component tests (npm --prefix client run test -- --reporter=verbose)

$ npm --prefix client run test -- --reporter=verbose
# docs/lab-03-final-evidence @ 3eadf5 + uncommitted docs/artifacts only (code = this commit) · 2026-09-27T08:30:29.705Z

> client@0.0.0 test
> vitest run --reporter=verbose

RUN v1.1.0 /OpelFolder/DMIT/CPE334/TokTickIT/client

 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > shows a loading state and nothing else until the session check answers 11ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > redirects an anonymous visitor to /login with the attempted path in from (AC-08) 2ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > lets a signed-in user through to a route for their role 1ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > sends a user with mustChangePassword to /change-password from any other route (AC-02) 8ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > lets a user with mustChangePassword reach /change-password itself 1ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > renders the Forbidden state without loading the screen: Requester = /staff/queue (AC-11) 2ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > renders the Forbidden state without loading the screen: Requester = /admin/users (AC-11) 1ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > renders the Forbidden state without loading the screen: IT Staff = /admin/users (AC-11) 1ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > renders the Forbidden state without loading the screen: IT Staff = /tickets (AC-11) 1ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > renders the Forbidden state without loading the screen: Administrator = /tickets (AC-11) 1ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > points the Forbidden state at the role home 1ms
 ✓ src/components/lab-03/RequireAuth.test.tsx > RequireAuth (UI-09) > lets an Administrator into the shared staff area 5ms
 ✓ src/components/TicketDetail.test.tsx > TicketDetail - read-only presentation (UI-05, AC-05) > renders every ticket field as text 16ms
 ✓ src/components/lab-03/CommentsPanel.test.tsx > CommentsPanel - composer visibility (BR-17, BR-23) > offers the composer when the caller may comment 24ms
 ✓ src/components/lab-03/CommentsPanel.test.tsx > CommentsPanel - composer visibility (BR-17, BR-23) > renders the thread read-only, with no composer, when the caller may not comment 2ms
 ✓ src/components/lab-03/CommentsPanel.test.tsx > CommentsPanel - composer visibility (BR-17, BR-23) > shows a retrievable error when the thread cannot be loaded 4ms
 ✓ src/components/lab-03/CommentsPanel.test.tsx > CommentsPanel > relativeTime > 2026-08-25T11:59:00.000Z - just now 0ms
 ✓ src/components/lab-03/CommentsPanel.test.tsx > relativeTime > 2026-08-25T11:59:00.000Z - 1 minute ago 0ms
 ✓ src/components/lab-03/CommentsPanel.test.tsx > relativeTime > 2026-08-25T11:59:00.000Z - 25 minutes ago 0ms
 ✓ src/components/lab-03/CommentsPanel.test.tsx > relativeTime > 2026-08-25T09:00:00.000Z - 3 hours ago 0ms
 ✓ src/components/lab-03/CommentsPanel.test.tsx > relativeTime > 2026-08-24T12:00:00.000Z - 2 days ago 0ms
 ✓ src/components/lab-03/CommentsPanel.test.tsx > relativeTime > falls back to a locale date once the comment is older than a month 1ms
 ✓ src/components/lab-03/CommentsPanel.test.tsx > relativeTime > returns an empty string for an unparseable value 0ms
 ✓ src/components/CreateTicketForm.test.tsx > CreateTicketForm > CreateTicketForm - master data (screen load) > populates the Category and Related System dropdowns from the API 22ms
 ✓ src/components/CreateTicketForm.test.tsx > CreateTicketForm - master data (screen load) > offers the three requested priorities with no ticket number or status input 9ms
 ✓ src/components/lab-03/login.test.tsx > Login - client validation (UI-01, AC-05) > shows an error under each empty field and sends no request 27ms
 ✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - layout and read-only group (UI-14, AC-24) > shows the header badges and the read-only ticket fields 17ms
 ✓ src/components/TicketDetail.test.tsx > TicketDetail - read-only presentation (UI-05, AC-05) > renders no editable control among the ticket fields 4ms
 ✓ src/components/AppShell.test.tsx > AppShell - identity and role navigation (UI-08, AC-11) > shows the user name and a role badge in the header 22ms
 ✓ src/components/AppShell.test.tsx > AppShell - identity and role navigation (UI-08, AC-11) > renders only the Requester navigation 4ms
 ✓ src/components/AppShell.test.tsx > AppShell - identity and role navigation (UI-08, AC-11) > renders only the IT Staff navigation 2ms
 ✓ src/components/AppShell.test.tsx > AppShell - identity and role navigation (UI-08, AC-11) > renders only the Administrator navigation 2ms
 ✓ src/components/MyTickets.test.tsx > MyTickets - list rendering (UI-04, AC-04) > renders one table row per ticket with the ticket number and summary 34ms
 ✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - table (UI-10, AC-16) > lists every ticket with the nine columns in order and an Open action 34ms
 ✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - table (UI-10, AC-16) > shows both priorities as distinct badges, the status label, owner or Unassigned, and the You tag 6ms
 ✓ src/components/lab-03/UserManagement.test.tsx > UserManagement - list (UI-21, AC-25) > shows name, email, role badge, status badge and Edit, sorted by name 37ms
 ✓ src/components/lab-03/UserManagement.test.tsx > UserManagement - list (UI-21, AC-25) > marks the signed-in administrator with "you" 4ms
 ✓ src/components/CreateTicketForm.test.tsx > CreateTicketForm - validation (UI-05, AC-01) > renders an error under every required field when submitting an empty form 14ms
 ✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - layout and read-only group (UI-14, AC-24) > offers three operational controls and a Claim button for a ticket the caller does not own 20ms
 ✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - layout and read-only group (UI-14, AC-24) > keeps the queue query string on Back to Queue 4ms
 ✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - layout and read-only group (UI-14, AC-24) > shows a not-found state for an unknown ticket 8ms
 ✓ src/components/AppShell.test.tsx > AppShell - identity and role navigation (UI-08, AC-11) > has no Development Requester block and no Change Requester control (BR-03) 2ms
 ✓ src/components/AppShell.test.tsx > AppShell - identity and role navigation (UI-08, AC-11) > links the app name to the role home 1ms
 ✓ src/components/AppShell.test.tsx > AppShell - identity and role navigation (UI-08, AC-11) > collapses to the app name and Log out while a password change is pending (AC-02) 2ms
 ✓ src/components/TicketDetail.test.tsx > TicketDetail - read-only presentation (UI-05, AC-05) > offers no edit, save, status, owner or IT-priority control anywhere on the screen 20ms
 ✓ src/components/TicketDetail.test.tsx > TicketDetail - read-only presentation (UI-05, AC-05) > shows IT Priority as a badge and an unassigned owner as an explicit placeholder 2ms
 ✓ src/components/TicketDetail.test.tsx > TicketDetail - read-only presentation (UI-05, AC-05) > shows the owner's name once IT Staff have claimed the ticket 7ms
 ✓ src/components/TicketDetail.test.tsx > TicketDetail - attachment list (BR-10, V-10) > lists an active attachment with its size, upload date and both actions 3ms
 ✓ src/components/MyTickets.test.tsx > MyTickets - list rendering (UI-04, AC-04) > renders every column the screen specifies 11ms
 ✓ src/components/MyTickets.test.tsx > MyTickets - list rendering (UI-04, AC-04) > shows a status badge and a priority badge on each row 4ms
 ✓ src/components/MyTickets.test.tsx > MyTickets - list rendering (UI-04, AC-04) > links each row to its ticket detail 1ms
 ✓ src/components/CreateTicketForm.test.tsx > CreateTicketForm - validation (UI-05, AC-01) > blocks the submit - no ticket is posted while the form is invalid 10ms
 ✓ src/components/lab-03/UserManagement.test.tsx > UserManagement - list (UI-21, AC-25) > offers no Delete control anywhere (BR-27) 5ms
 ✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - table (UI-10, AC-16) > marks a requester-resolved ticket with the check icon before its status 8ms
```

npm run test:client — 1 of 7

```

the form is disabled 10ms
✓ src/components/lab-03/UserManagement.test.tsx > UserManagement - list (UI-21, AC-25) > offers no delete control anywhere (BR-27) 5ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - table (UI-10, AC-16) > marks a requester-resolved ticket with the
check icon before its status 5ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - table (UI-10, AC-16) > shows the result line and requests the
documented defaults 1ms
✓ src/components/lab-03/ChangePassword.test.tsx > ChangePassword - live rules panel and validation (UI-06, AC-09) > lists the five BR-08
rules and ticks each one as the new password satisfies it 54ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - attachment list (BR-10, V-10) > shows a removed attachment with its reason and
timestamp and no download button 2ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - claim and owner (UI-15, AC-18, AC-19) > claims a New ticket: owner
becomes the caller and the status becomes Open 117ms
✓ src/components/MyTickets.test.tsx > MyTickets - list rendering (UI-04, AC-04) > identifies the caller by the session cookie, never by a
header or query parameter (UI-20, AC-18) 3ms
✓ src/components/MyTickets.test.tsx > MyTickets - list rendering (UI-04, AC-04) > renders a stacked card list instead of a table on a mobile
viewport 68ms
✓ src/components/AppShell.test.tsx > AppShell - profile menu and logout (UI-08, AC-08) > opens a menu with Change password and Log out 8ms
✓ src/components/CreateTicketForm.test.tsx > CreateTicketForm - validation (UI-03, AC-01) > marks the offending field invalid and links the
message to it 107ms
✓ src/components/lab-03/ChangePassword.test.tsx > ChangePassword - live rules panel and validation (UI-06, AC-09) > requires all three
fields and sends nothing when they are empty 10ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - table (UI-10, AC-16) > Open navigates to the staff ticket detail
11ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - table (UI-10, AC-16) > renders the same screen for an Administrator
8ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - attachment list (BR-10, V-10) > downloads an active attachment through the API with
the session cookie 103ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - attachment list (BR-10, V-10) > reports a refused download instead of failing
silently 6ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - claim and owner (UI-15, AC-18, AC-19) > assigns another IT Staff
member from the dropdown 11ms
✓ src/components/AppShell.test.tsx > AppShell - profile menu and logout (UI-08, AC-08) > navigates to /change-password from the menu 127ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - claim and owner (UI-15, AC-18, AC-19) > confirms before taking a
ticket away from its current owner 12ms
✓ src/components/AppShell.test.tsx > AppShell - profile menu and logout (UI-08, AC-08) > calls logout and lands on /login 124ms
✓ src/components/CreateTicketForm.test.tsx > CreateTicketForm - validation (UI-03, AC-01) > rejects a summary that is too short 214ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - claim and owner (UI-15, AC-18, AC-19) > rejects a malformed email without a request 36ms
✓ src/components/AppShell.test.tsx > AppShell - profile menu and logout (UI-08, AC-08) > posts to /api/auth/logout with credentials and
forgets the user (through the real provider) 103ms
✓ src/components/AppShell.test.tsx > AppShell - identity change discards loaded data > reumounts the routed subtree when a different user
signs in 7ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - claim and owner (UI-15, AC-18, AC-19) > unassigns with the
Unassigned option, and reports the 409 when the ticket is In Progress 76ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - IT priority (UI-16, AC-20) > saves the new IT priority without
touching the requested one 9ms
✓ src/components/lab-03/UserManagement.test.tsx > UserManagement - list (UI-21, AC-25) > searches by name or email, debounced 41ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - status (UI-17, AC-21, AC-22) > offers only the permitted
transitions plus the current status 21ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - status (UI-17, AC-21, AC-22) > hides the owner-only targets and
explains why when the ticket is unassigned (AC-22) 11ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - removal modal (UI-06, AC-09, BR-09) > keeps Confirm disabled until a reason is typed
30ms
✓ src/components/lab-03/UserManagement.test.tsx > UserManagement - list (UI-21, AC-25) > filters by role 103ms
✓ src/components/MyTickets.test.tsx > MyTickets - search, filter and pagination (UI-04, AC-10) > re-queries with the search term and narrows
the visible rows 45ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - toolbar (UI-11, AC-17) > debounces the search and re-queries with the
term 45ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - status (UI-17, AC-21, AC-22) > applies an unconfirmed transition
straight away 103ms
✓ src/components/lab-03/Login.test.tsx > Login - client validation (UI-01, AC-05) > clears a field error as soon as the field is edited
33ms
✓ src/components/lab-03/Login.test.tsx > Login - client validation (UI-01, AC-05) > offers a show/hide toggle on the password field with
aria-pressed 5ms
✓ src/components/lab-03/Login.test.tsx > Login - client validation (UI-01, AC-05) > explains that passwords are reset by an administrator
(AC-01) 4ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - status (UI-17, AC-21, AC-22) > confirms before moving to Resolved
137ms
✓ src/components/lab-03/ChangePassword.test.tsx > ChangePassword - live rules panel and validation (UI-06, AC-09) > flags a mismatch under
the confirmation field 70ms
✓ src/components/CreateTicketForm.test.tsx > CreateTicketForm - validation (UI-03, AC-01) > clears a field error as soon as the field is
corrected 60ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - status (UI-17, AC-21, AC-22) > confirms before moving to Cancelled
13ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - removal modal (UI-06, AC-09, BR-09) > re-disables Confirm when the reason is cleared
or is only whitespace 464ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - toolbar (UI-11, AC-17) > status chips toggle and send a repeated
status parameter 33ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - status (UI-17, AC-21, AC-22) > cancelling the dialog leaves the
status alone 142ms
✓ src/components/lab-03/Badges.test.tsx > StatusBadge > New - "New" with sg-badge-status-new 21ms
✓ src/components/lab-03/Badges.test.tsx > StatusBadge > Open - "Open" with sg-badge-status-open 2ms
✓ src/components/lab-03/Badges.test.tsx > StatusBadge > InProgress - "In Progress" with sg-badge-status-in-progress 2ms
✓ src/components/lab-03/Badges.test.tsx > StatusBadge > WaitingForRequester - "Waiting for Requester" with sg-badge-status-waiting 2ms
✓ src/components/lab-03/Badges.test.tsx > StatusBadge > Reopened - "Reopened" with sg-badge-status-reopened 3ms
✓ src/components/lab-03/Badges.test.tsx > StatusBadge > Resolved - "Resolved" with sg-badge-status-resolved 1ms
✓ src/components/lab-03/Badges.test.tsx > StatusBadge > Closed - "Closed" with sg-badge-status-closed 1ms
✓ src/components/lab-03/Badges.test.tsx > StatusBadge > Cancelled - "Cancelled" with sg-badge-status-cancelled 1ms
✓ src/components/lab-03/Badges.test.tsx > PriorityBadge and IfPriorityBadge > requested Low 1ms
✓ src/components/lab-03/Badges.test.tsx > PriorityBadge and IfPriorityBadge > requested Medium 1ms
✓ src/components/lab-03/Badges.test.tsx > PriorityBadge and IfPriorityBadge > requested High 1ms
✓ src/components/lab-03/Badges.test.tsx > PriorityBadge and IfPriorityBadge > IT Low carries the IT prefix and its own class 1ms
✓ src/components/lab-03/Badges.test.tsx > PriorityBadge and IfPriorityBadge > IT Medium carries the IT prefix and its own class 1ms
✓ src/components/lab-03/Badges.test.tsx > PriorityBadge and IfPriorityBadge > IT High carries the IT prefix and its own class 1ms
✓ src/components/lab-03/Badges.test.tsx > RoleBadge and ActiveBadge > Requester - "Requester" 1ms
✓ src/components/lab-03/Badges.test.tsx > RoleBadge and ActiveBadge > ITStaff - "IT Staff" 1ms
✓ src/components/lab-03/Badges.test.tsx > RoleBadge and ActiveBadge > Administrator - "Administrator" 1ms
✓ src/components/lab-03/Badges.test.tsx > RoleBadge and ActiveBadge > renders Active and Inactive 1ms
✓ src/components/lab-03/Badges.test.tsx > OwnerName and RequesterResolvedBadge > shows the name, or the italic Unassigned placeholder 2ms
✓ src/components/lab-03/Badges.test.tsx > OwnerName and RequesterResolvedBadge > writes the indication and carries the timestamp on hour
15ms

```

npm run test:client — 2 of 7

```

✓ src/components/lab-03/Badge.test.tsx > Badge and ActiveBadge > renders Active and Inactive 2ms
✓ src/components/lab-03/Badge.test.tsx > OwnerName and RequesterResolvedBadge > shows the name, or the italic Unassigned placeholder 2ms
✓ src/components/lab-03/Badge.test.tsx > OwnerName and RequesterResolvedBadge > writes the indication and carries the timestamp on hover 17ms
✓ src/components/lab-03/UseManagement.test.tsx > UseManagement - list (UI-21, AC-23) > shows the no-results state when nothing matches 87ms
✓ src/components/lab-03/UseManagement.test.tsx > UseManagement - list (UI-21, AC-23) > renders cards instead of a table on mobile (AC-33) 25ms
✓ src/components/lab-03/UseManagement.test.tsx > UseManagement - list (UI-21, AC-23) > shows a retryable failure on a 500 (AC-34) 25ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - status (UI-17, AC-21, AC-22) > keeps the previous status and shows the conflict when the server answers 409 (AC-21) 79ms
✓ src/components/MyTickets.test.tsx > MyTickets - search, filter and pagination (UI-04, AC-10) > finds a ticket by its ticket number 62ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - status (UI-17, AC-21, AC-22) > keeps the confirmation dialog open and shows the error when a confirmed change is refused 155ms
✓ src/components/MyTickets.test.tsx > MyTickets - search, filter and pagination (UI-04, AC-10) > filters by category through the dropdown 153ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - tabs, notes and attachments (UI-18, AC-23, AC-24) > shows three tabs with counts and follows the Web-SPA tabs pattern 82ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - tabs, notes and attachments (UI-18, AC-23, AC-24) > renders the Internal Notes panel with its own styling and composer 64ms
✓ src/components/MyTickets.test.tsx > MyTickets - search, filter and pagination (UI-04, AC-10) > filters by status through the dropdown 107ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - toolbar (UI-11, AC-17) > IT priority, owner and category filters map to their parameters 543ms
✓ src/components/MyTickets.test.tsx > MyTickets - search, filter and pagination (UI-04, AC-10) > sends the chosen sort option 112ms
✓ src/components/lab-03/ChangePassword.test.tsx > ChangePassword - live rules panel and validation (UI-06, AC-09) > flags a new password equal to the current one under the new-password field 76ms
✓ src/components/lab-03/Login.test.tsx > Login - invalid credentials (UI-02, AC-05) > shows the generic callout, clears the password, keeps the email and focuses the password 887ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - removal modal (UI-06, AC-09, BR-09) > sends the reason and moves the file into the removed list 63ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - toolbar (UI-11, AC-17) > the sort select and the sortable headers drive the sort parameter and aria-sort 302ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - tabs, notes and attachments (UI-18, AC-23, AC-24) > posts an internal note to the staff endpoint, never to the comments one (AC-03) 461ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - tabs, notes and attachments (UI-18, AC-23, AC-24) > shows the two composers as visibly distinct panels (V-13) 77ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - tabs, notes and attachments (UI-18, AC-23, AC-24) > lists attachments read-only: Download on active files, no upload and no Remove (AC-24) 86ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - removal modal (UI-06, AC-09, BR-09) > closes without removing anything when Cancel is pressed 450ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - upload zone (AC-06, AC-07, AC-08) > uploads a picked file and shows it in the active list 61ms
✓ src/components/lab-03/ChangePassword.test.tsx > ChangePassword - live rules panel and validation (UI-06, AC-09) > flags a new password that breaks the rules 82ms
✓ src/components/MyTickets.test.tsx > MyTickets - search, filter and pagination (UI-04, AC-10) > restores the full list when the filters are cleared 124ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - tabs, notes and attachments (UI-18, AC-23, AC-24) > downloads an attachment through the API with the session cookie 149ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - upload zone (AC-06, AC-07, AC-08) > rejects a disallowed type in the browser without calling the API 92ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - upload zone (AC-06, AC-07, AC-08) > surfaces a server rejection under the upload control 52ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - toolbar (UI-11, AC-17) > pages with the queue page sizes and returns to page 1 when a filter changes 498ms
✓ src/components/lab-03/Login.test.tsx > Login - inactive and throttled (UI-03, AC-06, AC-07) > shows the inactive-account callout on 409 ACCOUNT_INACTIVE 638ms
✓ src/components/lab-03/UseManagement.test.tsx > UseManagement - create panel (UI-22, AC-26) > collects the fields, shows the password rules live and creates the user 110ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - Administrator (UI-14, BR-17) > renders the operational fields as values, with no controls and no composers 63ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - upload zone (AC-06, AC-07, AC-08) > disables the picker once five files are active (AC-08) 152ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - ownership guard (AC-03, BR-04) > shows access denied instead of ticket data on a 403 10ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - ownership guard (AC-03, BR-04) > shows a not-found screen for a ticket that does not exist 12ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - ownership guard (AC-03, BR-04) > sends the session cookie on every read and never an X-Requester-Id header (UI-23) 8ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - Public Comments (UI-19, AC-14, BR-22) > lists the thread newest-first with author name, role badge and time 28ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - Public Comments (UI-19, AC-14, BR-22) > shows "No comments yet." for an empty thread 26ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - Public Comments (UI-19, AC-14, BR-22) > renders a comment body as text, never as HTML 15ms
✓ src/components/MyTickets.test.tsx > MyTickets - search, filter and pagination (UI-04, AC-10) > pages through the list with Previous and Next 214ms
✓ src/components/MyTickets.test.tsx > MyTickets - search, filter and pagination (UI-04, AC-10) > jumps to a page by its number 113ms
✓ src/components/CreateTicketForm.test.tsx > CreateTicketForm - validation (UI-03, AC-01) > shows server-supplied field errors under the matching fields 176ms
✓ src/components/lab-03/ChangePassword.test.tsx > ChangePassword - live rules panel and validation (UI-06, AC-09) > maps server field errors onto the three fields 677ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - busy states (V-09) > shows Posting... on Post Comment and on Add Internal Note 54ms
✓ src/components/lab-03/StaffTicketDetail.test.tsx > StaffTicketDetail - busy states (V-09) > shows Saving... on Confirm and on the control while a change is in flight 186ms
✓ src/components/TicketDetail.test.tsx > TicketDetail - Public Comments (UI-19, AC-14, BR-22) > posts a comment with the session cookie and re-renders the thread 545ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - toolbar (UI-11, AC-17) > Clear filters drops every filter and the search, and is disabled when nothing is set 712ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - toolbar (UI-11, AC-17) > reads its initial state from the URL so a queue link can be shared or returned to 30ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - states (UI-12, AC-17, AC-34) > shows skeleton rows while loading 5ms
✓ src/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - states (UI-12, AC-17, AC-34) > shows the empty state when the system has no tickets 22ms
✓ src/components/lab-03/Login.test.tsx > Login - inactive and throttled (UI-03, AC-06, AC-07) > shows the throttled callout on 429 and disables the button for the cooldown 762ms
✓ src/components/MyTickets.test.tsx > MyTickets - search, filter and pagination (UI-04, AC-10) > returns to page 1 when a filter changes, so a server error is not skipped past 71ms

```

npm run test:client — 3 of 7

```

disables the button for the cooldown 742ms
✓ sro/components/MyTickets.test.tsx > MyTickets - search, filter and pagination (UI-04, AC-10) > returns to page 1 when a filter changes, so a narrowest set is not skipped past 711ms
✓ sro/components/MyTickets.test.tsx > MyTickets - empty vs. no-results (UI-09, AC-19) > shows the empty state, and only the empty state, when the requester has no tickets 11ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - Public Comments (UI-19, AC-14, BR-22) > refuses an empty or whitespace comment under the textarea without calling the API 34ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - create panel (UI-22, AC-26) > shows a duplicate email under the Email field (AC-26) 957ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - Public Comments (UI-19, AC-14, BR-22) > turns the counter red and disables Post Comment past 2000 characters 11ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - create panel (UI-22, AC-26) > offers an Initial Password only on create, with a show/hide toggle 132ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - create panel (UI-22, AC-26) > closes without saving on Cancel 107ms
✓ sro/components/lab-03/ChangePassword.test.tsx > ChangePassword - live rules panel and validation (UI-06, AC-09) > posts the three values as JSON with credentials: include 710ms
✓ sro/components/lab-03/ChangePassword.test.tsx > ChangePassword - forced mode (UI-07, AC-02, AC-10) > shows the forced wording, Continue, and no Cancel 12ms
✓ sro/components/lab-03/ChangePassword.test.tsx > ChangePassword - forced mode (UI-07, AC-02, AC-10) > renders the shell without navigation while the change is pending 21ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - Public Comments (UI-19, AC-14, BR-22) > keeps the typed text and shows the error when the server refuses the post 36ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - "Problem appears resolved" (UI-19, AC-15, BR-21) > offers the button on an open ticket and none of the staff controls 11ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - edit panel (UI-23, AC-27, AC-29) > prefills the fields and saves the changes 21ms
✓ sro/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - states (UI-12, AC-17, AC-34) > shows a distinct no-results state when a filter matches nothing 72ms
✓ sro/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - states (UI-12, AC-17, AC-34) > shows the Forbidden state on a 403 without rendering any ticket 15ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - "Problem appears resolved" (UI-19, AC-15, BR-21) > confirms in a dialog, posts the indication and swaps the button for the indicator 192ms
✓ sro/components/lab-03/Login.test.tsx > Login - failure handling (UI-04, AC-34) > shows the safe message with Retry and preserves the entered values on a network failure 76ms
✓ sro/components/MyTickets.test.tsx > MyTickets - empty vs. no-results (UI-09, AC-19) > shows the no-results state, and only that, when a search matches nothing 66ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - "Problem appears resolved" (UI-19, AC-15, BR-21) > closes the dialog without posting when Cancel is pressed 12ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - "Problem appears resolved" (UI-19, AC-15, BR-21) > shows the indicator instead of the button once the ticket already carries the indication 15ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - "Problem appears resolved" (UI-19, AC-15, BR-21) > does not offer the button on a Resolved ticket 10ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - "Problem appears resolved" (UI-19, AC-15, BR-21) > does not offer the button on a Closed ticket 10ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - "Problem appears resolved" (UI-19, AC-15, BR-21) > does not offer the button on a Cancelled ticket 11ms
✓ sro/components/TicketDetail.test.tsx > TicketDetail - "Problem appears resolved" (UI-19, AC-15, BR-21) > keeps the dialog open and shows the server error on a 409 11ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - edit panel (UI-23, AC-27, AC-29) > confirms before deactivating, and says the user is signed out 31ms
✓ sro/components/lab-03/ChangePassword.test.tsx > ChangePassword - forced mode (UI-07, AC-02, AC-10) > publishes the updated user and navigates to the role home on success 69ms
✓ sro/components/MyTickets.test.tsx > MyTickets - empty vs. no-results (UI-09, AC-19) > distinguishes the two states by message and by call to action 41ms
✓ sro/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - states (UI-12, AC-17, AC-34) > shows a safe failure with Retry on a 509, keeping the entered search, and reopens 49ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - edit panel (UI-23, AC-27, AC-29) > cancelling the confirmation sends nothing 30ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - edit panel (UI-23, AC-27, AC-29) > disables the Active toggle on the administrator's own account, with the reason (AC-29) 81ms
✓ sro/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - states (UI-12, AC-17, AC-34) > Retry repeats the same request after a network failure 172ms
✓ sro/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - mobile (UI-19, AC-30) > renders cards, not a table, at the mobile media query 49ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - edit panel (UI-23, AC-27, AC-29) > disables the toggle and the role select for the last active administrator (AC-29, BR-24) 106ms
✓ sro/components/CreateTicketForm.test.tsx > CreateTicketForm - submitting state > disables the button and shows a busy label while the request is in flight 144ms
✓ sro/components/lab-03/Login.test.tsx > Login - failure handling (UI-04, AC-34) > shows the safe message on a 500 79ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - edit panel (UI-23, AC-27, AC-29) > leaves the controls enabled once a second active administrator exists 6ms
✓ sro/components/MyTickets.test.tsx > MyTickets - empty vs. no-results (UI-09, AC-19) > leaves the no-results state via Clear Filters 74ms
✓ sro/components/MyTickets.test.tsx > MyTickets - failure handling > shows an error callout with a retry instead of a misleading empty state 17ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - edit panel (UI-23, AC-27, AC-29) > shows the server's 409 inline when a guest is reached anyway (AC-29) 29ms
✓ sro/components/lab-03/ChangePassword.test.tsx > ChangePassword - voluntary mode > shows the voluntary wording, Save password and Cancel, and stays with a success callout 68ms
✓ sro/components/lab-03/StaffTicketQueue.test.tsx > StaffTicketQueue - search box and history (UI-11) > follows Back to an earlier search, and keeps what is typed after Clear Filters 97ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - initial password and access (UI-24, AC-28, AC-30) > sets a new initial password and confirms the user must change it 38ms
✓ sro/components/lab-03/Login.test.tsx > Login - failure handling (UI-04, AC-34) > shows the busy state while the request is in flight 79ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - initial password and access (UI-24, AC-28, AC-30) > shows the server's rejection under the password field 317ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - initial password and access (UI-24, AC-28, AC-30) > shows the forbidden state, and no user data, for a non-administrator (AC-30) 8ms
✓ sro/components/lab-03/ChangePassword.test.tsx > ChangePassword - voluntary mode > shows the safe failure message when the server is unreachable 70ms
✓ sro/components/lab-03/Login.test.tsx > Login - failure handling (UI-04, AC-34) > posts JSON with credentials: include to /api/auth/login 89ms
✓ sro/components/CreateTicketForm.test.tsx > CreateTicketForm - success (AC-01) > shows the ticket number returned by the server and a way onward 189ms
✓ sro/components/lab-03/ChangePassword.test.tsx > ChangePassword - busy state (V-09) > shows Saving... and disables Continue while the request is in flight 85ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - busy states (V-09) > shows Saving... on Save User while the create request is in flight 99ms
✓ sro/components/lab-03/UserManagement.test.tsx > UserManagement - busy states (V-09) > shows Setting... on Set Initial Password while the request is in flight 91ms

```

npm run test:client — 4 of 7

[illegible]

stderr | src/components/lab-03/StafficketQueue.test.jsx > StafficketQueue – states (UI-12, AC-17, AC-34) > shows skeleton rows while loading

An update to StafficketQueue inside a test was not wrapped in act(...).

When testing, code that causes React state updates should be wrapped into act(...):

```
act(() => {
  // fire events that update state */
});
/* assert on the output */
```

This ensures that you're testing the behavior the user would see in the browser. Learn more at <https://react.dev/link/wrap-tests-with-act>

An update to StafficketQueue inside a test was not wrapped in act(...).

When testing, code that causes React state updates should be wrapped into act(...):

```
act(() => {
  // fire events that update state */
});
/* assert on the output */
```

This ensures that you're testing the behavior the user would see in the browser. Learn more at <https://react.dev/link/wrap-tests-with-act>

An update to StafficketQueue inside a test was not wrapped in act(...).

When testing, code that causes React state updates should be wrapped into act(...):

```
act(() => {
  // fire events that update state */
});
/* assert on the output */
```

This ensures that you're testing the behavior the user would see in the browser. Learn more at <https://react.dev/link/wrap-tests-with-act>

An update to StafficketQueue inside a test was not wrapped in act(...).

When testing, code that causes React state updates should be wrapped into act(...):

```
act(() => {
  // fire events that update state */
});
/* assert on the output */
```

This ensures that you're testing the behavior the user would see in the browser. Learn more at <https://react.dev/link/wrap-tests-with-act>

stderr | src/components/lab-03/StafficketQueue.test.jsx > StafficketQueue – states (UI-12, AC-17, AC-34) > shows skeleton rows while loading

An update to StafficketQueue inside a test was not wrapped in act(...).

When testing, code that causes React state updates should be wrapped into act(...):

```
act(() => {
  // fire events that update state */
});
/* assert on the output */
```

This ensures that you're testing the behavior the user would see in the browser. Learn more at <https://react.dev/link/wrap-tests-with-act>

stderr | src/components/lab-03/StafficketQueue.test.jsx > StafficketQueue – search box and history (UI-11) > follows Back to an earlier search, and keeps what is typed after Clear filters

An update to MemoryRouter inside a test was not wrapped in act(...).

When testing, code that causes React state updates should be wrapped into act(...):

```
act(() => {
  // fire events that update state */
});
/* assert on the output */
```

This ensures that you're testing the behavior the user would see in the browser. Learn more at <https://react.dev/link/wrap-tests-with-act>

stderr | src/components/lab-03/StafficketQueue.test.jsx > StafficketQueue – search box and history (UI-11) > follows Back to an earlier search, and keeps what is typed after Clear filters

An update to StafficketQueue inside a test was not wrapped in act(...).

When testing, code that causes React state updates should be wrapped into act(...):

```
act(() => {
  // fire events that update state */
});
/* assert on the output */
```

This ensures that you're testing the behavior the user would see in the browser. Learn more at <https://react.dev/link/wrap-tests-with-act>

stderr | src/components/lab-03/StafficketQueue.test.jsx > StafficketQueue – search box and history (UI-11) > follows Back to an earlier search, and keeps what is typed after Clear filters

An update to StafficketQueue inside a test was not wrapped in act(...).

When testing, code that causes React state updates should be wrapped into act(...):

```
act(() => {
  // fire events that update state */
});
/* assert on the output */
```

This ensures that you're testing the behavior the user would see in the browser. Learn more at <https://react.dev/link/wrap-tests-with-act>

npm run test:client — 6 of 7

When testing, code that causes React state updates should be wrapped into `act(...)`:

```
act() => {
  /* fire events that update state */
});
/* assert on the output */
```

This ensures that you're testing the behavior the user would see in the browser. Learn more at <https://react.dev/link/wrap-tests-with-act>

An update to `StaffTicketQueue` inside a test was not wrapped in `act(...)`.

When testing, code that causes React state updates should be wrapped into `act(...)`:

```
act() => {
  /* fire events that update state */
});
/* assert on the output */
```

npm run test:client — 7 of 7

5. End-to-end — Playwright

```
● TokTickIT - End-to-end - Playwright (npx playwright test)

$ npx playwright test --reporter=list
# docs/lab-03-final-evidence @ 9eadf9 + uncommitted docs/artifacts only (code = this commit) · 2024-09-27T08:32:23.853Z

Running 93 tests using 1 worker

ok 1 [chromium] > e2e/lab-03/attachments.spec.ts:18:7 > Attachment lifecycle (E2E-02) > upload, download, remove with a reason, then download is refused (1.4s)
ok 2 [chromium] > e2e/lab-03/attachments.spec.ts:58:7 > Attachment lifecycle (E2E-02) > a removed attachment is refused by the API as well as hidden in the UI (1.3s)
ok 3 [chromium] > e2e/lab-03/attachments.spec.ts:97:7 > Attachment lifecycle (E2E-02) > rejects a disallowed file type without attaching it (AC-07) (1.0s)
ok 4 [chromium] > e2e/lab-03/create-ticket.spec.ts:18:7 > Create ticket (E2E-01) > create a ticket, then open it and find the same data (1.2s)
ok 5 [chromium] > e2e/lab-03/create-ticket.spec.ts:58:7 > Create ticket (E2E-01) > the new ticket appears in My Tickets under its number (1.0s)
ok 6 [chromium] > e2e/lab-03/create-ticket.spec.ts:90:7 > Create ticket (E2E-01) > an invalid form is refused with errors under the offending fields (834ms)
ok 7 [chromium] > e2e/lab-03/authentication.spec.ts:23:7 > Login, shell and logout (E2E-01) > an unknown email and a wrong password show the same generic message (918ms)
ok 8 [chromium] > e2e/lab-03/authentication.spec.ts:37:7 > Login, shell and logout (E2E-01) > an inactive account with the right password is told it is inactive (541ms)
ok 9 [chromium] > e2e/lab-03/authentication.spec.ts:44:7 > Login, shell and logout (E2E-01) > a valid login shows the name and role in the shell and lands on My Tickets (420ms)
ok 10 [chromium] > e2e/lab-03/authentication.spec.ts:55:7 > Login, shell and logout (E2E-01) > the session survives a reload (845ms)
ok 11 [chromium] > e2e/lab-03/authentication.spec.ts:64:7 > Login, shell and logout (E2E-01) > visiting/login while signed in goes straight to the role home (831ms)
ok 12 [chromium] > e2e/lab-03/authentication.spec.ts:72:7 > Login, shell and logout (E2E-01) > logout ends the session: Back and direct URLs both land on Login (1.7s)
ok 13 [chromium] > e2e/lab-03/authentication.spec.ts:101:7 > Login, shell and logout (E2E-01) > an anonymous visitor is sent to Login and returned after signing in (865ms)
ok 14 [chromium] > e2e/lab-03/authentication.spec.ts:135:7 > Initial password change (E2E-02, MFG-02) > a first login is forced through Change Password before the app opens (1.6s)
ok 15 [chromium] > e2e/lab-03/authentication.spec.ts:154:7 > Role navigation and forbidden pages (E2E-03) > a Requester sees only Requester limits and is refused the staff and admin areas (1.1s)
ok 16 [chromium] > e2e/lab-03/requester-comments.spec.ts:178:7 > Role navigation and forbidden pages (E2E-03) > IT Staff land on the queue, see the Queue link, and are refused /admin/users (1.0s)
ok 17 [chromium] > e2e/lab-03/authentication.spec.ts:191:7 > Role navigation and forbidden pages (E2E-03) > an Administrator lands on Users and sees Users and Queue (594ms)
ok 18 [chromium] > e2e/lab-03/requester-comments.spec.ts:18:7 > Public Comments on the Requester Ticket Detail (E2E-04, AC-14) > a requester posts a comment and sees it newest-first with name, role and time (1.6s)
ok 19 [chromium] > e2e/lab-03/requester-comments.spec.ts:42:7 > Public Comments on the Requester Ticket Detail (E2E-04, AC-14) > an empty comment is refused under the textarea and nothing is posted (1.5s)
ok 20 [chromium] > e2e/lab-03/requester-comments.spec.ts:133:7 > Public Comments on the Requester Ticket Detail (E2E-04, AC-14) > a comment body is rendered as text, never as markup (1.5s)
ok 21 [chromium] > e2e/lab-03/requester-comments.spec.ts:67:7 > Public Comments on the Requester Ticket Detail (E2E-04, AC-14) > the thread is visible to IT Staff and the Administrator through the same detail (2.8s)
ok 22 [chromium] > e2e/lab-03/requester-comments.spec.ts:146:7 > "Problem appears resolved" (E2E-04, AC-15, BR-21) > confirming replaces the button with the indicator and leaves the status alone (1.3s)
ok 23 [chromium] > e2e/lab-03/requester-comments.spec.ts:127:7 > "Problem appears resolved" (E2E-04, AC-15, BR-21) > cancelling the dialog changes nothing (1.2s)
ok 24 [chromium] > e2e/lab-03/staff-queue.spec.ts:18:7 > IT Staff Ticket Queue (E2E-05, AC-16, AC-17) > lists tickets of every requester with the nine columns and pages them (1.2s)
ok 25 [chromium] > e2e/lab-03/staff-queue.spec.ts:38:7 > IT Staff Ticket Queue (E2E-05, AC-16, AC-17) > filters by status chips, owner and IT priority, and sorts by status in workflow order (1.7s)
ok 26 [chromium] > e2e/lab-03/staff-queue.spec.ts:45:7 > IT Staff Ticket Queue (E2E-05, AC-16, AC-17) > the requester-resolved icon shows on a flipped row and sortable headers set aria-sort (1.6s)
ok 27 [chromium] > e2e/lab-03/staff-queue.spec.ts:80:7 > IT Staff Ticket Queue (E2E-05, AC-16, AC-17) > an Administrator sees the same queue: a Requester is refused (1.5s)
ok 28 [chromium] > e2e/lab-03/staff-queue.spec.ts:90:7 > IT Staff Ticket Queue (E2E-05, AC-16, AC-17) > a Requester gets the Forbidden state and a 403 from the API (799ms)
ok 29 [chromium] > e2e/lab-03/staff-queue.spec.ts:101:7 > IT Staff Ticket Queue (E2E-05, AC-16, AC-17) > renders cards instead of a table at mobile width with no horizontal scroll (AC-33) (707ms)
ok 30 [chromium] > e2e/lab-03/staff-ticket-flow.spec.ts:23:7 > IT Staff ticket operations (E2E-05) > claim - IT priority - In Progress - comment - internal note - Resolved - Closed, then the requester view (3.4s)
ok 31 [chromium] > e2e/lab-03/staff-ticket-flow.spec.ts:89:7 > IT Staff ticket operations (E2E-05) > the owner role: In Progress and Resolved are not offered while unassigned (AC-22) (1.1s)
ok 32 [chromium] > e2e/lab-03/staff-ticket-flow.spec.ts:122:7 > IT Staff ticket operations (E2E-05) > a transition outside the matrix is refused and the screen keeps the real status (AC-21) (1.7s)
ok 33 [chromium] > e2e/lab-03/staff-ticket-flow.spec.ts:140:7 > IT Staff ticket operations (E2E-05) > an Administrator reads the ticket and its notes but changes nothing (BR-17) (3.7s)
ok 34 [chromium] > e2e/lab-03/staff-ticket-flow.spec.ts:150:7 > IT Staff ticket operations (E2E-05) > the staff detail lists attachments read-only, with no add or remove (AC-24) (1.8s)
ok 35 [chromium] > e2e/lab-03/staff-ticket-flow.spec.ts:214:7 > IT Staff ticket operations (E2E-05) > IT Staff see the requester's comment and "appears resolved" indicator (E2E-04, AC-14, AC-15) (2.4s)
ok 36 [chromium] > e2e/lab-03/user-administration.spec.ts:30:7 > Administrator user management (E2E-06) > search and filter the directory (AC-25) (2.2s)
ok 37 [chromium] > e2e/lab-03/user-administration.spec.ts:85:7 > Administrator user management (E2E-06) > create an IT Staff account; the new user is forced to change the password at first login (AC-26, AC-28) (2.6s)
ok 38 [chromium] > e2e/lab-03/user-administration.spec.ts:99:7 > Administrator user management (E2E-06) > edit a role, and the guards on self and the last Administrator (AC-29, AC-28) (1.4s)
ok 39 [chromium] > e2e/lab-03/user-administration.spec.ts:153:7 > Administrator user management (E2E-06) > deactivating a user signs them out immediately (AC-27, BR-27) (2.0s)
ok 40 [chromium] > e2e/lab-03/user-administration.spec.ts:162:7 > Administrator user management (E2E-06) > setting a new initial password forces another change at the next login (AC-28) (3.5s)
ok 41 [chromium] > e2e/lab-03/user-administration.spec.ts:221:7 > Administrator user management (E2E-06) > a Requester and IT Staff are refused the screen and the API (AC-30) (1.9s)
ok 42 [chromium] > e2e/lab-03/visual.spec.ts:79:11 > Responsive and visual pass (E2E-07, AC-33) > desktop 1280px > Login (R-01 ... R-03) (40ms)
ok 43 [chromium] > e2e/lab-03/visual.spec.ts:85:11 > Responsive and visual pass (E2E-07, AC-33) > desktop 1280px > Change Password, forced (R-04, R-05) (58ms)
ok 44 [chromium] > e2e/lab-03/visual.spec.ts:94:11 > Responsive and visual pass (E2E-07, AC-33) > desktop 1280px > Ticket Queue (R-06 ... R-10) (94ms)
ok 45 [chromium] > e2e/lab-03/visual.spec.ts:105:11 > Responsive and visual pass (E2E-07, AC-33) > desktop 1280px > Staff Ticket Detail (R-12 ... R-14) (591ms)
ok 46 [chromium] > e2e/lab-03/visual.spec.ts:113:11 > Responsive and visual pass (E2E-07, AC-33) > desktop 1280px > My Tickets (Requester) (84ms)
ok 47 [chromium] > e2e/lab-03/visual.spec.ts:121:11 > Responsive and visual pass (E2E-07, AC-33) > desktop 1280px > Requester Ticket Detail with Public Comments (977ms)
```

npx playwright test — 1 of 2

```
ok 46 [chromium] > e2e\lab-03\visual.spec.ts:113:11 > Responsive and visual pass (E2E-07, AC-33) > desktop 1280px > My Tickets (Requester) (868ms)
ok 47 [chromium] > e2e\lab-03\visual.spec.ts:121:11 > Responsive and visual pass (E2E-07, AC-33) > desktop 1280px > Requester Ticket Detail with Public Comments (873ms)
ok 48 [chromium] > e2e\lab-03\visual.spec.ts:132:11 > Responsive and visual pass (E2E-07, AC-33) > desktop 1280px > Users (R-17 ... R-19) (730ms)
ok 49 [chromium] > e2e\lab-03\visual.spec.ts:79:11 > Responsive and visual pass (E2E-07, AC-33) > tablet 820px > Login (R-01 ... R-03) (427ms)
ok 50 [chromium] > e2e\lab-03\visual.spec.ts:85:11 > Responsive and visual pass (E2E-07, AC-33) > tablet 820px > Change Password, forced (R-04, R-05) (691ms)
ok 51 [chromium] > e2e\lab-03\visual.spec.ts:96:11 > Responsive and visual pass (E2E-07, AC-33) > tablet 820px > Ticket Queue (R-08 ... R-10) (907ms)
ok 52 [chromium] > e2e\lab-03\visual.spec.ts:105:11 > Responsive and visual pass (E2E-07, AC-33) > tablet 820px > Staff Ticket Detail (R-12 ... R-14) (853ms)
ok 53 [chromium] > e2e\lab-03\visual.spec.ts:113:11 > Responsive and visual pass (E2E-07, AC-33) > tablet 820px > My Tickets (Requester) (921ms)
ok 54 [chromium] > e2e\lab-03\visual.spec.ts:121:11 > Responsive and visual pass (E2E-07, AC-33) > tablet 820px > Requester Ticket Detail with Public Comments (933ms)
ok 55 [chromium] > e2e\lab-03\visual.spec.ts:132:11 > Responsive and visual pass (E2E-07, AC-33) > tablet 820px > Users (R-17 ... R-19) (720ms)
ok 56 [chromium] > e2e\lab-03\visual.spec.ts:79:11 > Responsive and visual pass (E2E-07, AC-33) > mobile 375px > Login (R-01 ... R-03) (413ms)
ok 57 [chromium] > e2e\lab-03\visual.spec.ts:85:11 > Responsive and visual pass (E2E-07, AC-33) > mobile 375px > Change Password, forced (R-04, R-05) (548ms)
ok 58 [chromium] > e2e\lab-03\visual.spec.ts:96:11 > Responsive and visual pass (E2E-07, AC-33) > mobile 375px > Ticket Queue (R-08 ... R-10) (943ms)
ok 59 [chromium] > e2e\lab-03\visual.spec.ts:105:11 > Responsive and visual pass (E2E-07, AC-33) > mobile 375px > Staff Ticket Detail (R-12 ... R-14) (911ms)
ok 60 [chromium] > e2e\lab-03\visual.spec.ts:113:11 > Responsive and visual pass (E2E-07, AC-33) > mobile 375px > My Tickets (Requester) (792ms)
ok 61 [chromium] > e2e\lab-03\visual.spec.ts:121:11 > Responsive and visual pass (E2E-07, AC-33) > mobile 375px > Requester Ticket Detail with Public Comments (878ms)
ok 62 [chromium] > e2e\lab-03\visual.spec.ts:132:11 > Responsive and visual pass (E2E-07, AC-33) > mobile 375px > Users (R-17 ... R-19) (690ms)
ok 63 [chromium] > e2e\lab-03\visual.spec.ts:147:7 > Shell and role navigation (R-06, R-07, V-10) > each role sees only its own links (desktop) (1.5s)
ok 64 [chromium] > e2e\lab-03\visual.spec.ts:164:7 > Shell and role navigation (R-06, R-07, V-10) > the mobile header opens as a sheet with the profile menu (R-07) (666ms)
ok 65 [chromium] > e2e\lab-03\visual.spec.ts:174:7 > Detail states (R-11, R-15, R-16, R-20) > queue no-results and safe failure (R-11, AC-34) (1.2s)
ok 66 [chromium] > e2e\lab-03\visual.spec.ts:196:7 > Detail states (R-11, R-15, R-16, R-20) > Internal Notes against Public Comments (R-15, V-12) (938ms)
ok 67 [chromium] > e2e\lab-03\visual.spec.ts:205:7 > Detail states (R-11, R-15, R-16, R-20) > confirmation dialog on mobile (R-16) (887ms)
ok 68 [chromium] > e2e\lab-03\visual.spec.ts:218:7 > Detail states (R-11, R-15, R-16, R-20) > Users validation and 409 under Email (R-20) (1.3s)
ok 69 [chromium] > e2e\lab-03\visual.spec.ts:242:9 > Measured checklist items (V-05, V-06, V-07) > V-05 every focusable control on Login shows a focus indicator (1.1s)
ok 70 [chromium] > e2e\lab-03\visual.spec.ts:266:9 > Measured checklist items (V-05, V-06, V-07) > V-06 every form control on Login has an accessible name (1.0s)
ok 71 [chromium] > e2e\lab-03\visual.spec.ts:242:9 > Measured checklist items (V-05, V-06, V-07) > V-05 every focusable control on Queue shows a focus indicator (1.6s)
ok 72 [chromium] > e2e\lab-03\visual.spec.ts:266:9 > Measured checklist items (V-05, V-06, V-07) > V-06 every form control on Queue has an accessible name (1.4s)
ok 73 [chromium] > e2e\lab-03\visual.spec.ts:242:9 > Measured checklist items (V-05, V-06, V-07) > V-05 every focusable control on Staff detail shows a focus indicator (2.0s)
ok 74 [chromium] > e2e\lab-03\visual.spec.ts:266:9 > Measured checklist items (V-05, V-06, V-07) > V-06 every form control on Staff detail has an accessible name (1.4s)
ok 75 [chromium] > e2e\lab-03\visual.spec.ts:242:9 > Measured checklist items (V-05, V-06, V-07) > V-05 every focusable control on Users
```

npx playwright test — 2 of 2

6. What the tests found

Tests written from the specification caught defects the code had shipped with — each fixed in the issue that found it:

Found by	Defect
E2E-07 <code>visual.spec.ts</code> (V-03)	The queue at 820 px scrolled the whole page to 1009 px — a visually-hidden column label escaped the table wrapper; the open mobile header sheet ran to 466 px
E2E-07 contrast check (V-07)	The Cancelled badge measured 4.39:1, under the 4.5:1 the UI spec requires
Direct-API evidence (Part 7)	A malformed JSON body returned Express's HTML error page with a stack trace and server file paths (BR-30); now a JSON <code>400</code> , with a test
<code>staff-queue.spec.ts</code> (E2E-05)	Typing into the queue search right after "Clear filters" could be wiped when the delayed URL update arrived; now covered by a component test too
E2E-01 (Issue #37)	After logout the guard could leave <code>?from=</code> on <code>/Login</code> ; a fixed unknown email tripped the login throttle — proof BR-07 works

Lab 3 — Test Plan and Results

Companion to [specification.md](#). Acceptance criteria (AC-01 ...) are defined in §9 of that document; business rules (BR-) in §5; endpoints in [api-spec.md](#); screens and visual items (V-) in [ui-spec.md](#). This plan was written with the contract, before implementation; the **Final Status** column is filled in as each Issue merges and must reflect the run on `main` at submission.

1. Test Strategy

Level	Tooling	What it covers
Unit	Vitest	Pure modules: password policy, session token hashing and expiry, login throttle, status transition matrix and owner rule (<code>ticketWorkflow.ts</code>), queue query parsing, seed idempotence against the in-memory fake client.
API / integration	Vitest + Supertest	Every endpoint in api-spec.md §3 against the Express app with <code>src/db.js</code> mocked (Lab 2 pattern): status codes, error codes, <code>fields</code> , cookies, and the authorization matrix row by row. bcrypt is real (fixtures are hashed at cost 4 so the suite stays fast; the routes hash at cost 10).
UI component	Vitest + React Testing Library + user-event	Rendering, validation placement, guards and role navigation, feedback states, and that the client sends the right requests (<code>fetch</code> mocked, <code>credentials: 'include'</code> asserted).
UI style / responsive	Playwright screenshots + DOM measurements	V-01 ... V-14 at 1280 / 820 / 375 px; <code>scrollWidth</code> checks; badge contrast.
Security / authorization	Supertest (API-13 ... API-18, API-08) + Playwright (E2E-03)	Cross-role and unauthenticated calls, tampered <code>requesterId</code> , Internal Note leakage, post-logout access.
Migration / regression	Manual scripted run + Lab 2 suites	Migration on a database holding Lab 2 tickets and attachments; every Lab 2 test updated from header to cookie and still green.
End-to-end	Playwright	Real login through the real screens for each role, against a migrated and seeded PostgreSQL.

Placement follows the handout's required structure: `server/tests/lab-03/` , `client/src/components/lab-03/` (new components live beside their tests, as in Lab 2), `e2e/lab-03/` . Lab 2 tests stay where they are and are updated in place (API-19 ... API-21).

Test accounts come from the seed (specification.md §7): `jennifer.anderson@...` (Requester, password already changed), `sarah.johnson@...` (Requester, initial password), `alex.smith@...` (inactive Requester), three IT Staff, `robert.wilson@...` (inactive IT Staff), `admin@toktickit.xyz` (Administrator). E2E helpers log in through the Login screen, never by writing a cookie.

2. Planned Tests

The three example rows from the handout (API-01, API-08, E2E-02) keep their ids.

Unit

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File Path	Final Status
UNIT-01	Unit	BR-08, AC-09	Password policy: length 7/8/72/73, missing upper/lower/digit/special	Exactly the failing rule named; valid password passes	<code>server/tests/lab-03/passwordPolicy.test.ts</code>	Pass
UNIT-02	Unit	BR-18, AC-21	Transition matrix: every (from, to) pair	Permitted pairs return <code>ok</code> ; all others return <code>INVALID_TRANSITION</code>	<code>server/tests/lab-03/ticketWorkflow.test.ts</code>	Pass
UNIT-03	Unit	BR-19, BR-20, AC-22	Owner rule and timestamps	InProgress/Resolved without owner rejected; Resolved sets <code>resolvedAt</code> , Closed sets <code>closedAt</code> , Reopened clears all three	<code>server/tests/lab-03/ticketWorkflow.test.ts</code>	Pass
UNIT-04	Unit	AC-17	Queue query parser: defaults, repeatable <code>status</code> , <code>owner=me/unassigned/uuid</code> , sort keys, page sizes, invalid values	Parsed object or <code>fields</code> naming the bad parameter	<code>server/tests/lab-03/queueQuery.test.ts</code>	Pass
UNIT-05	Unit	BR-10	Session helper: token is 32 random bytes, only SHA-256 stored, <code>expiresAt = now + 8h</code> , expired session rejected	As stated	<code>server/tests/lab-03/session.test.ts</code>	Pass
UNIT-06	Unit	BR-07, AC-07	Login throttle: 5 failures allowed, 6th blocked, window expiry, reset on success	As stated (fake timers)	<code>server/tests/lab-03/loginThrottle.test.ts</code>	Pass
UNIT-07	Unit	BR-29, AC-32	Seed against the in-memory <code>upsert</code> -only client, run twice	No <code>create</code> / <code>deleteMany</code> called; second run touches the same keys; counts 5 + 4 + 1 users, 24 tickets	<code>server/tests/seed.test.ts</code> (updated)	Pass

API

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File Path	Final Status
API-01	API	AC-01	Valid login	Authenticated response; safe user data	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass
API-02	API	AC-05, BR-06	Unknown email vs wrong password	Both <code>401 INVALID_CREDENTIALS</code> with byte-identical body	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass
API-03	API	AC-06, BR-01, BR-06	Inactive account, correct password	<code>403 ACCOUNT_INACTIVE</code> ; no <code>Set-Cookie</code> ; no session created	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass
API-04	API	AC-07, BR-07	Sixth failed attempt for one email; five <code>403 ACCOUNT_INACTIVE</code> answers for an inactive account	<code>429 TOO_MANY_ATTEMPTS</code> , even with the right password / still <code>403</code> , never <code>429</code>	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File Path	Final Status
API-05	API	AC-01, BR-09, BR-10	Login response and cookie hygiene	Cookie is <code>HttpOnly</code> ; <code>SameSite=Lax</code> ; <code>Path=/</code> ; body has no <code>passwordHash</code> ; <code>lastLoginAt</code> updated	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass
API-06	API	AC-05	Login body validation	Missing/malformed email or empty password → <code>400</code> with <code>fields</code>	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass
API-07	API	AC-08, BR-10	Logout	<code>204</code> ; session row deleted; cookie cleared; subsequent <code>GET /api/auth/me</code> <code>401</code>	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass
API-08	API	AC-04	Requester requests Internal Notes	Forbidden; no note data returned	<code>server/tests/lab-03/comments-notes.api.test.ts</code>	Pass
API-09	API	AC-01, BR-02	<code>GET /api/auth/me</code> with and without session, and with <code>mustChangePassword</code>	<code>200</code> <code>SessionUser</code> / <code>401</code> / <code>200</code> with <code>mustChangePassword: true</code> (route is allow-listed)	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass
API-10	API	AC-02, BR-02	<code>mustChangePassword</code> user calls <code>GET /api/tickets</code>	<code>403</code> <code>PASSWORD_CHANGE_REQUIRED</code>	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass
API-11	API	AC-09, BR-08, BR-11	Change password: wrong current, weak new, same as current, mismatch	<code>400</code> with the correct <code>fields</code> key for each	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass
API-12	API	AC-10, BR-11	Change password: valid	<code>200</code> , <code>mustChangePassword: false</code> , same cookie still valid, other sessions deleted	<code>server/tests/lab-03/auth.api.test.ts</code>	Pass
API-13	API	AC-12, BR-30	Unauthenticated call to every protected route	<code>401</code> <code>UNAUTHORIZED</code> , empty of data	<code>server/tests/lab-03/authorization.api.test.ts</code>	Pass
API-14	API	AC-12	Requester calls each <code>/api/staff/*</code> and <code>/api/admin/*</code> route	<code>403</code> <code>FORBIDDEN</code>	<code>server/tests/lab-03/authorization.api.test.ts</code>	Pass
API-15	API	AC-12	IT Staff calls each <code>/api/admin/*</code> route	<code>403</code> <code>FORBIDDEN</code>	<code>server/tests/lab-03/authorization.api.test.ts</code>	Pass
API-16	API	AC-12, BR-17	Administrator calls claim / owner / it-priority / status / internal-note create / comment create	<code>403</code> <code>FORBIDDEN</code> ; reads of the same ticket <code>200</code>	<code>server/tests/lab-03/authorization.api.test.ts</code>	Pass
API-17	API	AC-03, BR-03	Requester sends <code>requesterId</code> of another user in body and query on create/list	Ignored; ticket owned by session user; list scoped to session user	<code>server/tests/lab-03/authorization.api.test.ts</code>	Pass
API-18	API	AC-27, BR-10, BR-27	Deactivated user's existing session; role-changed user's session	Next request <code>401</code>	<code>server/tests/lab-03/authorization.api.test.ts</code>	Pass
API-19	API	AC-13, BR-14	Lab 2 create/list/detail/attachment suites re-run with a cookie instead of the header	All Lab 2 assertions still pass	<code>server/tests/tickets.api.test.ts</code> , <code>server/tests/attachments.api.test.ts</code> (updated)	Pass
API-20	API	AC-13, BR-16	<code>POST /api/tickets</code>	<code>itPriority</code> equals submitted <code>priority</code>	<code>server/tests/tickets.api.test.ts</code> (updated)	Pass
API-21	API	AC-24, BR-14	IT Staff / Administrator read and download another Requester's attachment; attempt add and remove	Reads <code>200</code> ; add/remove <code>403</code>	<code>server/tests/attachments.api.test.ts</code> (updated)	Pass
API-22	API	AC-14, BR-22	Create Public Comment: valid, empty, whitespace, 2001 chars	<code>201</code> with server <code>author/time</code> ; <code>400</code> <code>fields.body</code> for the rest	<code>server/tests/lab-03/comments-notes.api.test.ts</code>	Pass
API-23	API	AC-14, BR-23	Requester comments on another Requester's ticket; Administrator creates a comment	<code>403</code> both	<code>server/tests/lab-03/comments-notes.api.test.ts</code>	Pass
API-24	API	AC-14, BR-04	List comments as owner, IT Staff, Administrator	<code>200</code> , newest first, same content for all three	<code>server/tests/lab-03/comments-notes.api.test.ts</code>	Pass
API-25	API	AC-15, BR-05, BR-21	Resolution indication: owner on Open ticket; repeat; on Closed ticket; by IT Staff; Requester <code>PATCH</code> <code>status</code>	<code>200</code> <code>set</code> / <code>200</code> same timestamp / <code>409</code> / <code>403</code> / <code>403</code>	<code>server/tests/lab-03/comments-notes.api.test.ts</code>	Pass
API-26	API	AC-16	Queue default request as IT Staff	All requesters' tickets, <code>updatedAt</code> desc, page 1 of 10, pagination metadata	<code>server/tests/lab-03/staff-queue.api.test.ts</code>	Pass
API-27	API	AC-17	<code>search</code> , <code>status</code> (repeated), <code>itPriority</code> , <code>owner=me</code> , <code>owner=unassigned</code> , <code>category</code>	Correct Prisma <code>where</code> built; correct subset returned	<code>server/tests/lab-03/staff-queue.api.test.ts</code>	Pass
API-28	API	AC-17	Every <code>sort</code> value, priority and status ordering, tie-break on <code>id</code>	Correct <code>orderBy</code>	<code>server/tests/lab-03/staff-queue.api.test.ts</code>	Pass

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File Path	Final Status
API-29	API	AC-17	Invalid <code>status</code> , <code>sort</code> , <code>pageSize</code> , <code>page=0</code> , out-of-range page	400 naming the parameter; out-of-range → 200 empty with real total	server/tests/lab-03/staff-queue.api.test.ts	Pass
API-30	API	AC-16, AC-19	GET /api/staff/assignees; Administrator gets the queue	Active IT Staff only, sorted; Administrator 200	server/tests/lab-03/staff-queue.api.test.ts	Pass
API-31	API	AC-24	GET /api/staff/tickets/:id shape	StaffTicketDetail with counts, attachments, permittedTransitions; unknown id 404	server/tests/lab-03/staff-ticket-detail.api.test.ts	Pass
API-32	API	AC-18, BR-15, BR-19, BR-31	Claim on New / on owned-by-other / on Closed	Owner = caller and Open / owner replaced / 409	server/tests/lab-03/staff-ticket-detail.api.test.ts	Pass
API-33	API	AC-19, BR-15, BR-31	Owner PATCH: active IT Staff, inactive IT Staff, Requester id, null on Open, null on InProgress, assign on New, assign on Closed	200 / 400 fields.ownerId / 400 / 200 unassigned / 409 / 200 and status Open / 409	server/tests/lab-03/staff-ticket-detail.api.test.ts	Pass
API-34	API	AC-20, BR-16, BR-31	IT priority PATCH valid, invalid, and on a Closed ticket	200 with requestedPriority unchanged / 400 / 409	server/tests/lab-03/staff-ticket-detail.api.test.ts	Pass
API-35	API	AC-21, BR-18	Status PATCH for a permitted pair and for a forbidden pair	200 with recomputed permittedTransitions / 409 INVALID_TRANSITION	server/tests/lab-03/staff-ticket-detail.api.test.ts	Pass
API-36	API	AC-22, BR-19, BR-20	InProgress and Resolved on an unassigned ticket; Resolved/Closed/Reopened timestamps	409 / 409; timestamps set and cleared per BR-20	server/tests/lab-03/staff-ticket-detail.api.test.ts	Pass
API-37	API	AC-21	Status PATCH with unknown value; on Cancelled ticket	400 / 409	server/tests/lab-03/staff-ticket-detail.api.test.ts	Pass
API-38	API	AC-23, BR-22, BR-23	Create Internal Note as IT Staff (valid, empty); as Administrator	201 / 400 / 403	server/tests/lab-03/comments-notes.api.test.ts	Pass
API-39	API	AC-23, BR-04	List Internal Notes as IT Staff and Administrator; Requester-facing GET /api/tickets/:id	200 both; ticket detail body contains no note text or count	server/tests/lab-03/comments-notes.api.test.ts	Pass
API-40	API	AC-25	Users list: default, search on name and on email, role filter, invalid role	Sorted by name / subset / subset / 400	server/tests/lab-03/users-admin.api.test.ts	Pass
API-41	API	AC-26, BR-24	Create user valid	201, mustChangePassword: true, no hash in body, hash verifies	server/tests/lab-03/users-admin.api.test.ts	Pass
API-42	API	AC-26, BR-12, BR-13, BR-24	Create user: duplicate email (different case), unknown role, weak initial password, missing name	409 CONFLICT fields.email / 400 / 400 / 400	server/tests/lab-03/users-admin.api.test.ts	Pass
API-43	API	AC-27, BR-25	PATCH name/email/role/isActive; unknown fields ignored	200 with changes; passwordHash / department in body ignored	server/tests/lab-03/users-admin.api.test.ts	Pass
API-44	API	AC-29, BR-25	Administrator deactivates own account	409 CONFLICT	server/tests/lab-03/users-admin.api.test.ts	Pass
API-45	API	AC-29, BR-26	Deactivate / change role of the last active Administrator; same when a second active Administrator exists	409 / 409 / 200	server/tests/lab-03/users-admin.api.test.ts	Pass
API-46	API	AC-28, BR-27	Set initial password: valid; weak; unknown user	200 with mustChangePassword: true and sessions deleted / 400 / 404	server/tests/lab-03/users-admin.api.test.ts	Pass
API-47	API	AC-30	Requester and IT Staff call every admin route	403 with no user data	server/tests/lab-03/users-admin.api.test.ts	Pass
API-48	API	AC-27, BR-10	Deactivation and role change delete the target's sessions	session.deleteMany called with the user id	server/tests/lab-03/users-admin.api.test.ts	Pass

UI component

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File Path	Final Status
UI-01	UI	AC-05	Login: required fields, malformed email	Errors under the right field; no request sent	client/src/components/lab-03/Login.test.tsx	Pass
UI-02	UI	AC-05	Login: 401	Callout text, password cleared, email kept, focus on password	client/src/components/lab-03/Login.test.tsx	Pass

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File Path	Final Status
UI-03	UI	AC-06, AC-07	Login: 403 ACCOUNT_INACTIVE , 429	Inactive message / throttled message with disabled button	client/src/components/lab-03/Login.test.tsx	Pass
UI-04	UI	AC-34	Login: network failure and 500	Safe message, Retry, email preserved; busy state shown during request; credentials: 'include' on the request	client/src/components/lab-03/Login.test.tsx	Pass
UI-05	UI	AC-02, AC-10	Login success routes by mustChangePassword and role	/change-password / /tickets / /staff/queue / /admin/users	client/src/components/lab-03/Login.test.tsx	Pass
UI-06	UI	AC-09	Change Password: live rules panel, mismatch, same-as-current, server fields mapping	Correct rule ticks; errors under the right fields	client/src/components/lab-03/ChangePassword.test.tsx	Pass
UI-07	UI	AC-02, AC-10	Change Password forced mode: no nav rendered; success navigates to role home	As stated	client/src/components/lab-03/ChangePassword.test.tsx	Pass
UI-08	UI	AC-11	AppShell per role: nav links, profile menu, Logout call and redirect; Development Requester block absent	Only role links; POST /api/auth/logout then /login	client/src/components/AppShell.test.tsx (updated)	Pass
UI-09	UI	AC-11, AC-08	RequireAuth : unauthenticated → /login?from= ; wrong role → Forbidden state; mustChangePassword → /change-password	As stated	client/src/components/lab-03/RequireAuth.test.tsx	Pass
UI-10	UI	AC-16	Queue table: nine columns, badges, Unassigned, "You" tag, requester-resolved icon, Open action	Rendered from mocked data	client/src/components/lab-03/StaffTicketQueue.test.tsx	Pass
UI-11	UI	AC-17	Queue toolbar: search debounce, status chips, owner/priority/category filters, sort, page size, Clear	Correct query string on fetch ; page resets to 1	client/src/components/lab-03/StaffTicketQueue.test.tsx	Pass
UI-12	UI	AC-17, AC-34	Queue states: loading, empty, no-results, forbidden (403), failure with Retry	Distinct states rendered	client/src/components/lab-03/StaffTicketQueue.test.tsx	Pass
UI-13	UI	AC-33	Queue at mobile media query renders cards, not a table	Cards present, table absent	client/src/components/lab-03/StaffTicketQueue.test.tsx	Pass
UI-14	UI	AC-24	Staff detail: read-only group vs three selects; attachments tab has Download but no upload/remove	As stated	client/src/components/lab-03/StaffTicketDetail.test.tsx	Pass
UI-15	UI	AC-18, AC-19	Claim button and owner select: requests, busy indicator, confirmation when replacing another owner	Correct endpoint and body	client/src/components/lab-03/StaffTicketDetail.test.tsx	Pass
UI-16	UI	AC-21, AC-22	Status select lists only permittedTransitions ; terminal choices open confirm dialog; owner-required hint	As stated	client/src/components/lab-03/StaffTicketDetail.test.tsx	Pass
UI-17	UI	AC-21	409 on status/owner/priority	Control reverts; conflict callout with server message	client/src/components/lab-03/StaffTicketDetail.test.tsx	Pass

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File Path	Final Status
UI-18	UI	AC-23, BR-04	Internal Notes tab: amber styling, composer for IT Staff, read-only for Administrator; Public Comments composer	Visually distinct classes; composers per role	client/src/components/lab-03/StaffTicketDetail.test.tsx	Pass
UI-19	UI	AC-14, AC-15	Requester detail: comments list and composer validation; "Problem appears resolved" button, confirm, indicator; no staff controls	As stated	client/src/components/TicketDetail.test.tsx (updated), client/src/components/lab-03/CommentsPanel.test.tsx	Pass
UI-20	UI	AC-13	Lab 2 component suites with <code>AuthProvider</code> instead of <code>RequesterProvider</code> ; no <code>X-Requester-Id</code> in any request	All Lab 2 assertions pass	client/src/components/{CreateTicketForm,MyTickets,TicketDetail}.test.tsx (updated)	Pass
UI-21	UI	AC-25	Users list: columns, badges, "(you)", search and role filter query, no-results	As stated	client/src/components/lab-03/UserManagement.test.tsx	Pass
UI-22	UI	AC-26	Create panel: required fields, rules panel, 409 shown under Email, success adds row	As stated	client/src/components/lab-03/UserManagement.test.tsx	Pass
UI-23	UI	AC-27, AC-29	Edit panel: fields prefilled, deactivate confirm, self toggle disabled with hint, last-admin toggle/role disabled, inline 409	As stated	client/src/components/lab-03/UserManagement.test.tsx	Pass
UI-24	UI	AC-28, AC-30	Set initial password success callout; non-Administrator sees Forbidden	As stated	client/src/components/lab-03/UserManagement.test.tsx	Pass
UI-25	UI	V-13	Shared <code>Badges.tsx</code> renders every status/priority/role/active value with its class and written label	Snapshot of classes and text	client/src/components/lab-03/Badges.test.tsx	Pass

Migration / regression

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File Path	Final Status
MIG-01	Migration	AC-31, BR-28	Scripted before/after check on a database holding Lab 2 data, run after <code>prisma migrate deploy</code> and before the seed (the seed upserts extra tickets, so counts are only comparable pre-seed): counts of tickets, attachments, users; every <code>Ticket.requesterId</code> resolves to a <code>User</code> ; <code>itPriority = priority</code> on every row; all migrated users are <code>Requester</code> with <code>mustChangePassword = true</code>	All assertions hold; output pasted into \$5	server/scripts/verify-lab03-migration.ts (run manually against PostgreSQL)	Pass
MIG-02	Migration	AC-31	One active migrated requester (Sarah Johnson) logs in with the documented initial password, after the seed has written the hash	Login succeeds and lands on Change Password	e2e/lab-03/authentication.spec.ts (shares E2E-02)	Pass

End-to-end

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File Path	Final Status
E2E-01	E2E	AC-01, AC-05, AC-06, AC-08	Invalid login, inactive login, valid login as Jennifer, shell shows name and role, logout, Back button, direct URL after logout	Error callouts; My Tickets shown; after logout every app URL lands on <code>/login</code>	e2e/lab-03/authentication.spec.ts	Pass
E2E-02	E2E	AC-02	Initial password login and change	Normal app opens only after valid change	e2e/lab-03/authentication.spec.ts	Pass
E2E-03	E2E	AC-11, AC-12	Role navigation and forbidden pages: Requester → <code>/staff/queue</code> , <code>/admin/users</code> ; IT Staff → <code>/admin/users</code> ; direct <code>fetch</code> from the page to <code>/api/staff/tickets</code> as Requester	Forbidden state; 403	e2e/lab-03/authentication.spec.ts	Pass

Test ID	Type	Requirement / AC	What It Tests	Expected Result	Automated Test File Path	Final Status
E2E-04	E2E	AC-13, AC-14, AC-15	Requester regression: create ticket with attachment → My Tickets → detail → download → post comment → "Problem appears resolved"; IT Staff then see the comment and the indicator	Lab 2 flow intact; comment and indicator visible to the requester and to IT Staff (queue icon + detail badge)	e2e/*.spec.ts (updated helpers), e2e/lab-03/requester-comments.spec.ts, e2e/lab-03/staff-ticket-flow.spec.ts	Pass
E2E-05	E2E	AC-16 ... AC-23	IT Staff: queue search/filter/sort/paginate → open → claim → set IT priority → In Progress → post comment → add Internal Note → Resolved (confirm) → Closed; then log in as the Requester and verify comment visible, note absent, statuses shown	As stated	e2e/lab-03/staff-ticket-flow.spec.ts	Pass
E2E-06	E2E	AC-25 ... AC-30	Administrator: search, filter, create user (IT Staff) → log out → log in as new user → forced change → log back in as admin → edit role → self-deactivate blocked → set initial password → new user forced to change again	As stated	e2e/lab-03/user-administration.spec.ts	Pass
E2E-07	E2E	AC-33, AC-34	Login, Change Password, Queue, Staff Detail, Users, My Tickets and Requester Detail at 1280 / 820 / 375 with a scrollWidth check; backend stopped for one failure capture; focus, label and contrast measured (V-05 ... V-07)	No overflow; safe failure with Retry; every check passes; screenshots written with CAPTURE=1	e2e/lab-03/visual.spec.ts	Pass

3. Acceptance-Criterion Traceability Matrix

AC	Description (short)	Covered by
AC-01	Valid login returns identity and role	API-01, API-05, API-09, E2E-01
AC-02	Password change gate	API-09, API-10, UI-05, UI-07, UI-09, E2E-02
AC-03	Client-supplied requesterId ignored	API-17
AC-04	Requester refused on Internal Notes without content	API-08, API-39
AC-05	Generic invalid-credentials	API-02, API-06, UI-01, UI-02, E2E-01
AC-06	Inactive account	API-03, UI-03, E2E-01
AC-07	Throttling	UNIT-06, API-04, UI-03
AC-08	Logout invalidates	API-07, UI-08, UI-09, E2E-01
AC-09	Change-password validation	UNIT-01, API-11, UI-06
AC-10	Change-password success	API-12, UI-05, UI-07, E2E-02
AC-11	Role navigation and forbidden pages	UI-08, UI-09, E2E-03
AC-12	Direct API authorization	API-13 ... API-16, E2E-03
AC-13	Requester regression	API-19, API-20, UI-20, E2E-04
AC-14	Public Comments	API-22 ... API-24, UI-19, E2E-04
AC-15	Problem appears resolved	API-25, UI-19, E2E-04
AC-16	Queue listing	API-26, API-30, UI-10, E2E-05
AC-17	Queue search/filter/sort/page/invalid	UNIT-04, API-27 ... API-29, UI-11, UI-12, E2E-05
AC-18	Claim	API-32, UI-15, E2E-05
AC-19	Reassign	API-30, API-33, UI-15
AC-20	IT Priority	API-34, E2E-05
AC-21	Transitions and confirmation	UNIT-02, API-35, API-37, UI-16, UI-17, E2E-05
AC-22	Owner required	UNIT-03, API-36, UI-16
AC-23	Internal Notes	API-38, API-39, UI-18, E2E-05
AC-24	Attachment continuity for staff	API-21, API-31, UI-14
AC-25	Users list/search/filter	API-40, UI-21, E2E-06
AC-26	Create user and validation	API-41, API-42, UI-22, E2E-06
AC-27	Edit user; deactivated session dies	API-18, API-43, API-48, UI-23, E2E-06
AC-28	Set initial password	API-46, UI-24, E2E-06
AC-29	Self / last-admin guards	API-44, API-45, UI-23, E2E-06
AC-30	Non-admin forbidden	API-47, UI-24, E2E-03
AC-31	Migration preserves data	MIG-01, MIG-02, \$5 migration log
AC-32	Seed idempotent	UNIT-07, \$5 seed log

AC	Description (short)	Covered by
AC-33	Responsive	UI-13, E2E-07, \$4
AC-34	Safe failure	UI-04, UI-12, E2E-07

4. Responsive and Visual Checklist

Captured on 2026-09-26 by `CAPTURE=1 npx playwright test e2e/lab-03/visual.spec.ts` (E2E-07) on a freshly reset and seeded database; every row also passed the horizontal-overflow assertion (V-03) in the same run. Paths are under `artifacts/lab-03/screenshots/`. Each row is checked against V-01 ... V-14 in [ui-spec.md](#) §5.

#	Screen	Viewport	Result	Screenshot
R-01	Login	Desktop 1280	Pass	authentication/login-desktop.png
R-02	Login	Tablet 820	Pass	authentication/login-tablet.png
R-03	Login	Mobile 375	Pass	authentication/login-mobile.png
R-04	Change Password (forced)	Desktop / Tablet	Pass	authentication/change-password-desktop.png , change-password-tablet.png
R-05	Change Password (forced)	Mobile	Pass	authentication/change-password-mobile.png
R-06	Shell + profile menu (each role)	Desktop	Pass	authentication/shell-{requester,staff,admin}-desktop.png
R-07	Shell + profile sheet	Mobile	Pass — fixed in this pass (sheet overflowed to 466 px)	authentication/shell-mobile.png
R-08	Queue (table)	Desktop	Pass	staff-queue/queue-desktop.png
R-09	Queue (table, scrolling wrapper)	Tablet	Pass — fixed in this pass (page overflowed to 1009 px)	staff-queue/queue-tablet.png
R-10	Queue (cards, filter sheet)	Mobile	Pass	staff-queue/queue-mobile.png
R-11	Queue no-results / failure	Desktop	Pass	staff-queue/queue-no-results.png , queue-failure.png
R-12	Staff Ticket Detail	Desktop	Pass	staff-ticket-detail/detail-desktop.png
R-13	Staff Ticket Detail	Tablet	Pass	staff-ticket-detail/detail-tablet.png
R-14	Staff Ticket Detail (tabs strip)	Mobile	Pass	staff-ticket-detail/detail-mobile.png
R-15	Internal Notes tab vs Public Comments tab	Desktop	Pass	staff-ticket-detail/notes-vs-comments.png
R-16	Confirm dialog (Resolved)	Mobile	Pass	staff-ticket-detail/confirm-mobile.png
R-17	Users (list + panel)	Desktop	Pass	user-management/users-desktop.png
R-18	Users (panel as sheet)	Tablet	Pass	user-management/users-tablet.png
R-19	Users (cards, full-screen panel)	Mobile	Pass	user-management/users-mobile.png
R-20	Users validation + 409 under Email	Desktop	Pass	user-management/users-conflict.png
R-21	My Tickets (Requester, Lab 3 badges)	All three	Pass	requester/my-tickets-{desktop,tablet,mobile}.png
R-22	Requester Ticket Detail with Public Comments	All three	Pass	requester/ticket-detail-{desktop,tablet,mobile}.png

R-21 and R-22 were added in this pass: both Requester screens changed in Lab 3 (shared badges, comments, "Problem appears resolved") and belong in the same responsive check.

The demonstration screenshots for Answer Parts 5 – 8 (`p5-*` , `p6-*` , `p7-*` , `p8-*` in the same folders) are captured by `docs/lab-03/scripts/capture-evidence.mjs`.

5. Test Commands and Final Results

```
# database (from repo root)
docker compose up -d
npm run prisma:migrate      # applies 20260915000000_lab03_users_roles_workflow and
                             # 20260919000000_lab03_status_workflow_order
npm run prisma:seed         # idempotent; safe to re-run

# suites
npm run test:server         # unit + API (no database needed)
npm run test:client         # UI component
npm run test:e2e            # Playwright; needs the migrated + seeded database
```

Migration and regression evidence (AC-31) — recorded 2026-09-18

Procedure: on a database that already holds Lab 2 data, record `SELECT count(*)` for `Ticket`, `Attachment`, `RequesterUser` and the distinct `requesterId` set; run `prisma migrate deploy`; record the same counts on `Ticket`, `Attachment`, `User`; assert equality and `SELECT count(*) FROM "Ticket" WHERE "itPriority" <> "priority" = 0` (all of this **before** the seed runs); then run the seed; log in as one active migrated requester (Sarah Johnson) with the documented initial password and confirm the forced change.

Run against the local Lab 2 database (`toktikit`, migrations `20260808160909_init` + `20260822000000_lab02_requester_ticketing` applied, 5 tickets raised through the Lab 2 UI):

```
$ npx tsx scripts/verify-lab03-migration.ts before
Before migration: { tickets: 5, attachments: 0, requesterUsers: 5, distinctRequesters: 1 }

$ npx prisma migrate deploy
The following migration(s) have been applied:
└─ 20260915000000_lab03_users_roles_workflow/migration.sql
All migrations have been successfully applied.

$ npx tsx scripts/verify-lab03-migration.ts after
After migration: { tickets: 5, attachments: 0, users: 5, distinctRequesters: 1, statuses: { New: 5 } }
MIG-01 PASSED: counts, ownership, priorities and migrated users all verified.

$ npx tsx src/seed.ts          # twice - identical counts (AC-32)
Seed complete: { categories: 4, relatedSystems: 7, requesters: 5, itStaff: 4, administrators: 1, inactiveUsers: 2 }
Seed complete: { categories: 4, relatedSystems: 7, requesters: 5, itStaff: 4, administrators: 1, inactiveUsers: 2 }

$ SELECT count(*) FROM "User"; SELECT count(*) FROM "Ticket";    → 10, 5

$ curl -i -X POST /api/auth/login {"email":"sarah.johnson@kmutt.ac.th","password":"Welcome123!"}
HTTP/1.1 200 OK
Set-Cookie: toktickit_session=...; Max-Age=28800; Path=/; HttpOnly; SameSite=Lax
{"id":"...", "name":"Sarah Johnson", "email":"sarah.johnson@kmutt.ac.th", "role":"Requester", "mustChangePassword":true}

$ curl -b <cookie> /api/tickets
{"error":{"code":"PASSWORD_CHANGE_REQUIRED", "message":"You must change your password before continuing."}}

$ curl -X POST /api/auth/login {"email":"alex.smith@kmutt.ac.th","password":"Welcome123!"} # inactive
{"error":{"code":"ACCOUNT_INACTIVE", "message":"This account is inactive. Please contact an administrator."}}
```

MIG-02 (the same first login through the Login screen, landing on Change Password, then completing it) is covered by `e2e/lab-03/authentication.spec.ts` "Initial password change" — see the E2E log below.

Per-issue verification logs

Appended as each Issue merges: command, summary line of the run, and the test ids it turned to Pass.

Issue #37 — Authentication foundation (2026-09-18)

```
$ npm run test:server
Test Files  10 passed (10)
Tests      210 passed (210)

$ npm run test:client
Test Files  7 passed (7)
Tests      113 passed (113)
```

Turned to Pass: UNIT-01, UNIT-05, UNIT-06, UNIT-07; API-01 ... API-07, API-09 ... API-13, API-17 ... API-21; UI-01 ... UI-09, UI-20. The removed Lab 2 suites for the Development Requester selector (`requesters.api.test.ts`, `RequesterSelector.test.tsx`, `e2e/requester-context.spec.ts`) went with the feature (FR-05).

Migration (MIG-01) and seed evidence: see "Migration and regression evidence" above.

```
$ npm run prisma:seed && npm run test:e2e      # against the migrated + seeded database
ok 1 [chromium] > e2e\attachments.spec.ts:18:7 > Attachment lifecycle (E2E-02) > upload, download, remove with a reason, then download is refused (1.4s)
  ok 2 [chromium] > e2e\attachments.spec.ts:58:7 > Attachment lifecycle (E2E-02) > a removed attachment is refused by the API as well as hidden in the UI (1.3s)
    ok 3 [chromium] > e2e\attachments.spec.ts:97:7 > Attachment lifecycle (E2E-02) > rejects a disallowed file type without attaching it (AC-07) (1.1s)
    ok 4 [chromium] > e2e\create-ticket.spec.ts:19:7 > Create ticket (E2E-01) > create a ticket, then open it and find the same data (1.1s)
    ok 5 [chromium] > e2e\create-ticket.spec.ts:58:7 > Create ticket (E2E-01) > the new ticket appears in My Tickets under its number (1.0s)
    ok 6 [chromium] > e2e\create-ticket.spec.ts:80:7 > Create ticket (E2E-01) > an invalid form is refused with errors under the offending fields (864ms)
    ok 7 [chromium] > e2e\lab-03\authentication.spec.ts:23:7 > Login, shell and logout (E2E-01) > an unknown email and a wrong password show the same generic message (907ms)
      ok 8 [chromium] > e2e\lab-03\authentication.spec.ts:37:7 > Login, shell and logout (E2E-01) > an inactive account with the right password is told it is inactive (540ms)
      ok 9 [chromium] > e2e\lab-03\authentication.spec.ts:44:7 > Login, shell and logout (E2E-01) > a valid login shows the name and role in the shell and lands on My Tickets (635ms)
        ok 10 [chromium] > e2e\lab-03\authentication.spec.ts:55:7 > Login, shell and logout (E2E-01) > the session survives a reload (811ms)
        ok 11 [chromium] > e2e\lab-03\authentication.spec.ts:64:7 > Login, shell and logout (E2E-01) > visiting /login while signed in goes straight to the role home (828ms)
          ok 12 [chromium] > e2e\lab-03\authentication.spec.ts:72:7 > Login, shell and logout (E2E-01) > logout ends the session: Back and direct URLs both land on Login (1.7s)
            ok 13 [chromium] > e2e\lab-03\authentication.spec.ts:101:7 > Login, shell and logout (E2E-01) > an anonymous visitor is sent to Login and returned after signing in (575ms)
              ok 14 [chromium] > e2e\lab-03\authentication.spec.ts:115:7 > Initial password change (E2E-02, MIG-02) > a first login is forced through Change Password before the app opens (1.5s)
                ok 15 [chromium] > e2e\lab-03\authentication.spec.ts:154:7 > Role navigation and forbidden pages (E2E-03) > a Requester sees only Requester links and is refused the staff and admin areas (991ms)
                  ok 16 [chromium] > e2e\lab-03\authentication.spec.ts:175:7 > Role navigation and forbidden pages (E2E-03) > IT Staff land on the queue, see the Queue link, and are refused /admin/users (963ms)
                    ok 17 [chromium] > e2e\lab-03\authentication.spec.ts:191:7 > Role navigation and forbidden pages (E2E-03) > an Administrator lands on Users and sees Users and Queue (576ms)
                      ok 18 [chromium] > e2e\ownership.spec.ts:19:7 > Ownership guard (E2E-03) > opening another requester's ticket shows access denied (1.6s)
                      ok 19 [chromium] > e2e\ownership.spec.ts:35:7 > Ownership guard (E2E-03) > another requester cannot download the owner's attachment (1.6s)
                      ok 20 [chromium] > e2e\ownership.spec.ts:65:7 > Ownership guard (E2E-03) > the requester still sees their own ticket after the switch back (2.6s)
                      20 passed (24.0s)
```

Turned to Pass: MIG-01, MIG-02, E2E-01, E2E-02, E2E-03; the Lab 2 E2E flows (create ticket, attachments, ownership) now run on the session cookie instead of the Development Requester selector. E2E-02 changes Sarah's password, so the seed is re-run before each E2E run to reset her.

Found only by the E2E run and fixed: (1) after logout the route guard could redirect before the shell's own navigate and leave `?from=` on `/login`; (2) after login the "already signed in" redirect could override the `from` destination. Both now go through one decision (`loggedOut` flag on the auth context; `destinationFor` shared by both paths in Login). (3) The suite's fixed unknown email tripped BR-07's throttle after five runs in fifteen minutes — proof the throttle works, and the test now uses a fresh address per run.

Issue #38 — Requester comments and resolution (2026-09-19)

```
$ npm run test:server      Tests  242 passed (242)
$ npm run test:client      Tests  139 passed (139)
$ npm run test:e2e         26 passed
```

Turned to Pass: API-22 ... API-25, UI-19; the Requester half of E2E-04.

Issue #39 — IT Staff Ticket Queue (2026-09-19)

```
$ npm run test:server      Tests  317 passed (317)
$ npm run test:client      Tests  179 passed (179)
$ npm run test:e2e         32 passed
```

Turned to Pass: UNIT-04, API-26 ... API-30, UI-10 ... UI-13, UI-25; the `/api/staff` half of API-14. A migration reorders `TicketStatus` into workflow order so `sort=status` is a plain `ORDER BY`; the seed gains the 24 tickets of `specification.md` §7.

Issue #40 — IT Staff ticket operations (2026-09-25)

```
$ npm run test:server      Tests  573 passed (573)
$ npm run test:client      Tests  203 passed (203)
$ npm run test:e2e         37 passed
```

Turned to Pass: UNIT-02, UNIT-03, API-08, API-16, API-31 ... API-39, UI-14 ... UI-18, E2E-05. The seed gains the Public Comments and Internal Notes of §7, keyed on deterministic ids so it stays idempotent.

Issue #41 — Administrator user management (2026-09-26)

```
$ npm run test:server      Tests  654 passed (654)
$ npm run test:client      Tests  225 passed (225)
$ npm run test:e2e         43 passed
```

Turned to Pass: API-14 (complete), API-15, API-40 ... API-48, UI-21 ... UI-24, E2E-06.

Issue #42 — E2E, visual inspection, release (2026-09-26)

Turned to Pass: E2E-04 (IT Staff half added), E2E-07. The new `visual.spec.ts` found three defects on its first run, all fixed here: horizontal overflow on the queue at 820 px and on the open mobile header sheet, and the Cancelled badge at 4.39:1 contrast. Building the direct-API evidence found a fourth: a malformed JSON body answered with Express's HTML page, stack trace included — now a JSON `400` with a test. A fifth came from a flaky-looking E2E failure: typing into the queue search just after "Clear filters" could be wiped by the delayed URL update; fixed, with a component test.

Final run

On `main` after the release merge — `34eadf5`, Merge pull request #50 — against a migrated and freshly seeded database, all three suites from the repository root. The complete, verbatim output of each is in `test-runs/` (`server.txt`, `client.txt`, `e2e.txt`); each file's second line names the branch and commit it ran against.

```
$ npm run test:server
Test Files  16 passed (16)
Tests      656 passed (656)

$ npm --prefix client run test -- --reporter=verbose
Test Files  12 passed (12)
Tests      231 passed (231)

$ npx playwright test
83 passed

970 tests, 970 passing, 0 failed, 0 skipped.
```

Recorded 2026-09-27 on `docs/lab-03-final-evidence`, branched from `main` at `34eadf5` by `node docs/lab-03/scripts/capture-test-runs.mjs`. The only uncommitted edits at the time were under `docs/` and `artifacts/` (these logs, the answer pages, the Kanban screenshot), which no suite loads — so the code under test is exactly the release commit, and each log header says so. The same 970 tests had passed before the release on `feature/42-e2e-release`.

6. Issue Coverage

Issue	Tests it must turn to Pass
Authentication foundation	MIG-01, MIG-02, UNIT-01, UNIT-05, UNIT-06, UNIT-07, API-01 ... API-07, API-09 ... API-13, API-17 ... API-20, UI-01 ... UI-09, UI-20, E2E-01, E2E-02
Requester regression, comments, resolution	API-21 ... API-25, UI-19, E2E-04
IT Staff Ticket Queue	UNIT-04, API-26 ... API-30, UI-10 ... UI-13, UI-25
IT Staff Ticket operations	UNIT-02, UNIT-03, API-08, API-14, API-16, API-31 ... API-39, UI-14 ... UI-18, E2E-03, E2E-05
Administrator user management	API-15, API-40 ... API-48, UI-21 ... UI-24, E2E-06
E2E, visual inspection, release	E2E-07, \$4, \$5 final run

Answer Part 4:

AI Use with Reflection · 5 points

Lab 3 — AI Use and Reflection

Answer Part 4 deliverable for CPE334 Lab 3.

1. Environment and LLM Info

Field	Detail
Agent / Tool	Claude Code (desktop app)
LLM used	Claude Opus 5 for specification, planning and Issues #37 – #41; Claude Opus 5.5 for Issue #42 (release)
Thinking level	High for specification and design decisions; Medium for implementation
Student name	Thawat Boonsuk
Student ID	67070501024

2. Key Prompts

Six to ten prompts that materially shaped the sprint. Rows are added as the sprint progresses; the Issue column refers to the Lab 3 Kanban issues.

#	Phase	Issue	Prompt (summary or verbatim)	AI Output	How I Used / Adjusted It
P-01	Planning	contract	"Read <code>Lab_3_sheet.pdf</code> and make a plan." The agent mapped the Lab 2 server, client, docs and git flow with two read-only explorer agents, then asked four questions before planning: session store vs JWT, how much ticket access an Administrator gets, whether to plan the whole sprint or only the contract, and solo vs team	A phased sprint plan: data-model rename of <code>RequesterUser</code> → <code>User</code> , DB-backed session cookie, two tables for comments vs notes, a transition matrix, seven Issues, and a decision to hand each implementation Issue to a fresh session	Chose the session table over JWT (logout must really revoke), read-only Administrator (keeps the two roles separate as the handout asks), and one plan for the whole sprint executed in phases
P-02	Spec generation	contract	Write <code>specification.md</code> in the Lab 2 layout: keep the handout's BR-01...05 and AC-01...04 verbatim, number the rest, include the authorization matrix and a full status transition matrix	FR-01...14, BR-01...30, AC-01...34, AD-01...14, seed plan, migration steps	<i>review notes to be added after the student's own pass</i>
P-03	API contract	contract	Write <code>api-spec.md</code> extending Lab 2: cookie conventions, error codes, one subsection per endpoint, map each endpoint to API test ids	22 endpoint sections; <code>permittedTransitions</code> returned by the server so the client never encodes the matrix	
P-04	UI spec	contract	Write <code>ui-spec.md</code> : badges for eight statuses / IT priority / roles, Public-vs-Internal visual rule, five new screens with modes and feedback states, V-01...14		
P-05	Test plan	contract	Write <code>tests.md</code> before code: keep the handout's API-01 / API-08 / E2E-02 ids, cover every AC with at least one test, list real file paths	UNIT-01...07, API-01...48, UI-01...25, E2E-01...07, traceability matrix	
P-06	Implementation	#37	"Read Issue #37 and implement it" in a fresh session with only the contract (<code>specification.md</code> , <code>api-spec.md</code> , <code>ui-spec.md</code> , <code>tests.md</code>) and the Lab 2 code as context	Hand-written migration renaming <code>RequesterUser</code> → <code>User</code> in place, <code>Session</code> table + cookie helpers, <code>requireAuth</code> / <code>requireRole</code> / <code>requireSession</code> middleware, the four <code>/api/auth</code> routes, in-memory login throttle, bcrypt seed for all roles, <code>verify-lab03-migration.ts</code> ; client <code>AuthProvider</code> , <code>apiClient</code> (<code>credentials: 'include'</code>), <code>RequireAuth</code> , Login, Change Password, role-aware shell; Lab 2 suites moved from the header to the cookie; 210 server + 113 client tests green	Two adjustments from the contract while implementing: the seed gives David Lee a ready password (<code>Requester2!</code>) so the Lab 2 ownership E2E has two sign-in-able requesters (<code>specification.md</code> §7 updated), and the Lab 1 <code>SystemStatus</code> page was removed with <code>/api/users</code> because nothing else used it. MIG-01/02 and E2E-01...03 still need a PostgreSQL run to record
P-07	Implementation	#38	"Now start with issue 3 ... if you need more, read <code>Lab_3_sheet.pdf</code> " — then, mid-sprint: "you may run git commands that only read, never ones that change anything; tell me the command and I will run it" (saved as a standing rule for every later session)	Comment and resolution-indication endpoints, <code>CommentsPanel</code> , shared <code>Badges.tsx</code> , <code>requester-comments.spec.ts</code> ; later, a PR description and the git commands for me to run instead of running them myself	Caught that my new branch had been cut from a stale local <code>lab3-staging</code> without #37; after the git rule I ran every state-changing command myself. When the agent later broke the rule once (<code>git rm --cached</code> in #41) it said so unprompted and told me how to undo it

#	Phase	Issue	Prompt (summary or verbatim)	AI Output	How I Used / Adjusted It
P-08	Implementation	#39, #40	"Continue to Issue 4 ... give me the git setup first", then the same for Issue 5	<code>queueQuery.ts</code> , the status-order migration, 24 seeded tickets; <code>ticketWorkflow.ts</code> with the matrix as data, the staff detail with per-control 409 handling, <code>ThreadPanel</code> shared by comments and notes, 40 comments and 13 notes in the seed	Accepted the reordered <code>TicketStatus</code> enum migration after checking it changes no rows; asked for PR descriptions I could paste, since <code>gh</code> is not installed
P-09	Implementation	#41	"Continue to Issue 6 (admin users) ... don't touch git, just tell me the commands"	<code>/api/admin/*</code> with the self-deactivation and last-Administrator guards counted server-side, session revocation, <code>UserManagement</code> with both guards disabled <i>and</i> the 409 shown inline	Reviewed that deactivation deletes sessions and that a <code>password</code> field in the PATCH body is ignored; E2E accounts are unique per run because users are never deleted
P-10	Release	#42	"Issue 7 ... reset the DB for me" → Prisma's own guard refused to reset without explicit consent → "yes, reset the local database (but back it up also)"	A <code>pg_dump</code> backup outside the repo, then the reset; <code>visual.spec.ts</code> (E2E-07) with measured focus, label and contrast checks; three capture scripts; the answer pages and this PDF	The measured checks found three real defects the eye had missed (below). I decided the Cancelled badge colour change and the error-handler change were in scope for a release issue

3. My Reflection

Specification agent. เขียน Contract ให้เสร็จก่อน ทั้ง specification, API, UI และ test plan จากนั้นเริ่ม implementation ก็สามารถอ้างอิงเอกสารเหล่านี้ได้โดยตรง และเมื่อภายหลังเกิดปัญหาที่ขัดแย้งกับสิ่งที่ระบุไว้ก่อนหน้านี้ ก็ใช้ contract เป็นตัวตัดสินได้ เช่น coding session ตั้งชื่อไฟล์ทดสอบ staff detail ว่า staff-ticket-ops.api.test.ts แต่ทั้ง contract และ lab sheet ระบุว่า staff-ticket-detail.api.test.ts ดังนั้นจึงยึดตาม contract ส่วนกรณีที่ specification agent ผิดนั้น มักเป็นสิ่งที่การวัดจริงเท่านั้นที่จะตรวจพบได้

Coding agent. ส่วนใหญ่ทำงานตาม Contact แบ่งเป็น Session ๆ ทำให้โค้ดที่ได้ทำตามได้ค่อนข้างใกล้เคียงมาก ทั้ง transition matrix, owner rule และ permittedTransitions ถูกสร้างออกมาตรงตาม specification จุดที่มันน่าเชื่อถือน้อยที่สุดคือกรณีการตรวจสอบสามารถ "ผ่านโดยบังเอิญ" ได้ง่าย เช่น ใน #39 มันตรวจสอบว่า "ไม่มี horizontal overflow" ด้วยการอ่านค่า `body.scrollWidth` ซึ่งไม่สามารถตรวจจับได้ว่า element ใดกำลังล้นออกไปนอก document

Where AI was wrong, and what caught it.

- JSON body ที่ malformed ทำให้ Express ส่ง HTML error page ที่มี stack trace และ absolute server paths ออกมา ซึ่งขัดกับ BR-30 พบปัญหานี้ขณะสร้างหลักฐานสำหรับ direct API จึงแก้ด้วย error handler ที่ส่ง response ในรูปแบบ envelope และเพิ่ม test ครอบคลุมกรณีนี้แล้ว
- พบ overflow bug สองจุดได้แก่ queue ที่ 820 px และ mobile header sheet ที่ 375 px ซึ่งผ่านการตรวจสอบก่อนหน้านี้ทั้งหมด แต่ล้มเหลวเมื่อรัน E2E-07 visual spec ครั้งแรก
- Test fixtures ที่ซ่อน bug: Prisma stub ที่คืนทุก field ที่ถูกส่งเข้าไปจะสามารถซ่อนปัญหา passwordHash รั่วออกมาได้ และ fake directory ที่ถูก shallow-copy ก็ทำให้การแก้ไขจาก test หนึ่งรั่วไหลไปยัง test ถัดไป ทั้งสองกรณีจึงถูกแก้เพื่อให้ test ตรวจสอบสิ่งที่มันอ้างว่ากำลังตรวจสอบจริง ๆ
- Date test สมมติว่าเครื่องใช้ locale ภาษาอังกฤษ และล้มเหลวบน Local ของผมซึ่งแสดงปีเป็น 2569

Process. Agent ละเมิดกฎ "read-only git" หนึ่งครั้งใน #41 โดยมันรายงานเรื่องนี้ด้วยตัวเองใน message เดียวกัน และให้ command สำหรับ undo การเปลี่ยนแปลงมาให้ แต่เหตุการณ์นี้ก็แสดงให้เห็นว่าทำไมกฎที่ว่า ฉันต้องการให้ทุกการเปลี่ยนแปลงใน repository ต้องผ่านมือของฉันเองเท่านั้น

Next sprint. นำ measured checks ต่าง ๆ เช่น overflow, focus, labels และ contrast เข้าไปอยู่ในแผนตั้งแต่ UI issue แรก แทนที่จะรอจนถึง release issue เพื่อให้ defect ถูกพบตั้งแต่ issue ที่เป็นต้นเหตุของมัน และยังคงใช้รูปแบบ one-issue-per-session ต่อไป เพราะมันช่วยให้การเปลี่ยนแปลงแต่ละส่วนสามารถ review ได้ง่าย

Answer Part 5:

Working Login and Password Change UI · 5 points

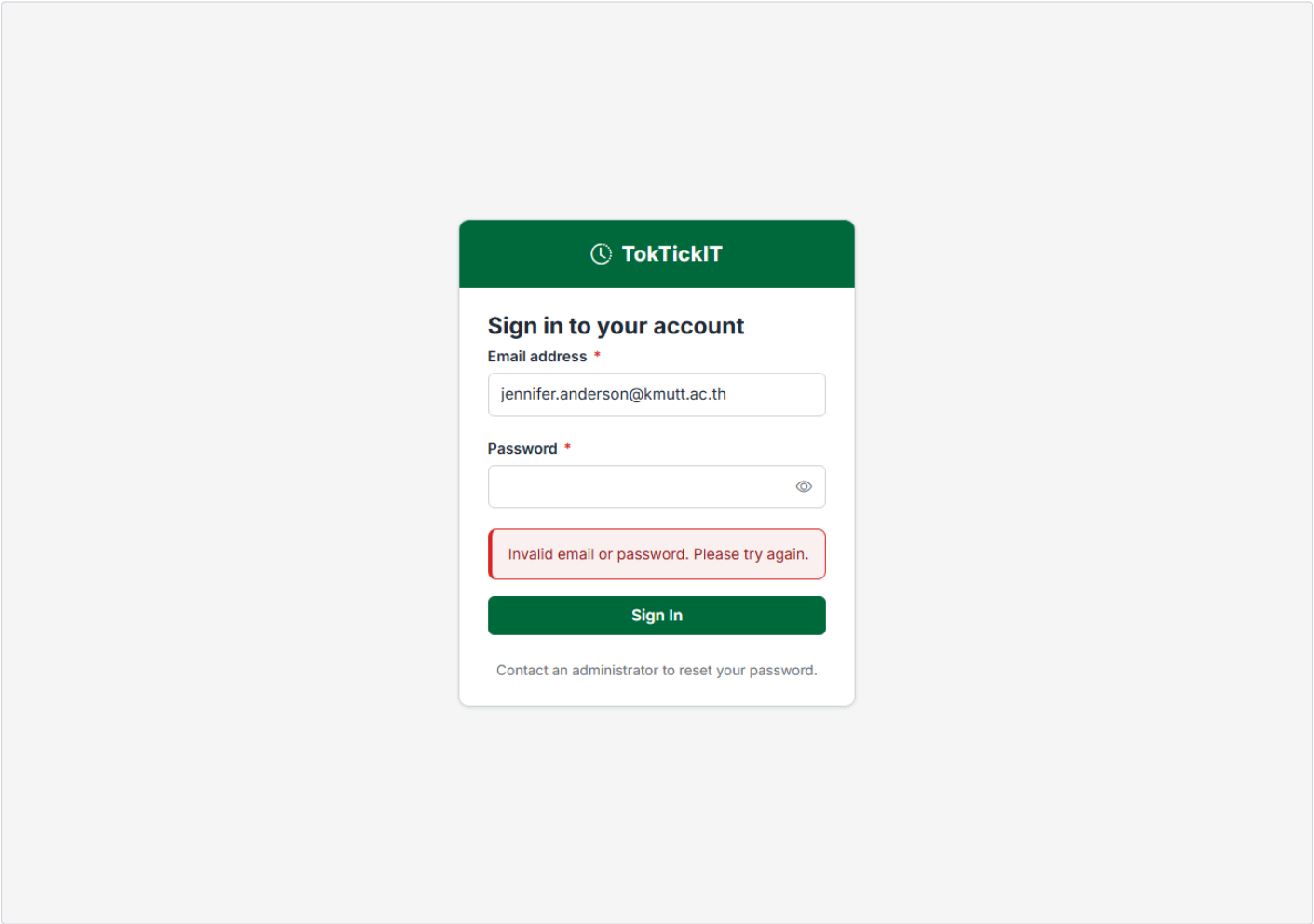
Answer Part 5 — Working Login and Password Change UI

All screenshots are from the running stack on a freshly seeded database, captured by `scripts/capture-evidence.mjs`. Where the point is *where the browser ended up*, a dark bar at the bottom shows the URL — a screenshot has no address bar of its own. The same behaviours are asserted by `e2e/lab-03/authentication.spec.ts` (E2E-01 ... E2E-03) and the Login / ChangePassword / RequireAuth component suites.

Requirement	Screenshot	Rule
Valid login	\$6 below — user and role in the shell	FR-01, AC-01
Invalid login	\$1	BR-06, AC-05
Inactive account	\$2	BR-01, BR-06, AC-06
Busy feedback	\$3	V-09
Safe failure	\$4	AC-34
Mandatory first-password change	\$5	BR-02, AC-02, AC-09
Authenticated user / role display	\$6	FR-03
Logout, and direct access blocked afterwards	\$7	FR-03, AC-08

1. Invalid login — one generic message

A wrong password and an unknown email get the same message, so the screen never reveals which accounts exist. The email is kept; the password is cleared.



Invalid email or password

2. Inactive account

Only when the password is *correct* does an inactive account learn that it is inactive — an attacker without the password cannot tell.



Sign in to your account

Email address *

Password *

This account is inactive. Please contact an administrator.

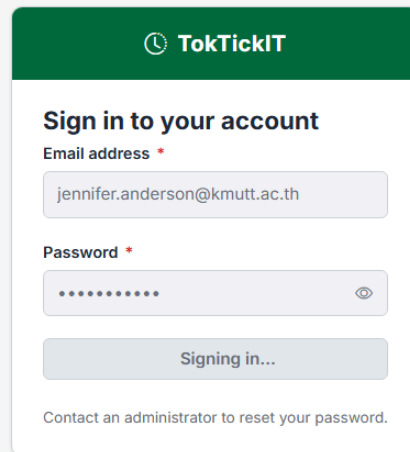
Sign In

Contact an administrator to reset your password.

This account is inactive

3. Busy state

While the request is in flight the button reads "Signing in...", shows a spinner and is disabled, and the fields are locked (the request was held for two seconds so it could be captured).



The screenshot shows a login form for TokTickIT. The form has a green header with the TokTickIT logo. Below the header, the title "Sign in to your account" is displayed. The form contains two input fields: "Email address" and "Password". The "Email address" field contains the text "jennifer.anderson@kmutt.ac.th". The "Password" field is masked with dots. Below the input fields is a "Signing in..." button. At the bottom of the form, there is a link that says "Contact an administrator to reset your password."

Signing in...

4. Safe failure — the backend is unreachable

The request never gets an answer. The screen says so in plain words, keeps the typed email, and shows nothing internal.



Sign in to your account

Email address *

Password *

Something went wrong. Please try again.

[Retry](#)

Sign In

Contact an administrator to reset your password.

Something went wrong

5. Mandatory password change at first login

Michael Brown is on his initial password. Signing in lands on Change Password — with no navigation, only Log out — and the BR-08 rules panel ticks each rule live. A new password that breaks the rules, and a confirmation that does not match, are refused under their own fields:

 TokTickIT

Change Your Password

You must change your password to continue.

Current (temporary) password *

.....

New password *

.....

New password does not meet the rules below.

☒ At least 8 characters

☒ One upper-case letter

☒ One lower-case letter

☒ One digit

☐ One special character

Confirm new password *

.....

Passwords do not match.

Continue

URL: /change-password - forced: no navigation, only Log out

Forced change with validation

Trying to leave by typing another URL is sent straight back until the change is made — and the API answers `403 PASSWORD_CHANGE_REQUIRED` on every data route meanwhile:

TokTickIT

MB

Michael Brown

Requester

Log out

TokTickIT

Change Your Password

You must change your password to continue.

Current (temporary) password *

New password *

At least 8 characters

One upper-case letter

One lower-case letter

One digit

One special character

Confirm new password *

Continue

URL: /change-password – visited /tickets – sent back to Change Password

Blocked until changed

6. Authenticated user and role in the shell

After a valid login the header shows the user's name, initials and role badge; the profile menu offers Change password and Log out. Only the role's own links are rendered.

CPE334 Lab 3 — TokTickIT — Thawat Boonsuk 67070501024

49/114

TokTickITMy TicketsCreate Ticket

JAJennifer AndersonRequester

My Tickets

Tickets raised by Jennifer Anderson.

Search

Ticket number or summary

Category

All categories

Status

All statuses

Sort by

Newest first

Clear Filters

Showing 1–10 of 38 tickets

Ticket No.	Created Date	Summary	Category	Requested Priority	IT Priority	Current Status	Ticket Owner	Last Updated	
TKT-2026-000032	26 n.b. 2569	E2E ownership round trip	Account and Access	Medium	IT Medium	New	Unassigned	26 n.b. 2569	Detail
TKT-2026-000031	26 n.b. 2569	E2E ownership of attachments	Account and Access	Medium	IT Medium	New	Unassigned	26 n.b. 2569	Detail
TKT-2026-000030	26 n.b. 2569	E2E ownership guard	Account and Access	Medium	IT Medium	New	Unassigned	26 n.b. 2569	Detail
TKT-2026-000029	26 n.b. 2569	E2E requester signal to staff	Account and Access	Medium	IT Medium	New	Unassigned	26 n.b. 2569	Detail
TKT-2026-000028	26 n.b. 2569	E2E staff attachment read path	Account and Access	Medium	IT Medium	New	Unassigned	26 n.b. 2569	Detail
TKT-2026-000027	26 n.b. 2569	E2E administrator read-only	Account and Access	Medium	IT Medium	Open	Priya Raman	26 n.b. 2569	Detail
TKT-2026-000026	26 n.b. 2569	E2E invalid transition	Account and Access	Medium	IT Medium	New	Unassigned	26 n.b. 2569	Detail
TKT-2026-000025	26 n.b. 2569	E2E owner rule	Account and Access	Medium	IT Medium	Open	Priya Raman	26 n.b. 2569	Detail

Jennifer Anderson · Requester

Each role's shell, profile menu open — Requester: My Tickets, Create Ticket; IT Staff: Queue; Administrator: Users, Queue:

TokTickITMy TicketsCreate Ticket

JAJennifer AndersonRequester

My Tickets

Tickets raised by Jennifer Anderson.

Search

Ticket number or summary

Category

All categories

Status

All statuses

Sort by

Newest first

Clear Filters

Showing 1–10 of 102 tickets

Ticket No.	Created Date	Summary	Category	Requested Priority	IT Priority	Current Status	Ticket Owner	Last Updated	
TKT-2026-000096	Sep 26, 2026	E2E ownership round trip	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
TKT-2026-000095	Sep 26, 2026	E2E ownership of attachments	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
TKT-2026-000094	Sep 26, 2026	E2E ownership guard	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
TKT-2026-000093	Sep 26, 2026	E2E requester signal to staff	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
TKT-2026-000092	Sep 26, 2026	E2E staff attachment read path	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
		E2E administrator	Account						

Requester shell

TokTickIT

Queue

PR Priya RamanIT Staff

Ticket Queue

Every ticket in the system, across all requesters.

Search

Sort by

Search by ticket number or summary...

Recently updated

Filters

Clear filters

Showing 1 to 10 of 120 tickets

TICKET NO.	CREATED	SUMMARY	CATEGORY	REQ. PRIORITY	IT PRIORITY	STATUS	OWNER	UPDATED
TKT-2026-000096	Sep 26, 2026	E2E ownership round trip	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2021
TKT-2026-000095	Sep 26, 2026	E2E ownership of attachments	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2021
TKT-2026-000094	Sep 26, 2026	E2E ownership guard	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2021
TKT-2026-000093	Sep 26, 2026	E2E requester signal to staff	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2021
TKT-2026-000092	Sep 26, 2026	E2E staff attachment read path	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2021
TKT-2026-000091	Sep 26, 2026	E2E administrator read-	Account and	Medium	IT Medium	New	Priya Raman	Sep 26, 2021

IT Staff shell

TokTickIT

Users

Queue

SA System AdministratorAdministrator

Users

Accounts, roles and access for the whole system.

Search

Role

Name or email

All roles

NAME	EMAIL	ROLE	STATUS
Alex Smith	alex.smith@kmutt.ac.th	Requester	Inactive
Chen Wei	chen.wei@kmutt.ac.th	IT Staff	Active
Dara Suksan 08lt3	dara.suksan.08lt3@kmutt.ac.th	Requester	Active
Dara Suksan zsq4b	dara.suksan.zsq4b@kmutt.ac.th	Requester	Active
David Lee	david.lee@kmutt.ac.th	Requester	Active
E2E Deactivate Me mui005ae	e2e.deactivate.mui005ae@kmutt.ac.th	Requester	Inactive
E2E Deactivate Me mui0cd9w	e2e.deactivate.mui0cd9w@kmutt.ac.th	Requester	Inactive
E2E Deactivate Me mui0hi5y	e2e.deactivate.mui0hi5y@kmutt.ac.th	Requester	Inactive

Administrator shell

7. Logout, then direct access is blocked

Logout deletes the session row and clears the cookie. Afterwards a protected URL redirects to Login, and the API answers 401 to the same browser (recorded by the capture script: GET /api/tickets after logout → 401).



Sign in to your account

Email address *

Password *



Sign In

Contact an administrator to reset your password.

URL: /login?from=%2Ftickets - after logout: /tickets redirects to Login

After logout, /tickets redirects to Login

Answer Part 6:

Working IT Staff Ticket Queue UI · 5 points

Answer Part 6 — Working IT Staff Ticket Queue UI

Signed in as Priya Raman (IT Staff) on the seeded database — 24 tickets across four requesters, every status at least twice, eight unassigned. Captured by `scripts/capture-evidence.mjs`; asserted by `e2e/lab-03/staff-queue.spec.ts` (E2E-05), `StaffTicketQueue.test.tsx` (UI-10 ... UI-13) and `staff-queue.api.test.ts` (API-26 ... API-30).

The queue keeps its state in the URL (`?status=open&status=inprogress&owner=me&sort=...`), so a filtered view survives a reload, can be shared, and is where "Back to Queue" returns to. Every control re-queries the server; the list is never a client-side slice.

Requirement	Section
Realistic data; assigned / unassigned ownership; status and priority badges	\$1
Search	\$2
Filters	\$3
Sorting	\$4
Pagination	\$5
Empty, no-results and failure feedback	\$6
Open-detail action	\$7
Responsive behaviour	\$8

1. Realistic data, ownership and badges

Ten columns in the order the UI spec fixes. The owner is a name, or *Unassigned* in muted italics; the signed-in user's own tickets carry a **You** tag. Requested and IT Priority are separate badges ("High" vs "IT High") so they are never confused when they differ. A check icon before the status marks a ticket the requester has reported as resolved.

Ticket Queue

Every ticket in the system, across all requesters.

Search

TKT-2026-9000

Sort by

Recently updated

Filters

Clear filters

Showing 1 to 10 of 24 tickets

Ticket No.	Created	Summary	Category	Req. Priority	IT Priority	Status	Owner	Updated
TKT-2026-900001	18 n.u. 2569	Cannot sign in to LEB2 after password reset	Account and Access	High	IT High	New	Unassigned	18 n.u. 2569
TKT-2026-900002	18 n.u. 2569	Printer on floor 3 jams on every duplex job	Hardware	Medium	IT Medium	New	Unassigned	18 n.u. 2569
TKT-2026-900003	17 n.u. 2569	Request access to the grade submission app fo...	Account and Access	Low	IT Low	New	Unassigned	17 n.u. 2569
TKT-2026-900007	14 n.u. 2569	Outlook keeps asking for the password	Software	High	IT High	In Progress	Chen Wei	17 n.u. 2569
TKT-2026-900004	16 n.u. 2569	VPN disconnects every 10 minutes from home	Network	High	IT High	Open	Nattapong Srisuk	17 n.u. 2569
TKT-2026-900005	15 n.u. 2569	Laptop battery drains from 100% to 20% in an...	Hardware	Medium	IT High	Open	Priya Raman YOU	17 n.u. 2569
TKT-2026-900024	13 n.u. 2569	Projector in room 402 shows a pink tint	Hardware	Medium	IT Medium	In Progress	Nattapong Srisuk	17 n.u. 2569
TKT-2026-900022	17 n.u. 2569	Guest Wi-Fi vouchers for the open day	Network	Medium	IT Medium	New	Unassigned	17 n.u. 2569
TKT-2026-900008	14 n.u. 2569	Grade submission app shows last semester...	Software	High	IT High	In Progress	Priya Raman YOU	16 n.u. 2569
TKT-2026-900023	16 n.u. 2569	Email signature not applied on mobile	Software	Low	IT Low	Open	Unassigned	16 n.u. 2569

Previous

1

2

3

Next

Page 1 of 3

Per page

10

Queue with seeded data

2. Search — ticket number or summary

TokTickIT

Queue

PR Priya RamanIT Staff

Ticket Queue

Every ticket in the system, across all requesters.

Search

VPN

×

Sort by

Recently updated

▼

Filters

●

Clear filters

Showing 1 to 2 of 2 tickets

TICKET NO. ⬆️⬆️	CREATED ⬆️⬆️	SUMMARY	CATEGORY	REQ. PRIORITY	IT PRIORITY ⬆️⬆️	STATUS ⬆️⬆️	OWNER	UPDATED ⬆️⬆️
TKT-2026-900004	16 n.u. 2569	VPN disconnects every 10 minutes from home	Network	High	IT High	Open	Nattapong Srisuk	17 n.u. 2569 Open
TKT-2026-900013	07 n.u. 2569	VPN certificate expired on the lab laptop	Network	High	IT High	Reopened	Chen Wei	15 n.u. 2569 Open

Previous

Next

Page 1 of 1

Per page 10

URL: /staff/queue?search=VPN - search=VPN (ticket number or summary)

Search VPN

3. Filters — status chips, IT priority, owner, category

Two status chips combine as OR; the owner filter offers Anyone, Me, Unassigned and each active IT Staff member. A dot on "Filters" shows that filters are active.

Ticket Queue

Every ticket in the system, across all requesters.

Search

TKT-2026-9000

Sort by

Recently updated

Filters

Clear filters

Status

New

Open

In Progress

Waiting for Requester

Reopened

Resolved

Closed

Cancelled

IT Priority

Any priority

Owner

Me

Category

All categories

Showing 1 to 1 of 1 ticket

TICKET NO. ⬆️⬆️	CREATED ⬆️⬆️	SUMMARY	CATEGORY	REQ. PRIORITY	IT PRIORITY ⬆️⬆️	STATUS ⬆️⬆️	OWNER	UPDATED ⬆️⬆️
TKT-2026-900005	15 n.u. 2569	Laptop battery drains from 100% to 20% in an...	Hardware	Medium	IT High	Open	Priya Raman YOU	17 n.u. 2569 Open

Previous

Next

Page 1 of 1

Per page

10

URL: /staff/queue?search=TKT-2026-9000&status=Open&owner=me - status=Open OR InProgress, owner=me

Open OR In Progress, owner = me

4. Sorting

Five columns sort from their header (with `aria-sort`), and the same ten options are in the Sort select. IT Priority sorts High → Medium → Low; Status sorts in workflow order, not alphabetically.

Ticket Queue

Every ticket in the system, across all requesters.

Search

TKT-2026-9000

Sort by

IT Priority (High first)

Filters

Clear filters

Showing 1 to 10 of 24 tickets

TICKET NO. ⬆	CREATED ⬆	SUMMARY	CATEGORY	REQ. PRIORITY	IT PRIORITY ⬆	STATUS ⬆	OWNER	UPDATED ⬆
TKT-2026-900001	18 n.u. 2569	Cannot sign in to LEB2 after password reset	Account and Access	High	IT High	New	Unassigned	18 n.u. 2569 Open
TKT-2026-900008	14 n.u. 2569	Grade submission app shows last semester...	Software	High	IT High	In Progress	Priya Raman YOU	16 n.u. 2569 Open
TKT-2026-900004	16 n.u. 2569	VPN disconnects every 10 minutes from home	Network	High	IT High	Open	Nattapong Srisuk	17 n.u. 2569 Open
TKT-2026-900013	07 n.u. 2569	VPN certificate expired on the lab laptop	Network	High	IT High	Reopened	Chen Wei	15 n.u. 2569 Open
TKT-2026-900016	03 n.u. 2569	Wi-Fi authentication loop on Android phones	Network	Medium	IT High	Resolved	Chen Wei	10 n.u. 2569 Open
TKT-2026-900007	14 n.u. 2569	Outlook keeps asking for the password	Software	High	IT High	In Progress	Chen Wei	17 n.u. 2569 Open
TKT-2026-900005	15 n.u. 2569	Laptop battery drains from 100% to 20% in an...	Hardware	Medium	IT High	Open	Priya Raman YOU	17 n.u. 2569 Open
TKT-2026-900020	15 n.u. 2569	Duplicate of the Wi-Fi library ticket	Network	Medium	IT Medium	Cancelled	Unassigned	15 n.u. 2569 Open
URL: /staff/queue?search=TKT-2026-9000&sort=itPriority:desc - sort=itPriority:desc via the column header (aria-sort=descending)								
TKT-2026-900018	26 n.u. 2569	Replace cracked laptop screen	Hardware	High	IT Medium	Closed	Nattapong Srisuk	03 n.u. 2569 Open
TKT-2026-900024	13 n.u. 2569	Projector in room 402 shows a pink tint	Hardware	Medium	IT Medium	In Progress	Nattapong Srisuk	17 n.u. 2569 Open

Previous

1

2

3

Next

Page 1 of 3

Per page

10

Sorted by IT Priority, High first

5. Pagination

5 / 10 / 25 / 50 per page (default 10), at most five page buttons, and a result line that describes the whole filtered set. Any filter change returns to page 1.

Ticket Queue

Every ticket in the system, across all requesters.

Search

Sort by

TokTickIT Queue

PR Priya Raman IT Staff

Showing 11 to 20 of 24 tickets

TICKET NO. ⬆	CREATED ⬆	SUMMARY	CATEGORY	REQ. PRIORITY	IT PRIORITY ⬆	STATUS ⬆	OWNER	UPDATED ⬆	
TKT-2026-900006	15 n.u. 2569	Campus Wi-Fi drops in the library reading room	Network	Medium	IT Medium	Open	Unassigned	16 n.u. 2569	Open
TKT-2026-900012	08 n.u. 2569	Email quota warning every morning	Software	Low	IT Medium	Reopened	Nattapong Srisuk	16 n.u. 2569	Open
TKT-2026-900009	13 n.u. 2569	Shared drive mapping lost after Windows update	Software	Medium	IT Low	In Progress	Nattapong Srisuk	16 n.u. 2569	Open
TKT-2026-900013	07 n.u. 2569	VPN certificate expired on the lab laptop	Network	High	IT High	Reopened	Chen Wei	15 n.u. 2569	Open
TKT-2026-900010	12 n.u. 2569	Need a second monitor for the registrar desk	Hardware	Low	IT Low	Waiting for Requester	Chen Wei	15 n.u. 2569	Open
TKT-2026-900020	15 n.u. 2569	Duplicate of the Wi-Fi library ticket	Network	Medium	IT Medium	Cancelled	Unassigned	15 n.u. 2569	Open
TKT-2026-900011	12 n.u. 2569	Cannot print from the lecture theatre PC	Hardware	Medium	IT Medium	Waiting for Requester	Priya Raman YOU	14 n.u. 2569	Open
TKT-2026-900014	05 n.u. 2569	LEB2 assignment upload fails for files over 20 MB	Software	Medium	IT Medium	Resolved	Priya Raman YOU	11 n.u. 2569	Open
TKT-2026-900016	03 n.u. 2569	Wi-Fi authentication loop on Android phones	Network	Medium	IT High	Resolved	Chen Wei	10 n.u. 2569	Open
TKT-2026-900015	04 n.u. 2569	Keyboard keys sticking on the front-desk PC	Hardware	Low	IT Low	Resolved	Nattapong Srisuk	09 n.u. 2569	Open

Previous 1 2 3 Next Page 2 of 3

Per page 10

URL: /staff/queue?search=TKT-2026-9000&page=2 - page=2, 10 per page

Page 2 of 3

6. Empty, no-results and failure feedback

Three different situations, three different panels. "No tickets in the system yet" (a seeded system always has tickets, so this one request was answered with an empty list — the bar says so):

Ticket Queue

Every ticket in the system, across all requesters.

Search

Sort by



No tickets in the system yet.

When a requester raises a ticket it appears here.

URL: /staff/queue — empty list substituted for this request — the "no tickets yet" state

Empty

A search that matches nothing, with its own Clear filters action:

Ticket Queue

Every ticket in the system, across all requesters.

Search

Sort by



No tickets match these filters

Nothing matches the current search and filters. Try a different term, or clear the filters to see the whole queue.

No results

The API unreachable — a plain message and Retry, no internal detail; Retry recovers without a reload (asserted in visual.spec.ts):

TokTickIT

Queue

PR Priya RamanIT Staff

Ticket Queue

Every ticket in the system, across all requesters.

Search

TKT-2026-9000

Sort by

Recently updated

Filters

Clear filters

Could not reach the server. Please check your connection and try again. [Retry](#).

Failure with Retry

7. Open detail

"Open" on a row (or the whole card on mobile) goes to the staff Ticket Detail.

TokTickIT

Queue

PR Priya RamanIT Staff

Queue / Ticket Detail

Back to Queue

VPN disconnects every 10 minutes from home

TKT-2026-900004

Open

High

IT High

Ticket operations

Ticket Owner

Nattapong Srisuk

Claim

IT Priority

High

Current Status

Open

Ticket details

TICKET NO.	CATEGORY	RELATED SYSTEM	REQUESTED PRIORITY
TKT-2026-900004	Network	VPN	High
REQUESTER	CREATED	UPDATED	
Michael Brown · michael.brown@kmutt.ac.th · Library	16 n.a. 2569 16:00	17 n.a. 2569 15:30	
SUMMARY	VPN disconnects every 10 minutes from home		
DESCRIPTION	The VPN client drops the tunnel roughly every ten minutes; reconnecting works but the pattern repeats.		

Public Comments (2)

Internal Notes (0)

Attachments (0)

Public Comments (2)

URL: /staff/tickets/574802da-2555-4144-a11d-aa8a485506d5 - Open -> /staff/tickets/:id

Open -> staff detail

8. Responsive

Desktop shows the table; tablet keeps every column and scrolls inside the table's own wrapper — never the page; mobile turns each ticket into a card with Ticket No., status, summary, IT priority and owner.

Tablet 820 px

TokTickITQueue

PRPriya RamanIT Staff

Ticket Queue

Every ticket in the system, across all requesters.

Search

TKT-2026-9000

Sort by

Recently updated

Filters

Clear filters

Showing 1 to 10 of 24 tickets

TICKET NO.	CREATED	SUMMARY	CATEGORY	REQ. PRIORITY	IT PRIORITY	STATUS
TKT-2026-900001	Sep 18, 2026	Cannot sign in to LEB2 after password reset	Account and Access	High	IT High	New
TKT-2026-900002	Sep 18, 2026	Printer on floor 3 jams on every duplex job	Hardware	Medium	IT Medium	New
TKT-2026-900003	Sep 17, 2026	Request access to the grade submission app f...	Account and Access	Low	IT Low	New
TKT-2026-900007	Sep 14, 2026	Outlook keeps asking for the password	Software	High	IT High	In Progress
TKT-2026-900004	Sep 16, 2026	VPN disconnects every 10 minutes from home	Network	High	IT High	Open
TKT-2026-900005	Sep 15, 2026	Laptop battery drains from 100% to 20% in an...	Hardware	Medium	IT High	Open
TKT-2026-900024	Sep 13, 2026	Projector in room 402 shows a pink tint	Hardware	Medium	IT Medium	In Progress
TKT-2026-900022	Sep 17, 2026	Guest Wi-Fi vouchers for the open day	Network	Medium	IT Medium	New
TKT-2026-900008	Sep 14, 2026	Grade submission app shows last semester...	Software	High	IT High	In Progress
TKT-2026-900023	Sep 16, 2026	Email signature not applied on mobile	Software	Low	IT Low	Open

Previous

1

2

3

Next

Page 1 of 3

Per page

10

Mobile 375 px

TokTickIT

Menu

Ticket Queue

Every ticket in the system, across all requesters.

Search

TKT-2026-9000

Sort by

Recently updated

Filters

Clear filters

Showing 1 to 10 of 24 tickets

TKT-2026-900001

New

Cannot sign in to LEB2 after password reset

IT High

Unassigned

CREATED

Sep 18, 2026

UPDATED

Sep 18, 2026

TKT-2026-900002

New

Printer on floor 3 jams on every duplex job

IT Medium

Unassigned

Answer Part 7:

Working IT Staff Ticket Detail UI · 10 points

Answer Part 7 — Working IT Staff Ticket Detail UI

One ticket, followed from arrival to resolution. Jennifer Anderson (Requester) raised it with an attachment and a comment; Priya Raman (IT Staff) works it. Captured by `scripts/capture-evidence.mjs`; asserted by `e2e/lab-03/staff-ticket-flow.spec.ts` (E2E-04, E2E-05), `StaffTicketDetail.test.tsx` (UI-14 ... UI-18), `staff-ticket-detail.api.test.ts` (API-31 ... API-37) and `ticketWorkflow.test.ts` (UNIT-02, UNIT-03).

The status dropdown lists only what the server returns in `permittedTransitions`, computed from the same transition matrix that enforces the change — the client never encodes the workflow. The server is the rule; §9 shows it refusing every change the UI does not offer.

Requirement	Section
Claim / reassign	§1, §3
IT Priority	§2
Permitted status changes (with confirmation)	§2, §4
Validation and conflict	§3, §6
Public Comments	§5
Internal Notes	§6
Attachment continuity	§7
Requester resolution indication	§8
Role restrictions	§8, §9
Safe failure	§7
Direct API authorization evidence	§9

1. New and unassigned → Claim

The read-only group (ticket, requester with email and department, requested priority, description) sits apart from the three operational controls. While unassigned, In Progress and Resolved are simply not offered, with the reason under the control. **Claim** makes Priya the owner and moves New → Open in one step (BR-31).

TokTickIT

Queue

PR

Priya Raman

IT Staff

▼

Queue / Ticket Detail

Back to Queue

Docking station drops the external monitor (08lt3)

TKT-2026-000033

NewMediumIT Medium

Ticket operations

Ticket Owner

Unassigned

▼

IT Priority

Medium

▼

Current Status

New

▼

Assign an owner first to move this ticket to In Progress or Resolved.

Ticket details

TICKET NO.

TKT-2026-000033

CATEGORY

Hardware

RELATED SYSTEM

Corporate Laptop

REQUESTED PRIORITY

Medium

REQUESTER

Jennifer Anderson · jennifer.anderson@kmutt.ac.th · Registrar

CREATED

26 n.b. 2569 13:24

UPDATED

26 n.b. 2569 13:24

SUMMARY

Docking station drops the external monitor (08lt3)

DESCRIPTION

The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.

Public Comments (1)

Internal Notes (0)

Attachments (1)

Public Comments (1)

Visible to you and to the IT team working on this ticket.

Add public comment

Reply to the requester...

0 / 2000

Post Comment

JA

Jennifer Anderson

Requester

just now

It happened three times this morning. Happy to bring the dock to the IT desk.

Before: New, unassigned

[Queue](#) / Ticket Detail[Back to Queue](#)**Docking station drops the external monitor (08It3)**

TKT-2026-000033

Open

Medium

IT Medium

Ticket operations

Ticket Owner

Priya Raman

IT Priority

Medium

Current Status

Open

Ticket details

TICKET NO.

TKT-2026-000033

CATEGORY

Hardware

RELATED SYSTEM

Corporate Laptop

REQUESTED PRIORITY

Medium

REQUESTER

Jennifer Anderson ·
jennifer.anderson@kmutt.ac.th ·
Registrar

CREATED

26 n.u. 2569 13:24

UPDATED

26 n.u. 2569 13:24

SUMMARY

Docking station drops the external monitor (08It3)

DESCRIPTION

The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.

Public Comments (1)

Internal Notes (0)

Attachments (1)

Public Comments (1)

Visible to you and to the IT team working on this ticket.

After Claim: owner Priya, Open

2. IT Priority and a permitted status change

IT Priority moves to High; the requested priority stays Medium. With an owner, In Progress is now offered and applied.

TokTickITQueue

PRPriya RamanIT Staff

Queue / Ticket Detail

Back to Queue

Docking station drops the external monitor (08It3)

TKT-2026-000033In ProgressMediumIT High

Ticket operations

Ticket Owner

Priya Raman

IT Priority

High

Current Status

In Progress

Ticket details

TICKET NO.	CATEGORY	RELATED SYSTEM	REQUESTED PRIORITY
TKT-2026-000033	Hardware	Corporate Laptop	Medium
REQUESTER	CREATED	UPDATED	
Jennifer Anderson · jennifer.anderson@kmutt.ac.th · Registrar	26 n.u. 2569 13:24	26 n.u. 2569 13:24	
SUMMARY			
Docking station drops the external monitor (08It3)			
DESCRIPTION			
The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.			

Public Comments (1)Internal Notes (0)Attachments (1)

Public Comments (1)

Visible to you and to the IT team working on this ticket.

IT High, In Progress

3. A real conflict, then reassignment

Unassigning an In Progress ticket is refused by the server (409 , BR-31); the message appears under the control and the select snaps back to the real owner. Reassigning to Chen Wei takes the work away from the current owner, so it is confirmed first.

Docking station drops the external monitor (08It3)

TKT-2026-000033 In Progress Medium IT High

Ticket operations

Ticket Owner

IT Priority

Current Status

Priya Raman

High

In Progress

A ticket that is In Progress must keep an owner.
Reassign it, or change its status first.

Ticket details

TICKET NO.	CATEGORY	RELATED SYSTEM	REQUESTED PRIORITY
TKT-2026-000033	Hardware	Corporate Laptop	Medium
REQUESTER	CREATED	UPDATED	
Jennifer Anderson · jennifer.anderson@kmutt.ac.th · Registrar	26 n.u. 2569 13:24	26 n.u. 2569 13:24	

SUMMARY
Docking station drops the external monitor (08It3)

DESCRIPTION
The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.

Public Comments (1) Internal Notes (0) Attachments (1)

[Queue](#) / Ticket Detail[Back to Queue](#)**Docking station drops the external monitor (08lt3)**

TKT-2026-000033

In Progress

Medium

IT High

Ticket operations

Ticket Owner

Priya Raman

IT Priority

High

Current Status

In Progress

A ticket that is In Progress must keep an owner.
Reassign it, or change its status first.

Reassign this ticket?

Priya Raman is the current owner. Chen Wei will take it over.

Confirm

Cancel

Ticket details

TICKET NO.

TKT-2026-000033

REQUESTER

Jennifer Anderson ·
jennifer.anderson@kmutt.ac.th ·
Registrar

CREATED

26 n.u. 2569 13:24

UPDATED

26 n.u. 2569 13:24

REQUESTED PRIORITY

Medium

SUMMARY

Docking station drops the external monitor (08lt3)

DESCRIPTION

The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.

[Public Comments \(1\)](#)[Internal Notes \(0\)](#)[Attachments \(1\)](#)

Reassign confirmation

4. Resolved, Closed and Cancelled are confirmed

TokTickITQueue

PRPriya RamanIT Staff

Queue / Ticket Detail

Back to Queue

Docking station drops the external monitor (08It3)

TKT-2026-000033In ProgressMediumIT High

Ticket operations

Ticket Owner

Chen Wei

IT Priority

High

Current Status

In Progress

Claim

Ticket details

TICKET NO.
TKT-2026-000033

REQUESTER
Jennifer Anderson ·
jennifer.anderson@kmutt.ac.th ·
Registrar

SUMMARY
Docking station drops the external monitor (08It3)

DESCRIPTION
The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.

Mark as Resolved?

The ticket moves to Resolved and the requester will see the new status.

Confirm

Cancel

REQUESTED PRIORITY

Medium

Public Comments (1)

Internal Notes (0)

Attachments (1)

Public Comments (1)

Visible to you and to the IT team working on this ticket.

Mark as Resolved?

5. Public Comments

The requester's comment and the staff reply, newest first, each with name, role badge and time.

TokTickIT
Queue
PR
Priya Raman
IT Staff

Queue / Ticket Detail
Back to Queue

Docking station drops the external monitor (08lt3)

TKT-2026-000033 In Progress Medium IT High

Ticket operations

Ticket Owner
Chen Wei

IT Priority
Claim
High

Current Status
In Progress

Ticket details

TICKET NO.	CATEGORY	RELATED SYSTEM	REQUESTED PRIORITY
TKT-2026-000033	Hardware	Corporate Laptop	Medium
REQUESTER	CREATED	UPDATED	
Jennifer Anderson · jennifer.anderson@kmutt.ac.th · Registrar	26 n.a. 2569 13:24	26 n.a. 2569 13:24	
SUMMARY			
Docking station drops the external monitor (08lt3)			
DESCRIPTION			
The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.			

Public Comments (2)
Internal Notes (0)
Attachments (1)

Public Comments (2)

Visible to you and to the IT team working on this ticket.

Add public comment

Reply to the requester...

0 / 2000

Post Comment

PR
Priya Raman
IT Staff
just now

Thanks — please bring the dock to the IT desk on Monday.

JA
Jennifer Anderson
Requester
just now

It happened three times this morning. Happy to bring the dock to the IT desk.

Public Comments

6. Internal Notes — validation, then a note

An empty note is refused under the composer. The Internal Notes panel is amber with a lock icon and "Internal — not visible to the requester"; its composer and outlined button are never on screen at the same time as the public one.

TICKET NO.	CATEGORY	RELATED SYSTEM	REQUESTED PRIORITY
TKT-2026-000033	Hardware	Corporate Laptop	Medium
REQUESTER	CREATED	UPDATED	
Jennifer Anderson · jennifer.anderson@kmutt.ac.th · Registrar	26 n.u. 2569 13:24	26 n.u. 2569 13:24	
SUMMARY			
Docking station drops the external monitor (08It3)			
DESCRIPTION			
The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.			

Public Comments (2) Internal Notes (0) Attachments (1)

Internal Notes (0)

Internal — not visible to the requester.

Add internal note

Private note for IT Staff...

Note cannot be empty.

0 / 2000

Add Internal Note

No internal notes yet.

Empty note refused

TokTickIT
Queue
PR Priya Raman IT Staff

Queue / Ticket Detail
Back to Queue

Docking station drops the external monitor (08It3)

TKT - 2026 - 000033 In Progress Medium IT High

Ticket operations

Ticket Owner
IT Priority
Current Status

Chen Wei
Claim
High
In Progress

Ticket details

TICKET NO.	CATEGORY	RELATED SYSTEM	REQUESTED PRIORITY
TKT - 2026 - 000033	Hardware	Corporate Laptop	Medium
REQUESTER	CREATED	UPDATED	
Jennifer Anderson · jennifer.anderson@kmutt.ac.th · Registrar	26 n.b. 2569 13:24	26 n.b. 2569 13:24	
SUMMARY			
Docking station drops the external monitor (08It3)			
DESCRIPTION			
The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.			

Public Comments (2)
Internal Notes (1)
Attachments (1)

Internal Notes (1)

Internal — not visible to the requester.

Add internal note

Private note for IT Staff...

0 / 2000

Add Internal Note

PR Priya Raman IT Staff
just now

Known firmware issue on this dock model; replacement unit ordered.

Note added

7. Attachment continuity and safe failure

The requester's file is listed and downloadable; removed files would show greyed with their reason. There is no upload area and no Remove control — and the API refuses both (§9).

Queue / Ticket Detail

Back to Queue

Docking station drops the external monitor (08It3)

TKT-2026-000033

In Progress

Medium

IT High

Ticket operations

Ticket Owner

Chen Wei

Claim

IT Priority

High

Current Status

In Progress

Ticket details

TICKET NO.

TKT-2026-000033

CATEGORY

Hardware

RELATED SYSTEM

Corporate Laptop

REQUESTED PRIORITY

Medium

REQUESTER

Jennifer Anderson · jennifer.anderson@kmutt.ac.th · Registrar

CREATED

26 n.u. 2569 13:24

UPDATED

26 n.u. 2569 13:24

SUMMARY

Docking station drops the external monitor (08It3)

DESCRIPTION

The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.

Public Comments (2)

Internal Notes (1)

Attachments (1)

Attachments

Attachments are managed by the requester. IT Staff can download them, but cannot add or remove files.

Attachments, read-only

With the API unreachable, a change fails under its own control with a plain message; nothing else on the screen is lost.

TokTickIT

Queue

PR

Priya Raman

IT Staff

▼

Queue / Ticket Detail

Back to Queue

Docking station drops the external monitor (08It3)

TKT-2026-000033

In Progress

Medium

IT High

Ticket operations

Ticket Owner

Chen Wei

▼

Claim

IT Priority

High

▼

Current Status

In Progress

▼

Could not reach the server. The change was not saved.

Ticket details

TICKET NO.	CATEGORY	RELATED SYSTEM	REQUESTED PRIORITY
TKT-2026-000033	Hardware	Corporate Laptop	Medium
REQUESTER	CREATED	UPDATED	
Jennifer Anderson · jennifer.anderson@kmutt.ac.th · Registrar	26 n.u. 2569 13:24	26 n.u. 2569 13:24	
SUMMARY			
Docking station drops the external monitor (08It3)			
DESCRIPTION			
The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.			

Public Comments (2)

Internal Notes (1)

Attachments (1)

Safe failure on IT Priority

8. The requester's indication, and the other two roles

Jennifer reports the problem appears resolved; Priya sees "Requester reports resolved" in the header (and a check icon in the queue row). The status does not change — that is IT Staff's decision (BR-05).

[Queue](#) / Ticket Detail[Back to Queue](#)**Docking station drops the external monitor (08It3)**

TKT-2026-000033

In Progress

Medium

IT High

Requester reports resolved

Ticket operations

Ticket Owner

Chen Wei

IT Priority

High

Current Status

In Progress

Ticket details

TICKET NO.

TKT-2026-000033

CATEGORY

Hardware

RELATED SYSTEM

Corporate Laptop

REQUESTED PRIORITY

Medium

REQUESTER

Jennifer Anderson ·
jennifer.anderson@kmutt.ac.th ·
Registrar

CREATED

26 n.u. 2569 13:24

UPDATED

26 n.u. 2569 13:24

SUMMARY

Docking station drops the external monitor (08It3)

DESCRIPTION

The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.

Public Comments (2)

Internal Notes (1)

Attachments (1)

Public Comments (2)

Visible to you and to the IT team working on this ticket.

Requester reports resolved

An Administrator sees the same ticket, notes included, with the controls rendered as values and both composers hidden (BR-17). Jennifer, even on her own ticket, is refused the staff route; her own view shows Priya's reply but never the note.

Back to Queue

Docking station drops the external monitor (08lt3)

TKT-2026-000033 In Progress Medium IT High Requester reports resolved

Ticket operations

Administrators can view but not change tickets.

TICKET OWNER

Chen Wei

IT PRIORITY

IT High

CURRENT STATUS

In Progress

Ticket details

TICKET NO.

TKT-2026-000033

CATEGORY

Hardware

RELATED SYSTEM

Corporate Laptop

REQUESTED PRIORITY

Medium

REQUESTER

Jennifer Anderson ·
jennifer.anderson@kmutt.ac.th ·
Registrar

CREATED

26 n.u. 2569 13:24

UPDATED

26 n.u. 2569 13:24

SUMMARY

Docking station drops the external monitor (08lt3)

DESCRIPTION

The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.

Public Comments (2)

Internal Notes (1)

Attachments (1)

Public Comments (2)

Visible to you and to the IT team working on this ticket.

PR

Priya Raman

IT Staff

just now

Thanks — please bring the dock to the IT desk on Monday.

JA

Jennifer Anderson

Requester

just now

It happened three times this morning. Happy to bring the dock to the IT desk.



You don't have access to this page

This area is not available for your role.

[Go to your home](#)

URL: /staff/tickets/1c07a4a1-ae5d-44c5-9bbf-f888b5049887 - Requester on a staff route (her own ticket)

Requester — staff route refused

TokTickIT
My Tickets
Create Ticket

JA
Jennifer Anderson
Requester

My Tickets / TKT-2026-000033

Docking station drops the external monitor (08lt3)

TKT-2026-000033
In Progress
Medium
IT High
Owner: Chen Wei
Requester reports resolved
Created 26 n.u. 2569 13:24

Ticket details

This view is read-only. Ticket fields are set when the ticket is created and are changed by the IT team, not here.

TICKET NO.	CREATED DATE	CATEGORY	RELATED SYSTEM
TKT-2026-000033	26 n.u. 2569 13:24	Hardware	Corporate Laptop
REQUESTER	REQUESTED PRIORITY	IT PRIORITY	CURRENT STATUS
Jennifer Anderson · Registrar	Medium	IT High	In Progress
TICKET OWNER	LAST UPDATED		
Chen Wei	26 n.u. 2569 13:24		
SUMMARY			
Docking station drops the external monitor (08lt3)			
DESCRIPTION			
The second monitor goes black every few minutes when the laptop is docked; undocked it is fine.			

Attachments (1 of 5 active)

dock-event-log.png
16 B
Uploaded 26 n.u. 2569 13:24

Download
Remove

Add a file

JPG, PNG, WEBP, PDF up to 5.0 MB. A ticket can hold 5 active files; removing one frees a slot.

Choose Files
No file chosen

Public Comments (2)

Visible to you and to the IT team working on this ticket.

Add public comment

Reply to the requester...

0 / 2000

Post Comment

PR
Priya Raman
IT Staff
just now

Thanks — please bring the dock to the IT desk on Monday.

JA
Jennifer Anderson
Requester
just now

It happened three times this morning. Happy to bring the dock to the IT desk.

Requester's own view — reply visible, note absent

9. Direct API authorization evidence

Hiding a control is feedback; the server is the rule. `scripts/capture-api-authorization.mjs` goes around the UI and calls the endpoints directly — with no session, as a Requester, as IT Staff and as an Administrator — and records each request, the status the specification requires, the status returned and the body. **29 checks, all passed.** The verbatim transcript is `test-runs/api-authorization.txt`:

```
TokTickIT - Direct API authorization evidence

TokTickIT - direct API authorization evidence
Run: 2026-09-27T08:25:55.591Z against http://localhost:5000
Fixture: ticket TKT-2026-00097 raised by Jennifer (Requester), with one Internal Note by Priya (IT Staff)

- No session (BR-30, AC-12)
$ GET /api/staff/tickets # as no session - no cookie: 401 before anything is read
expected 401 - got 401 PASS ("error":{"code":"UNAUTHORIZED","message":"You must sign in to continue."})
$ GET /api/tickets/<ticket> # as no session
expected 401 - got 401 PASS ("error":{"code":"UNAUTHORIZED","message":"You must sign in to continue."})
$ GET /api/admin/users # as no session
expected 401 - got 401 PASS ("error":{"code":"UNAUTHORIZED","message":"You must sign in to continue."})

- Requester reaching staff and admin routes (FR-04, AC-04, AC-30)
$ GET /api/staff/tickets # as Requester - the queue is staff-only
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ GET /api/tickets/<ticket>/internal-notes # as Requester - her own ticket, and still no note, count or hint (BR-23)
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ POST /api/staff/tickets/<ticket>/claim # as Requester
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ PATCH /api/staff/tickets/<ticket>/status {"status":"Resolved"} # as Requester - a Requester cannot set status (BR-05)
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ PATCH /api/tickets/<ticket>/status {"status":"Resolved"} # as Requester - there is no Requester status route at all
expected 404 - got 404 PASS ("error":{"code":"NOT_FOUND","message":"No such endpoint."})
$ GET /api/admin/users # as Requester
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ GET /api/tickets/<ticket> # as Requester - her own ticket is readable ...
expected 200 - got 200 PASS ("id":"0bfe5ebd-1108-4a4b-9210-7cb8efe68861","ticketNumber":"TKT-2026-00097","summary":"Authorization evidence ticket","description":"Created by capture-api-authoriza...
$ GET /api/tickets/<ticket> # as Other Requester - ... another requester gets 403 and no ticket data (BR-14)
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"This ticket belongs to another requester."})

- IT Staff: the workflow is the server's (BR-15, BR-18, BR-19, BR-31)
$ PATCH /api/staff/tickets/<ticket>/status {"status":"Closed"} # as IT Staff - New - Closed is not in the matrix
expected 409 - got 409 PASS ("error":{"code":"INVALID_TRANSITION","message":"A ticket that is New cannot become Closed. Permitted: Open, Cancelled."})
$ PATCH /api/staff/tickets/<ticket>/status {"status":"InProgress"} # as IT Staff - In Progress needs an owner (AC-22)
expected 409 - got 409 PASS ("error":{"code":"INVALID_TRANSITION","message":"A ticket must have an owner before it can become In Progress. Assign an owner first."})
$ PATCH /api/staff/tickets/<ticket>/owner {"ownerId":"<requester id>"} # as IT Staff - a Requester cannot be an owner (AC-19)
expected 400 - got 400 PASS ("error":{"code":"VALIDATION_FAILED","message":"One or more fields are invalid.","fields":{"ownerId":"The owner must be an active IT Staff member."}})
$ PATCH /api/staff/tickets/<ticket>/status {"status":"Bogus"} # as IT Staff - unknown status value
expected 400 - got 400 PASS ("error":{"code":"VALIDATION_FAILED","message":"One or more fields are invalid.","fields":{"status":"status must be one of New, Open, InProgress, WaitingForRequester, Closed, Cancelled."}})
$ POST /api/staff/tickets/<ticket>/claim # as IT Staff - claim: owner = caller, New - Open
expected 200 - got 200 PASS ("id":"0bfe5ebd-1108-4a4b-9210-7cb8efe68861","ticketNumber":"TKT-2026-00097","summary":"Authorization evidence ticket","status":"Open","itPriority":"Medium","requeste...
$ PATCH /api/staff/tickets/<ticket>/status {"status":"InProgress"} # as IT Staff - now permitted
expected 200 - got 200 PASS ("id":"0bfe5ebd-1108-4a4b-9210-7cb8efe68861","ticketNumber":"TKT-2026-00097","summary":"Authorization evidence ticket","status":"InProgress","itPriority":"Medium","re...
$ PATCH /api/staff/tickets/<ticket>/owner {"ownerId":null} # as IT Staff - an In Progress ticket must keep an owner
expected 409 - got 409 PASS ("error":{"code":"INVALID_TRANSITION","message":"A ticket that is In Progress must keep an owner. Reassign it, or change its status first."})
$ POST /api/tickets/<ticket>/attachments # as IT Staff - staff read attachments but never add them (BR-14)
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ GET /api/admin/users # as IT Staff - user management is Administrator-only (API-15)
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})

- Administrator: reads everything, changes no ticket (BR-17)
$ GET /api/staff/tickets/<ticket> # as Administrator - read the ticket ...
expected 200 - got 200 PASS ("id":"0bfe5ebd-1108-4a4b-9210-7cb8efe68861","ticketNumber":"TKT-2026-00097","summary":"Authorization evidence ticket","status":"InProgress","itPriority":"Medium","re...
$ GET /api/staff/tickets/<ticket>/internal-notes # as Administrator - ... and its notes
expected 200 - got 200 PASS ("data":[{"id":"8d20b66f-4537-400c-af26-f92f573ada35","body":"PRIVATE: vendor case 4471, do not share","createdAt":"2026-09-27T08:25:55.579Z","author":{"id":"8b941723-...
$ POST /api/staff/tickets/<ticket>/claim # as Administrator - no claim
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ PATCH /api/staff/tickets/<ticket>/it-priority {"itPriority":"Low"} # as Administrator - no IT priority
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ PATCH /api/staff/tickets/<ticket>/status {"status":"WaitingForRequester"} # as Administrator - no status
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ POST /api/staff/tickets/<ticket>/internal-notes {"body":"admin note"} # as Administrator - no note
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ POST /api/tickets/<ticket>/comments {"body":"admin comment"} # as Administrator - no comment
expected 403 - got 403 PASS ("error":{"code":"FORBIDDEN","message":"You do not have access to this resource."})
$ PATCH /api/admin/users/<own id> {"isActive":false} # as Administrator - cannot deactivate themselves (BR-25)
expected 409 - got 409 PASS ("error":{"code":"CONFLICT","message":"You cannot deactivate your own account."})

- Internal Note never reaches the Requester (AC-23)
note text in GET /api/tickets/<ticket> as Requester: absent - PASS
note text in GET /api/tickets/<ticket>/comments as Requester: absent - PASS

29 checks, all passed.
```

Direct API authorization transcript

What it proves	Rule
No session → 401 before anything is read	BR-30, AC-12
A Requester is refused every staff and admin route, including Internal Notes on her own ticket, with no note, count or existence hint	FR-04, BR-23, AC-04
There is no route through which a Requester can set status	BR-05, AC-15
Another requester's ticket is 403 with no ticket data	BR-14
IT Staff cannot make a transition outside the matrix, enter In Progress without an owner, assign a Requester as owner, or add attachments	BR-15, BR-18, BR-19, BR-14
An Administrator reads the ticket and its notes but every mutation is 403 ; they cannot deactivate themselves	BR-17, BR-25
The note's text is absent from every Requester-facing response	AC-23

Answer Part 8:

Working Administrator User Management UI · 5 points

Answer Part 8 — Working Administrator User Management UI

Signed in as the System Administrator. Captured by `scripts/capture-evidence.mjs`; asserted by `e2e/lab-03/user-administration.spec.ts` (E2E-06), `UserManagement.test.tsx` (UI-21 ... UI-24) and `users-admin.api.test.ts` (API-40 ... API-48).

Nobody is ever deleted (BR-27): there is no delete control anywhere, not even a disabled one. Deactivation is how an account is retired, and it signs that user out at once.

Requirement from the lab sheet	Section
User list with Name, Email, Role, Status and Edit	\$1
Search by name or email	\$2
Optional role filtering	\$2
Create user with one permitted role and an initial password	\$3
Duplicate-email and invalid-input validation	\$3
Edit name, email, role and activation state	\$4
Set a new initial password; required change at next login	\$5
Self-deactivation and last-active-Administrator prevention	\$6
Forbidden for non-Administrators	\$7
Responsive Zen Green presentation and safe failure	\$7, \$8

1. The directory

Name (the signed-in Administrator marked "(you)"), Email, Role badge, Active/Inactive badge, Edit. Sorted by name; no pagination at this scale.

Users

Create User

Accounts, roles and access for the whole system.

Search

@kmutt.ac.th

x

Role

All roles

v

NAME	EMAIL	ROLE	STATUS	
Alex Smith	alex.smith@kmutt.ac.th	Requester	Inactive	Edit
Chen Wei	chen.wei@kmutt.ac.th	IT Staff	Active	Edit
Dara Suksan zsq4b	dara.suksan.zsq4b@kmutt.ac.th	Requester	Active	Edit
David Lee	david.lee@kmutt.ac.th	Requester	Active	Edit
E2E Deactivate Me mui005ae	e2e.deactivate.mui005ae@kmutt.ac.th	Requester	Inactive	Edit
E2E New Staff mui000uc	e2e.newstaff.mui000uc@kmutt.ac.th	IT Staff	Active	Edit
E2E Reset Me mui0075x	e2e.resetme.mui0075x@kmutt.ac.th	Requester	Active	Edit
E2E Role Change mui003lg	e2e.rolechange.mui003lg@kmutt.ac.th	IT Staff	Active	Edit
Jennifer Anderson	jennifer.anderson@kmutt.ac.th	Requester	Active	Edit
Michael Brown	michael.brown@kmutt.ac.th	Requester	Active	Edit
Nattapong Srisuk	nattapong.srisuk@kmutt.ac.th	IT Staff	Active	Edit
Priya Raman	priya.raman@kmutt.ac.th	IT Staff	Active	Edit
Robert Wilson	robert.wilson@kmutt.ac.th	IT Staff	Inactive	Edit
Sarah Johnson	sarah.johnson@kmutt.ac.th	Requester	Active	Edit

Users list

2. Search and role filter

Search matches part of a name or an email; the role filter narrows to one role.

Users

Accounts, roles and access for the whole system.

Create User

Search

raman

x

Role

All roles

Edit

Search "raman"

TokTickIT

Users

Queue

SA

System Administrator

Administrator

▼

Users

Create User

Accounts, roles and access for the whole system.

Search

Name or email

Role

Administrator

▼

NAME	EMAIL	ROLE	STATUS
System Administrator (you)	admin@toktickit.xyz	Administrator	Active

Edit

Role = Administrator

3. Create — validation, then a new IT Staff account

Every invalid field is refused under itself: missing name, malformed email, a password that breaks BR-08. Then a valid account: one role, active, an initial password with its rules panel satisfied.

Users

Accounts, roles and access for the whole system.

Create User

Search

Name or email

Role

All roles

TokTickIT Users Queue

SA System Administrator Administrator

Chen Wei	chen.wei@kmutt.ac.th	IT Staff	Active	Edit
Dara Suksan zsq4b	dara.suksan.zsq4b@kmutt.ac.th	Requester	Active	Edit
David Lee	david.lee@kmutt.ac.th	Requester	Active	Edit
E2E Deactivate Me mui005ae	e2e.deactivate.mui005ae@kmutt.ac.th	Requester	Inactive	Edit
E2E New Staff mui000uc	e2e.newstaff.mui000uc@kmutt.ac.th	IT Staff	Active	Edit
E2E Reset Me mui0075x	e2e.resetme.mui0075x@kmutt.ac.th	Requester	Active	Edit
E2E Role Change mui003lg	e2e.rolechange.mui003lg@kmutt.ac.th	IT Staff	Active	Edit
Jennifer Anderson	jennifer.anderson@kmutt.ac.th	Requester	Active	Edit
Michael Brown	michael.brown@kmutt.ac.th	Requester	Active	Edit
Nattapong Srisuk	nattapong.srisuk@kmutt.ac.th	IT Staff	Active	Edit
Priya Raman	priya.raman@kmutt.ac.th	IT Staff	Active	Edit
Robert Wilson	robert.wilson@kmutt.ac.th	IT Staff	Inactive	Edit
Sarah Johnson	sarah.johnson@kmutt.ac.th	Requester	Active	Edit
System Administrator (you)	admin@toktickit.xyz	Administrator	Active	Edit

Full Name *

Full name is required.

Email Address *

not-an-email

Enter a valid email address.

Role *

Requester

Active

Yes

Initial Password *

Password must be at least 8 characters.

- ☐ At least 8 characters
- ☐ One upper-case letter
- ☒ One lower-case letter
- ☐ One digit
- ☐ One special character

Save User

Cancel

Invalid input

Users

Accounts, roles and access for the whole system.

Create User

Search

Name or email

Role

All roles

TokTickIT Users Queue

SA System Administrator Administrator

Chen Wei	chen.wei@kmutt.ac.th	IT Staff	Active	Edit
Dara Suksan zsq4b	dara.suksan.zsq4b@kmutt.ac.th	Requester	Active	Edit
David Lee	david.lee@kmutt.ac.th	Requester	Active	Edit
E2E Deactivate Me mui005ae	e2e.deactivate.mui005ae@kmutt.ac.th	Requester	Inactive	Edit
E2E New Staff mui000uc	e2e.newstaff.mui000uc@kmutt.ac.th	IT Staff	Active	Edit
E2E Reset Me mui0075x	e2e.resetme.mui0075x@kmutt.ac.th	Requester	Active	Edit
E2E Role Change mui003lg	e2e.rolechange.mui003lg@kmutt.ac.th	IT Staff	Active	Edit
Jennifer Anderson	jennifer.anderson@kmutt.ac.th	Requester	Active	Edit
Michael Brown	michael.brown@kmutt.ac.th	Requester	Active	Edit
Nattapong Srisuk	nattapong.srisuk@kmutt.ac.th	IT Staff	Active	Edit
Priya Raman	priya.raman@kmutt.ac.th	IT Staff	Active	Edit
Robert Wilson	robert.wilson@kmutt.ac.th	IT Staff	Inactive	Edit
Sarah Johnson	sarah.johnson@kmutt.ac.th	Requester	Active	Edit
System Administrator (you)	admin@toktickit.xyz	Administrator	Active	Edit

Full Name *

Dara Suksan 08lt3

Full name is required.

Email Address *

dara.suksan.08lt3@kmutt.ac.th

Enter a valid email address.

Role *

IT Staff

Active

Yes

Initial Password *

.....

Password must be at least 8 characters.

- At least 8 characters
- One upper-case letter
- One lower-case letter
- One digit
- One special character

Save User

Cancel

Valid input

The new user starts with a forced password change. An email already in use — in any letter case — is refused under the Email field (409):

TokTickIT

Users

Queue

SA System Administrator Administrator

Users

Accounts, roles and access for the whole system.

Create User

Dara Suksan 08lt3 was created. They must change their password at first login.

Search

dara.suksan.08lt3@kmutt.ac.th

x

Role

All roles

NAME	EMAIL	ROLE	STATUS	
Dara Suksan 08lt3	dara.suksan.08lt3@kmutt.ac.th	IT Staff	Active	Edit

Created

TokTickIT

Users

Queue

SA System Administrator Administrator

mui005ae	mutt.ac.th			
E2E Deactivate Me mui0cd9w	e2e.deactivate.mui0cd9w@kmutt.ac.th	Requester	Inactive	Edit
E2E Deactivate Me mui0hi5y	e2e.deactivate.mui0hi5y@kmutt.ac.th	Requester	Inactive	Edit
E2E Deactivate Me mui0t3g6	e2e.deactivate.mui0t3g6@kmutt.ac.th	Requester	Inactive	Edit
E2E New Staff mui000uc	e2e.newstaff.mui000uc@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui0ca21	e2e.newstaff.mui0ca21@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui0hesz	e2e.newstaff.mui0hesz@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui0szzb	e2e.newstaff.mui0szzb@kmutt.ac.th	IT Staff	Active	Edit
E2E Reset Me mui0075x	e2e.resetme.mui0075x@kmutt.ac.th	Requester	Active	Edit
E2E Reset Me mui0cep7	e2e.resetme.mui0cep7@kmutt.ac.th	Requester	Active	Edit
E2E Reset Me mui0hjy	e2e.resetme.mui0hjy@kmutt.ac.th	Requester	Active	Edit

Full Name *

Duplicate Example

Email Address *

priya.raman@kmutt.ac.th

That email address is already in use.

Role *

Requester

Active

Yes

Initial Password *

.....

At least 8 characters

One upper-case letter

One lower-case letter

One digit

One special character

Save User

Cancel

Duplicate email under the field

4. Edit name, email, role and activation

The same panel edits the four fields an Administrator may change — nothing else. Changing a role signs the user out, so their next request runs with the new role.

Users

Accounts, roles and access for the whole system.

[Create User](#)

Search

dara.suksan.08lt3@kmutt.ac.th

Role

All roles ▾

NAME	EMAIL	ROLE	STATUS	
Dara Suksan 08lt3	dara.suksan.08lt3@kmutt.ac.th	IT Staff	Active	Edit

Edit User

Full Name *

Dara Suksan 08lt3

Email Address *

dara.suksan.08lt3@kmutt.ac.th

Role *

Requester ▾

Active

Yes ▾

[Save Changes](#)[Cancel](#)

SET NEW INITIAL PASSWORD

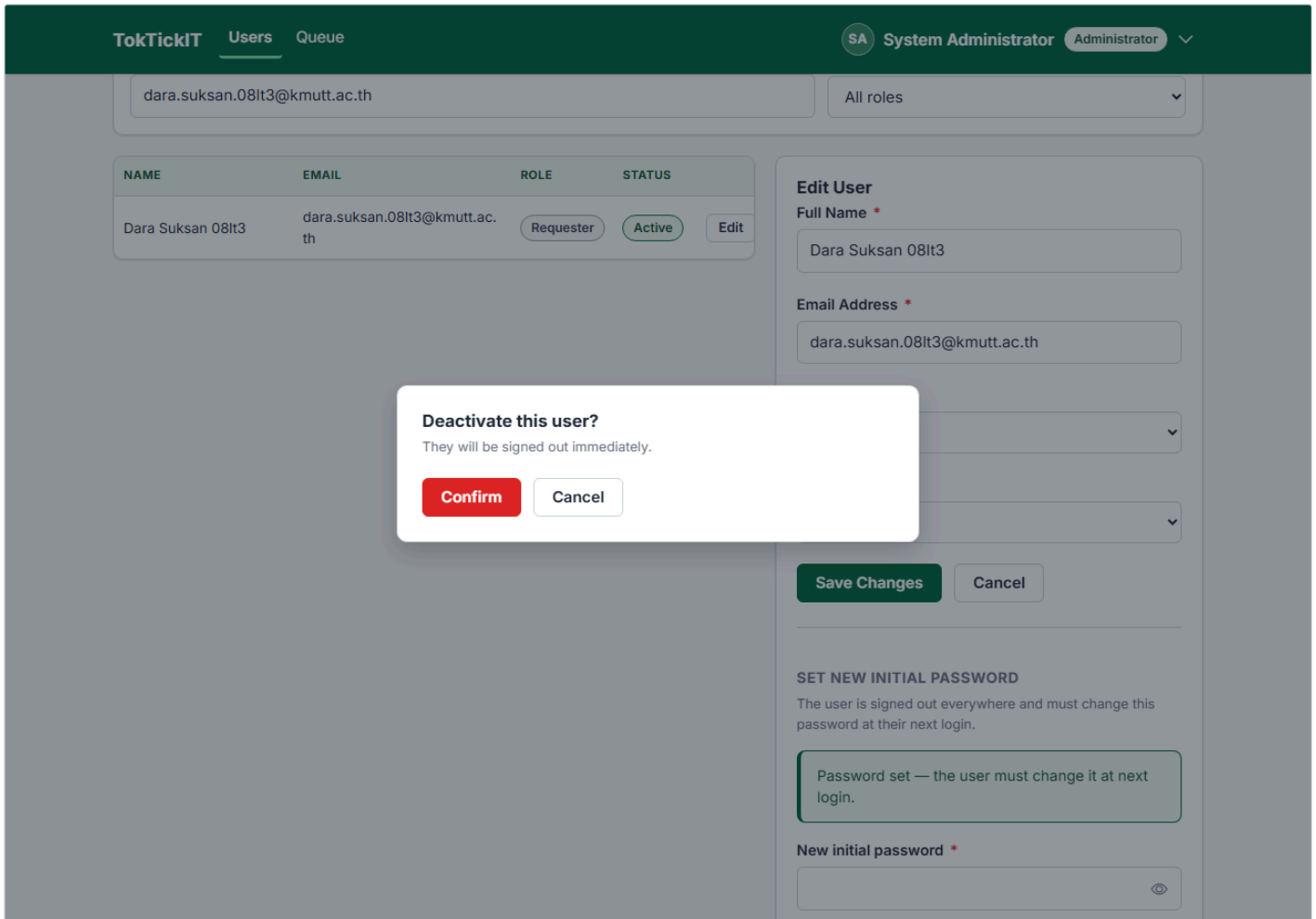
The user is signed out everywhere and must change this password at their next login.

New initial password *

[Set Initial Password](#)

Edit User

Turning Active off asks first, and says what happens:



Deactivate this user?

5. A new initial password, and the change it forces

Setting one stores its hash, sets `mustChangePassword`, and ends every session of that user. At the next login the user goes straight to Change Password.

Users

Accounts, roles and access for the whole system.

[Create User](#)

TokTickIT Users Queue

SA System Administrator Administrator ▾

All roles ▾

NAME	EMAIL	ROLE	STATUS
Dara Suksan 08lt3	dara.suksan.08lt3@kmutt.ac.th	Requester	Active Edit

Edit User

Full Name *

Email Address *

Role *

Requester ▾

Active

Yes ▾

[Save Changes](#)[Cancel](#)

SET NEW INITIAL PASSWORD

The user is signed out everywhere and must change this password at their next login.

Password set — the user must change it at next login.

New initial password *

[Set Initial Password](#)

Password set

TokTickIT

DS

Dara Suksan 08It3

Requester

Log out

TokTickIT

Change Your Password

You must change your password to continue.

Current (temporary) password *

New password *

At least 8 characters

One upper-case letter

One lower-case letter

One digit

One special character

Confirm new password *

Continue

URL: /change-password - dara.suksan.08It3@kmutt.ac.th signed in with the new initial password

Next login goes to Change Password

6. The two safety guards

On the Administrator's own account, Active is disabled — "You cannot deactivate your own account." As the only active Administrator, Role is disabled too — "At least one active administrator is required." The disabled controls are feedback; the server enforces both with 409 (BR-25, BR-26) — see the last line of the Part 7 transcript — and the panel shows that 409 inline if it is ever reached.

TokTickIT

Users

Queue

SA

System Administrator

Administrator

Create User

Users

Accounts, roles and access for the whole system.

Search

admin@toktickit.xyz

Role

All roles

NAME	EMAIL	ROLE	STATUS	
System Administrator (you)	admin@toktickit.xyz	Administrator	Active	Edit

Edit User

Full Name *

System Administrator

Email Address *

admin@toktickit.xyz

Role *

Administrator

Active

Yes

You cannot deactivate your own account.

At least one active administrator is required.

Save Changes

Cancel

SET NEW INITIAL PASSWORD

The user is signed out everywhere and must change this password at their next login.

New initial password *

Set Initial Password

Both guards

7. Forbidden for other roles; safe failure

IT Staff and Requesters get the forbidden state and no user data; the API answers 403 before a user is loaded (AC-30). With the API unreachable, the list says so plainly and offers Retry.

Users

Accounts, roles and access for the whole system.

[Create User](#)

Search

Role

⚠ Could not reach the server. Please check your connection and try again. [Retry](#)

Safe failure

IT Staff on /admin/users (mobile)



You don't have access to this page

This area is not available for your role.

[Go to your home](#)

URL: /admin/users – IT Staff

8. Responsive

Desktop puts the list and the panel side by side (60 / 40); tablet stacks the panel above the list; mobile shows each user as a card.

TokTickITUsersQueue

SA System AdministratorAdministrator

Users

Create User

Accounts, roles and access for the whole system.

Search

@kmutt.ac.th

Role

IT Staff

NAME	EMAIL	ROLE	STATUS	
Chen Wei	chen.wei@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui000uc	e2e.newstaff.mui000uc@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui0ca21	e2e.newstaff.mui0ca21@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui0hesz	e2e.newstaff.mui0hesz@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui0szzb	e2e.newstaff.mui0szzb@kmutt.ac.th	IT Staff	Active	Edit
E2E Role Change mui003lg	e2e.rolechange.mui003lg@kmutt.ac.th	IT Staff	Active	Edit
E2E Role Change mui0cbxu	e2e.rolechange.mui0cbxu@kmutt.ac.th	IT Staff	Active	Edit
E2E Role Change mui0hgua	e2e.rolechange.mui0hgua@kmutt.ac.th	IT Staff	Active	Edit
E2E Role Change mui0t20p	e2e.rolechange.mui0t20p@kmutt.ac.th	IT Staff	Active	Edit
Nattapong Srisuk	nattapong.srisuk@kmutt.ac.th	IT Staff	Active	Edit
Priya Raman	priya.raman@kmutt.ac.th	IT Staff	Active	Edit
Robert Wilson	robert.wilson@kmutt.ac.th	IT Staff	Inactive	Edit

Edit User

Full Name *
Priya Raman

Email Address *
priya.raman@kmutt.ac.th

Role *
IT Staff

Active
Yes

Save ChangesCancel

SET NEW INITIAL PASSWORD

The user is signed out everywhere and must change this password at their next login.

New initial password *

Set Initial Password

Desktop 1280

TokTickIT

UsersQueue

SA System AdministratorAdministrator

Users

Create User

Accounts, roles and access for the whole system.

Search

@kmutt.ac.th

Role

IT Staff

Edit User

Full Name *

Priya Raman

Email Address *

priya.raman@kmutt.ac.th

Role *

IT Staff

Active

Yes

Save Changes

Cancel

SET NEW INITIAL PASSWORD

The user is signed out everywhere and must change this password at their next login.

New initial password *

Set Initial Password

NAME

EMAIL

ROLE

STATUS

Chen Wei

chen.wei@kmutt.ac.th

IT Staff

Active

Edit

TokTickIT

Menu

E2E Role Change mui0hgua

Active

e2e.rolechange.mui0hgua@kmutt.ac.th

IT Staff

Edit

E2E Role Change mui0t20p

Active

e2e.rolechange.mui0t20p@kmutt.ac.th

IT Staff

Edit

Nattapong Srisuk

Active

nattapong.srisuk@kmutt.ac.th

IT Staff

Edit

Priya Raman

Active

priya.raman@kmutt.ac.th

IT Staff

Edit

Robert Wilson

Inactive

robert.wilson@kmutt.ac.th

IT Staff

Edit

Answer Part 9:

Zen Green UI and Responsive Evidence · 5 points

Answer Part 9 — Zen Green UI and Responsive Evidence

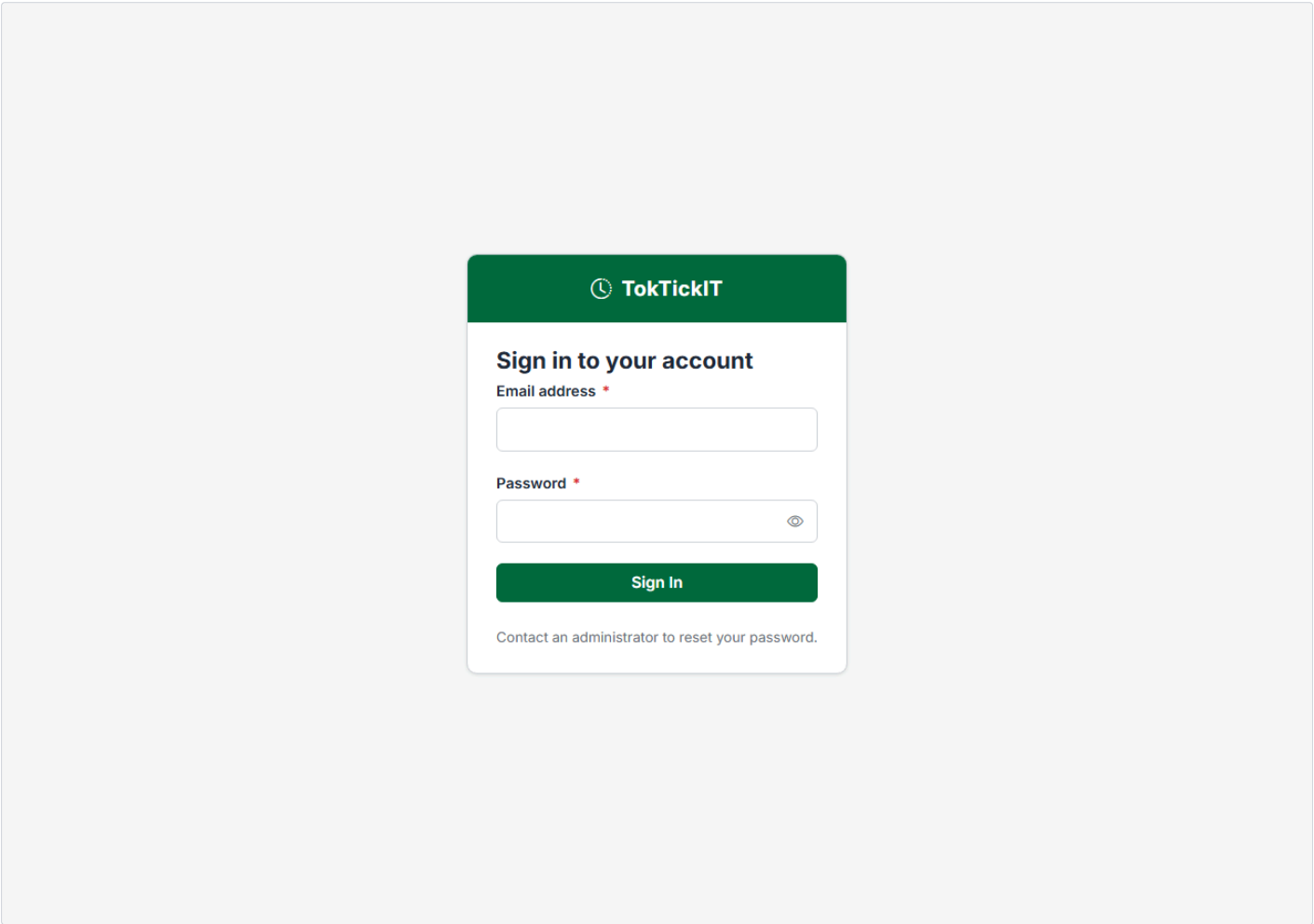
Link: [docs/lab-03/ui-spec.md](#) — rendered in full after this page. Its \$5 is the **completed visual checklist** (V-01 ... V-14): design consistency, role navigation, badges, editable vs read-only fields, validation placement, focus, clipping, overlap and horizontal overflow, each ticked at all three widths with the evidence named.

Every screenshot below was written by `CAPTURE=1 npx playwright test e2e/lab-03/visual.spec.ts` (E2E-07) on a freshly seeded database. The same spec runs without the flag in every test run and **asserts** what a screenshot can only show:

Check	How it is measured
No horizontal page overflow (V-03)	<code>documentElement.scrollWidth ≤ innerWidth</code> on every screen at 1280, 820 and 375 px
Focus indicator on every control (V-05)	the first 25 tab stops on Login, Queue, staff detail and Users each draw an outline or focus shadow
Every input labelled; password toggles announce state (V-06)	each <code>input</code> / <code>select</code> / <code>textarea</code> has a label; each toggle has <code>aria-pressed</code>
Badge contrast ≥ 4.5 : 1 (V-07)	WCAG contrast computed for every badge on the queue (all eight statuses), staff detail, Internal Notes and Users
Role navigation (V-10)	each role's exact link list
Clean console (Definition of Done)	no console error or uncaught exception on each role's happy path

This pass found and fixed three defects no earlier check had caught: the queue page scrolling sideways at 820 px, the mobile header sheet running off-screen, and the Cancelled badge at 4.39 : 1.

1. Login and Change Password



Login — desktop 1280

 TokTickIT

Sign in to your account

Email address *

Password *

Sign In

Contact an administrator to reset your password.

 TokTickIT

Sign in to your account

Email address *

Password *

Sign In

Contact an administrator to reset your password.



Change Your Password

You must change your password to continue.

Current (temporary) password *

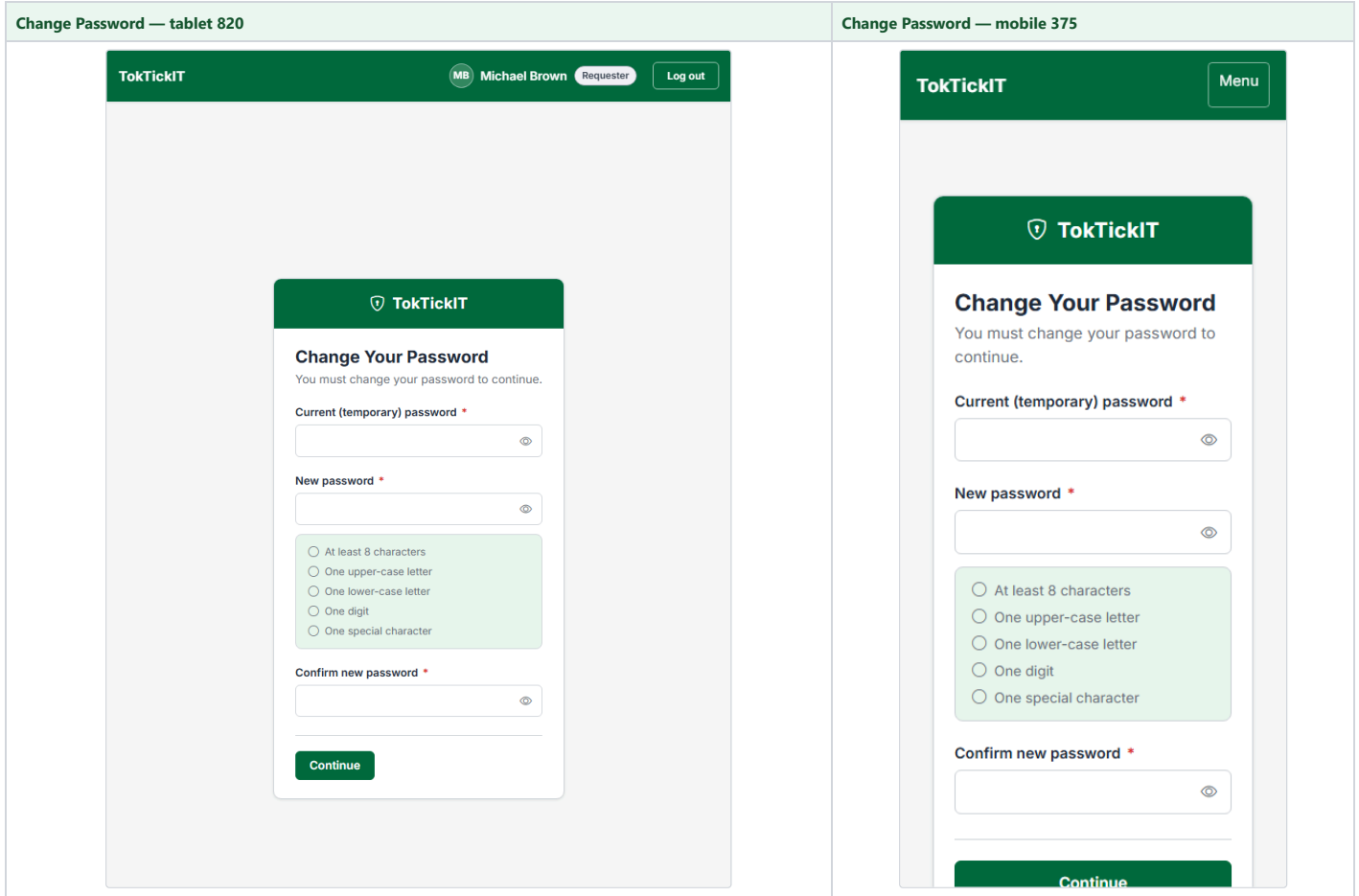
New password *

- ☐ At least 8 characters
- ☐ One upper-case letter
- ☐ One lower-case letter
- ☐ One digit
- ☐ One special character

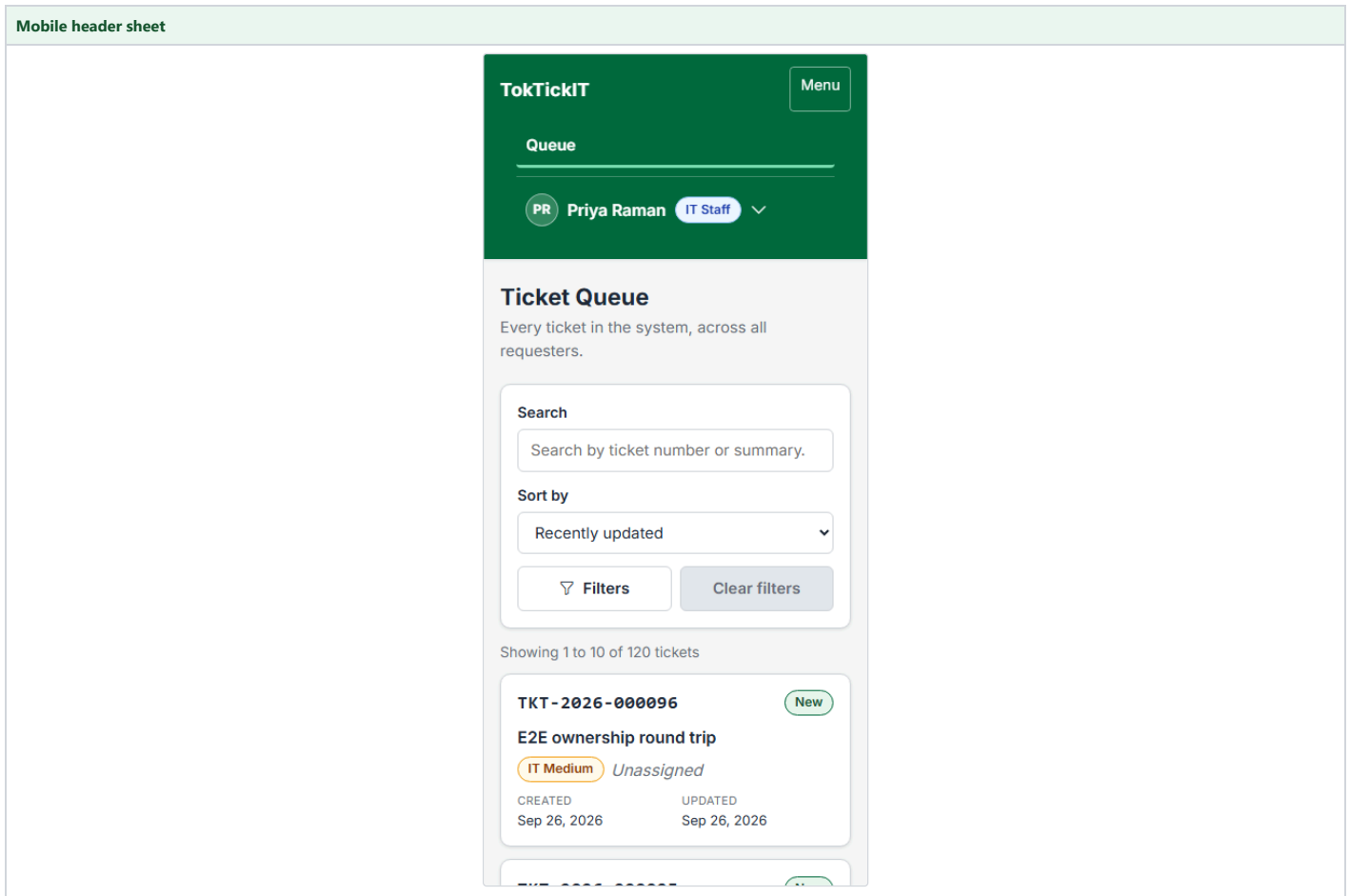
Confirm new password *

Continue

Change Password (forced) — desktop 1280



The mobile header collapses behind **Menu**; opened, navigation and the profile stack full-width under the bar:



2. IT Staff Ticket Queue

TokTickIT

Queue

PR

Priya Raman

IT Staff

▼

Ticket Queue

Every ticket in the system, across all requesters.

Search

TKT-2026-9000

Sort by

Recently updated

▼

Filters

●

Clear filters

Showing 1 to 10 of 24 tickets

TICKET NO. ⬆️⬆️	CREATED ⬆️⬆️	SUMMARY	CATEGORY	REQ. PRIORITY	IT PRIORITY ⬆️⬆️	STATUS ⬆️⬆️	OWNER	UPDATED ⬆️⬆️	
TKT-2026-900001	Sep 18, 2026	Cannot sign in to LEB2 after password reset	Account and Access	High	IT High	New	Unassigned	Sep 18, 2026	Open
TKT-2026-900002	Sep 18, 2026	Printer on floor 3 jams on every duplex job	Hardware	Medium	IT Medium	New	Unassigned	Sep 18, 2026	Open
TKT-2026-900003	Sep 17, 2026	Request access to the grade submission app fo...	Account and Access	Low	IT Low	New	Unassigned	Sep 17, 2026	Open
TKT-2026-900007	Sep 14, 2026	Outlook keeps asking for the password	Software	High	IT High	In Progress	Chen Wei	Sep 17, 2026	Open
TKT-2026-900004	Sep 16, 2026	VPN disconnects every 10 minutes from home	Network	High	IT High	Open	Nattapong Srisuk	Sep 17, 2026	Open
TKT-2026-900005	Sep 15, 2026	Laptop battery drains from 100% to 20% in an...	Hardware	Medium	IT High	Open	Priya Raman YOU	Sep 17, 2026	Open
TKT-2026-900024	Sep 13, 2026	Projector in room 402 shows a pink tint	Hardware	Medium	IT Medium	In Progress	Nattapong Srisuk	Sep 17, 2026	Open
TKT-2026-900022	Sep 17, 2026	Guest Wi-Fi vouchers for the open day	Network	Medium	IT Medium	New	Unassigned	Sep 17, 2026	Open
TKT-2026-900008	Sep 14, 2026	Grade submission app shows last semester...	Software	High	IT High	In Progress	Priya Raman YOU	Sep 16, 2026	Open
TKT-2026-900023	Sep 16, 2026	Email signature not applied on mobile	Software	Low	IT Low	Open	Unassigned	Sep 16, 2026	Open

Previous

1

2

3

Next

Page 1 of 3

Per page

10

▼

Queue — desktop 1280, table

TokTickIT

Queue

PR Priya RamanIT Staff

Ticket Queue

Every ticket in the system, across all requesters.

Search

TKT-2026-9000

Sort by

Recently updated

Filters

Clear filters

Showing 1 to 10 of 24 tickets

Ticket No.	Created	Summary	Category	Req. Priority	IT Priority	Status
TKT-2026-900001	Sep 18, 2026	Cannot sign in to LEB2 after password reset	Account and Access	High	IT High	New
TKT-2026-900002	Sep 18, 2026	Printer on floor 3 jams on every duplex job	Hardware	Medium	IT Medium	New
TKT-2026-900003	Sep 17, 2026	Request access to the grade submission app f...	Account and Access	Low	IT Low	New
TKT-2026-900007	Sep 14, 2026	Outlook keeps asking for the password	Software	High	IT High	In Progress
TKT-2026-900004	Sep 16, 2026	VPN disconnects every 10 minutes from home	Network	High	IT High	Open
TKT-2026-900005	Sep 15, 2026	Laptop battery drains from 100% to 20% in an...	Hardware	Medium	IT High	Open
TKT-2026-900024	Sep 13, 2026	Projector in room 402 shows a pink tint	Hardware	Medium	IT Medium	In Progress
TKT-2026-900022	Sep 17, 2026	Guest Wi-Fi vouchers for the open day	Network	Medium	IT Medium	New
TKT-2026-900008	Sep 14, 2026	Grade submission app shows last semester...	Software	High	IT High	In Progress
TKT-2026-900023	Sep 16, 2026	Email signature not applied on mobile	Software	Low	IT Low	Open

Previous

1

2

3

Next

Page 1 of 3

Per page

10

TokTickIT

Menu

Ticket Queue

Every ticket in the system, across all requesters.

Search

TKT-2026-9000

Sort by

Recently updated

Filters

Clear filters

Showing 1 to 10 of 24 tickets

TKT-2026-900001

New

Cannot sign in to LEB2 after password reset

IT High

Unassigned

CREATED

Sep 18, 2026

UPDATED

Sep 18, 2026

TKT-2026-900002

New

Printer on floor 3 jams on every duplex job

IT Medium

Unassigned

3. IT Staff Ticket Detail

TokTickITQueue

PRPriya RamanIT Staff

Queue / Ticket Detail

Back to Queue

Grade submission app shows last semester sections

TKT-2026-900008In ProgressHighIT High

Ticket operations

Ticket Owner

Priya Raman

IT Priority

High

Current Status

In Progress

Ticket details

TICKET NO.

TKT-2026-900008

CATEGORY

Software

RELATED SYSTEM

Grade Submission App

REQUESTED PRIORITY

High

REQUESTER

David Lee · david.lee@kmutt.ac.th · Engineering

CREATED

Sep 14, 2026, 11:00 AM

UPDATED

Sep 16, 2026, 10:40 PM

SUMMARY

Grade submission app shows last semester sections

DESCRIPTION

The section list has not rolled over to the current semester, so grades cannot be entered.

Public Comments (2)

Internal Notes (2)

Attachments (0)

Public Comments (2)

Visible to you and to the IT team working on this ticket.

Add public comment

Reply to the requester...

0 / 2000

Post Comment

PR

Priya Raman

IT Staff

12 days ago

Thanks for reporting this. We have picked it up and are investigating.

DL

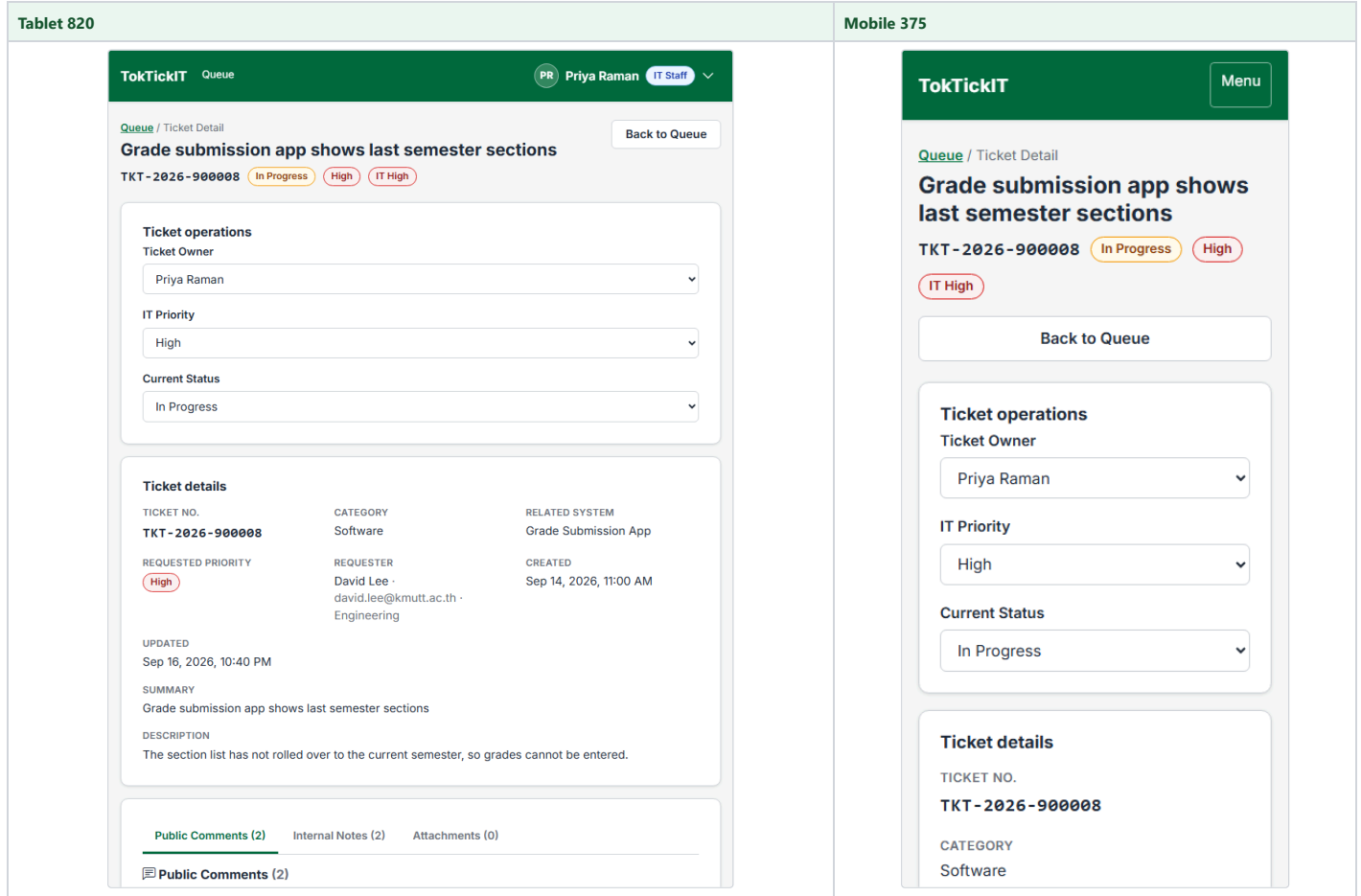
David Lee

Requester

12 days ago

Is there any update on this? It is still happening today.

Staff detail — desktop 1280



Public Comments and Internal Notes are visibly distinct (V-12), and confirmations are sized for a phone (V-14):

Queue / Ticket Detail

Back to Queue

Grade submission app shows last semester sections

TKT - 2026-900008 In Progress High IT High

Ticket operations

Ticket Owner

Priya Raman

IT Priority

High

Current Status

In Progress

Ticket details

TICKET NO.	CATEGORY	RELATED SYSTEM	REQUESTED PRIORITY
David Lee · david.lee@kmutt.ac.th · Engineering	Sep 14, 2026, 11:00 AM	Sep 16, 2026, 10:40 PM	

SUMMARY

Grade submission app shows last semester sections

DESCRIPTION

The section list has not rolled over to the current semester, so grades cannot be entered.

Public Comments (2) Internal Notes (2) Attachments (0)

Internal Notes (2)

Internal — not visible to the requester.

Add internal note

Private note for IT Staff...

0 / 2000

Add Internal Note

Priya Raman IT Staff 12 days ago

Waiting on the hardware swap before we move this any further.

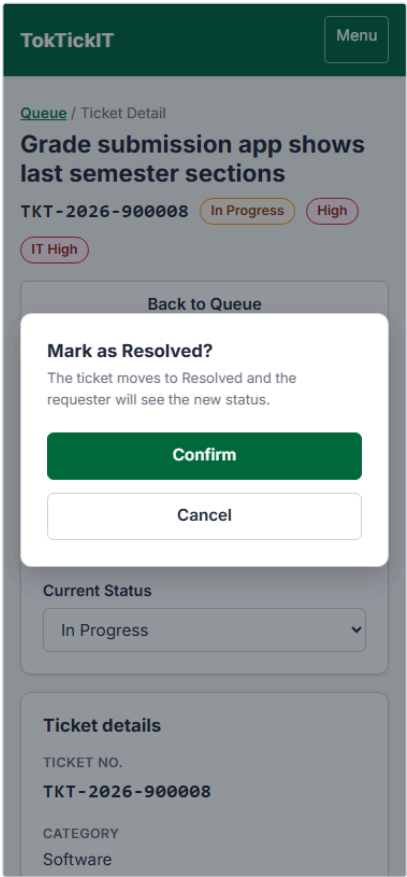
Priya Raman IT Staff 12 days ago

Vendor case opened, reference pending. Do not share with the requester.

Internal Notes (amber) vs Public Comments

CPE334 Lab 3 — TokTickIT — Thawat Boonsuk 67070501024

102/114



4. Administrator User Management

TokTickIT

Users

Queue

SA

System Administrator

Administrator

Users

Create User

Accounts, roles and access for the whole system.

Search

@kmutt.ac.th

Role

IT Staff

NAME	EMAIL	ROLE	STATUS	
Chen Wei	chen.wei@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui000uc	e2e.newstaff.mui000uc@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui0ca21	e2e.newstaff.mui0ca21@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui0hesz	e2e.newstaff.mui0hesz@kmutt.ac.th	IT Staff	Active	Edit
E2E New Staff mui0szzb	e2e.newstaff.mui0szzb@kmutt.ac.th	IT Staff	Active	Edit
E2E Role Change mui003lg	e2e.rolechange.mui003lg@kmutt.ac.th	IT Staff	Active	Edit
E2E Role Change mui0cbxu	e2e.rolechange.mui0cbxu@kmutt.ac.th	IT Staff	Active	Edit
E2E Role Change mui0hgua	e2e.rolechange.mui0hgua@kmutt.ac.th	IT Staff	Active	Edit
E2E Role Change mui0t20p	e2e.rolechange.mui0t20p@kmutt.ac.th	IT Staff	Active	Edit
Nattapong Srisuk	nattapong.srisuk@kmutt.ac.th	IT Staff	Active	Edit
Priya Raman	priya.raman@kmutt.ac.th	IT Staff	Active	Edit
Robert Wilson	robert.wilson@kmutt.ac.th	IT Staff	Inactive	Edit

Edit User

Full Name *

Priya Raman

Email Address *

priya.raman@kmutt.ac.th

Role *

IT Staff

Active

Yes

Save Changes

Cancel

SET NEW INITIAL PASSWORD

The user is signed out everywhere and must change this password at their next login.

New initial password *

Set Initial Password

Users — desktop 1280, list + panel

TokTickIT

UsersQueue

SA System AdministratorAdministrator

Users

Create User

Accounts, roles and access for the whole system.

Search

@kmutt.ac.th

Role

IT Staff

Edit User

Full Name *

Priya Raman

Email Address *

priya.raman@kmutt.ac.th

Role *

IT Staff

Active

Yes

Save Changes

Cancel

SET NEW INITIAL PASSWORD

The user is signed out everywhere and must change this password at their next login.

New initial password *

Set Initial Password

NAME	EMAIL	ROLE	STATUS
Chen Wei	chen.wei@kmutt.ac.th	IT Staff	Active

TokTickIT

Menu

E2E Role Change mui0hgua

e2e.rolechange.mui0hgua@kmutt.ac.th

IT Staff

Active

Edit

E2E Role Change mui0t20p

e2e.rolechange.mui0t20p@kmutt.ac.th

IT Staff

Active

Edit

Nattapong Srisuk

nattapong.srisuk@kmutt.ac.th

IT Staff

Active

Edit

Priya Raman

priya.raman@kmutt.ac.th

IT Staff

Active

Edit

Robert Wilson

robert.wilson@kmutt.ac.th

IT Staff

Inactive

Edit

5. Requester screens changed in Lab 3

The shared badges, IT Priority, owner, Public Comments and "Problem appears resolved" reach the Requester's screens too.

My Tickets

Tickets raised by Jennifer Anderson.

Create Ticket

Search

Ticket number or summary

Category

All categories



Status

All statuses



Sort by

Newest first



Clear Filters

Showing 1–10 of 102 tickets

Ticket No.	Created Date	Summary	Category	Requested Priority	IT Priority	Current Status	Ticket Owner	Last Updated	
TKT-2026-000096	Sep 26, 2026	E2E ownership round trip	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
TKT-2026-000095	Sep 26, 2026	E2E ownership of attachments	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
TKT-2026-000094	Sep 26, 2026	E2E ownership guard	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
TKT-2026-000093	Sep 26, 2026	E2E requester signal to staff	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
TKT-2026-000092	Sep 26, 2026	E2E staff attachment read path	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
TKT-2026-000091	Sep 26, 2026	E2E administrator read-only	Account and Access	Medium	IT Medium	Open	Priya Raman	Sep 26, 2026	Detail
TKT-2026-000090	Sep 26, 2026	E2E invalid transition	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail
TKT-2026-000089	Sep 26, 2026	E2E owner rule	Account and Access	Medium	IT Medium	Open	Priya Raman	Sep 26, 2026	Detail
TKT-2026-000088	Sep 26, 2026	E2E staff operations journey	Account and Access	Medium	IT High	Closed	Priya Raman	Sep 26, 2026	Detail
TKT-2026-000087	Sep 26, 2026	E2E appears resolved cancelled	Account and Access	Medium	IT Medium	New	Unassigned	Sep 26, 2026	Detail

Previous

1

2

3

4

5

Next

Page 1 of 11

Per page

10



TokTickIT

My Tickets

Create Ticket

JA

Jennifer Anderson

Requester

My Tickets

Create Ticket

Tickets raised by Jennifer Anderson.

Search

Category

Status

Ticket number or summary

All categories

All statuses

Sort by

Newest first

Clear Filters

Showing 1-10 of 102 tickets

TICKET NO.	CREATED DATE	SUMMARY	CATEGORY	REQUESTED PRIORITY	IT PRIORITY	CURRENT STATUS
TKT-2026-000096	Sep 26, 2026	E2E ownership round trip	Account and Access	Medium	IT Medium	New
TKT-2026-000095	Sep 26, 2026	E2E ownership of attachments	Account and Access	Medium	IT Medium	New
TKT-2026-000094	Sep 26, 2026	E2E ownership guard	Account and Access	Medium	IT Medium	New
TKT-2026-000093	Sep 26, 2026	E2E requester signal to staff	Account and Access	Medium	IT Medium	New
TKT-2026-000092	Sep 26, 2026	E2E staff attachment read path	Account and Access	Medium	IT Medium	New
TKT-2026-000091	Sep 26, 2026	E2E administrator read-only	Account and Access	Medium	IT Medium	Open
TKT-2026-000090	Sep 26, 2026	E2E invalid transition	Account and Access	Medium	IT Medium	New
TKT-2026-000089	Sep 26, 2026	E2E owner rule	Account and Access	Medium	IT Medium	Open
TKT-2026-000088	Sep 26, 2026	E2E staff operations journey	Account and Access	Medium	IT High	Closed
TKT-2026-000087	Sep 26, 2026	E2E appears resolved cancelled	Account and Access	Medium	IT Medium	New

TokTickIT

Menu

My Tickets

Create Ticket

Tickets raised by Jennifer Anderson.

Search

Category

Status

Sort by

Ticket number or summary

All categories

All statuses

Newest first

Clear Filters

Showing 1-10 of 102 tickets

TKT-2026-000096

New

E2E ownership round trip

Medium

Account and Access

CREATED

LAST UPDATED

TokTickITMy TicketsCreate Ticket

JAJennifer AndersonRequester

My Tickets / TKT-2026-900005

Problem appears resolved

Laptop battery drains from 100% to 20% in an hour

TKT-2026-900005OpenMediumIT HighOwner: Priya RamanCreated Sep 15, 2026, 08:10 PM

Ticket details

This view is read-only. Ticket fields are set when the ticket is created and are changed by the IT team, not here.

TICKET NO.	CREATED DATE	CATEGORY	RELATED SYSTEM
TKT-2026-900005	Sep 15, 2026, 08:10 PM	Hardware	Corporate Laptop
REQUESTER	REQUESTED PRIORITY	IT PRIORITY	CURRENT STATUS
Jennifer Anderson · Registrar	Medium	IT High	Open
TICKET OWNER	LAST UPDATED		
Priya Raman	Sep 17, 2026, 02:45 PM		
SUMMARY			
Laptop battery drains from 100% to 20% in an hour			
DESCRIPTION			
The corporate laptop no longer lasts a meeting on battery. Battery report attached in the original email.			

Attachments (0 of 5 active)

No files are attached to this ticket yet.

Add a file

JPG, PNG, WEBP, PDF up to 5.0 MB. A ticket can hold 5 active files; removing one frees a slot.

Choose FilesNo file chosen

Public Comments (2)

Visible to you and to the IT team working on this ticket.

Add public comment

Reply to the requester...

0 / 2000

Post Comment

PR

Priya Raman

IT Staff

11 days ago

We have made a change on our side; please tell us whether it helps.

JA

Jennifer Anderson

Requester

11 days ago

Thanks for looking into it — let me know if you need anything from my side.

Ticket Detail — tablet 820

TokTickITMy TicketsCreate TicketJAJennifer AndersonRequester

My Tickets / TKT-2026-900005

Laptop battery drains from 100% to 20% in an hour

TKT-2026-900005OpenMediumIT High

Owner: Priya RamanCreated Sep 15, 2026, 08:10 PM

Ticket details

This view is read-only. Ticket fields are set when the ticket is created and are changed by the IT team, not here.

TICKET NO.

TKT-2026-900005

CREATED DATE

Sep 15, 2026, 08:10 PM

CATEGORY

Hardware

RELATED SYSTEM

Corporate Laptop

REQUESTER

Jennifer Anderson · Registrar

REQUESTED PRIORITY

Medium

IT PRIORITY

IT High

CURRENT STATUS

Open

TICKET OWNER

Priya Raman

LAST UPDATED

Sep 17, 2026, 02:45 PM

SUMMARY

Laptop battery drains from 100% to 20% in an hour

DESCRIPTION

The corporate laptop no longer lasts a meeting on battery. Battery report attached in the original email.

Attachments (0 of 5 active)

No files are attached to this ticket yet.

Add a file

JPG, PNG, WEBP, PDF up to 5.0 MB. A ticket can hold 5 active files; removing one frees a slot.

Choose FilesNo file chosen

Public Comments (2)

Visible to you and to the IT team working on this ticket.

Add public comment

Ticket Detail — mobile 375

TokTickITMenu

My Tickets / TKT-2026-900005

Laptop battery drains from 100% to 20% in an hour

TKT-2026-900005OpenMedium

IT HighOwner: Priya Raman

Created Sep 15, 2026, 08:10 PM

Problem appears resolved

Ticket details

This view is read-only. Ticket fields are set when the ticket is created and are changed by the IT team, not here.

TICKET NO.

TKT-2026-900005

CREATED DATE

Sep 15, 2026, 08:10 PM

CATEGORY

Hardware

RELATED SYSTEM

Corporate Laptop

REQUESTER

Jennifer Anderson · Registrar

REQUESTED PRIORITY

Lab 3 — UI Specification (Zen Green Theme)

Companion to [specification.md](#). Extends the [Lab 2 UI spec](#): its tokens, component rules, editable/read-only styling, breakpoints and tap-target rule all stay in force. This document adds the badges, shell changes and five new screens Lab 3 needs, and re-runs the visual checklist. Data behind each screen is in [api-spec.md](#).

1. Color Tokens

No new tokens. Lab 3 reuses `--zg-primary`, `--zg-secondary`, `--zg-pale`, `--zg-bg`, `--zg-surface`, `--zg-border`, `--zg-text`, `--zg-text-muted`, `--zg-error`, `--zg-warning`, `--zg-warning-bg`. One new semantic use: `--zg-warning` / `--zg-warning-bg` mark **Internal Notes** so private content is amber wherever it appears (\$2).

Editable vs. read-only controls

Unchanged. Lab 3 relies on this distinction heavily on the IT Staff Ticket Detail: the Requester-owned fields (summary, description, category, related system, requested priority, requester) are read-only values with muted labels; the operational fields (owner, IT priority, status) are real `select` controls with input chrome. A user must be able to tell at a glance which four things they can change.

2. Component Rules

All Lab 2 rules apply (labels above inputs, asterisk on required, errors under the field, form-level callout above actions, busy state on submit, one primary button per screen, focus ring in `--zg-secondary`, level written inside every badge).

Badges

Badge	Class	Values	Style
Status	<code>.zg-badge-status-{new,open,in-progress,waiting,resolved,closed,reopened,cancelled}</code>	the eight <code>TicketStatus</code> values, shown as "New", "Open", "In Progress", "Waiting for Requester", "Resolved", "Closed", "Reopened", "Cancelled"	New: pale fill / primary border (Lab 2). Open: <code>#EFF6FF</code> / <code>#93C5FD</code> / <code>#1E40AF</code> . In Progress: <code>--zg-warning-bg</code> / <code>--zg-warning</code> / <code>#92400E</code> . Waiting for Requester: <code>#F5F3FF</code> / <code>#C4B5FD</code> / <code>#5B21B6</code> . Resolved: <code>--zg-pale</code> / <code>--zg-secondary</code> / <code>#14532D</code> . Closed: <code>#F3F4F6</code> / <code>#9CA3AF</code> / <code>#374151</code> . Reopened: <code>#FFF7ED</code> / <code>#FDBA74</code> / <code>#9A3412</code> . Cancelled: <code>#F3F4F6</code> / <code>#D1D5DB</code> / <code>#4B5563</code> with strike-through label (text darkened from the first draft's <code>#6B7280</code> , which measured 4.39:1 — under V-07)
Requested Priority	<code>.zg-badge-priority-{low,medium,high}</code>	Low / Medium / High	Unchanged from Lab 2

CPE334 Lab 3 — TokTickIT — Thawat Boonsuk 67070501024

109/114

Badge	Class	Values	Style
IT Priority	<code>.zg-badge-it-priority-{low,medium,high}</code>	Low / Medium / High	Same fills as Requested Priority, plus a leading "IT" prefix in the label ("IT High") so the two columns are never confused when they differ
Role	<code>.zg-badge-role-{requester,it-staff,administrator}</code>	Requester / IT Staff / Administrator	Requester: #F3F4F6 / #9CA3AF / #374151 . IT Staff: #EFF6FF / #93C5FD / #1E40AF . Administrator: <code>--zg-pale</code> / <code>--zg-primary</code> / #14532D
Account status	<code>.zg-badge-active</code> , <code>.zg-badge-inactive</code>	Active / Inactive	Active: <code>--zg-pale</code> / <code>--zg-secondary</code> . Inactive: #FEF2F2 / <code>--zg-error</code> / #991B1B
Owner	<code>.zg-owner</code> / <code>.zg-owner-unassigned</code>	name, or italic muted <i>Unassigned</i>	Lab 2 <code>NotAssigned</code> placeholder, now shared
Requester resolution indicator	<code>.zg-badge-requester-resolved</code>	"Requester reports resolved"	<code>--zg-pale</code> fill, dashed <code>--zg-secondary</code> border, check icon; shown in the staff detail header and as an icon in the queue row

Badge components are extracted once into `client/src/components/Badges.tsx` (`StatusBadge` , `PriorityBadge` , `ItPriorityBadge` , `RoleBadge` , `ActiveBadge` , `OwnerName`) and used by every screen; the Lab 2 copies in `MyTickets.tsx` and `TicketDetail.tsx` are removed.

Public vs Internal (BR-04, handout §8.4)

	Public Comments	Internal Notes
Panel heading	"Public Comments" with a speech-bubble icon	"Internal Notes" with a lock icon and an amber "Internal — not visible to the requester" caption
Entry style	White card, <code>--zg-border</code> left border	<code>--zg-warning-bg</code> card, 4 px <code>--zg-warning</code> left border
Composer	Label "Add public comment"; placeholder "Reply to the requester..."	Label "Add internal note"; placeholder "Private note for IT Staff..."; amber border on the textarea
Submit button	Primary "Post Comment"	Outlined amber "Add Internal Note"
Body rendering	Text node, <code>white-space: pre-wrap</code> , never HTML	Same

The two composers are never on screen at the same time (they live in separate tabs), so a note cannot be typed into the wrong box.

Confirmation dialog

Reuses `.zg-modal` . Title names the action ("Mark as Resolved?", "Cancel this ticket?"), one sentence of consequence, Cancel (secondary) and Confirm (primary; `--zg-error` fill for Cancel-ticket and Deactivate-user). Confirm shows a busy state; the dialog stays open on failure and shows the error inside it.

Feedback states (handout §8.6)

Every screen below implements the states from this table where the row says so:

State	Presentation
Loading	<code>.zg-spinner</code> centred in the card/table area with "Loading..." text; controls disabled
Saving	Button busy state (label swap + spinner), form disabled
Success	Green <code>.zg-callout-success</code> for 4 s, or inline change of the data (badge/list updates)
Validation	Field-level <code>.zg-field-error</code> under the control; form-level callout if the server returned no <code>fields</code>
Empty	Illustration-free message + primary call to action
No-results	Message "No tickets match your search or filters" + "Clear filters" button; visually distinct from Empty
Forbidden	<code>.zg-state-denied</code> : lock icon, "You don't have access to this page", link to the role's home
Not found	<code>.zg-state-denied</code> variant: "This ticket/user could not be found", link back
Conflict	Amber <code>.zg-callout-warning</code> with the server message, inline where the action was taken; the control reverts to its previous value
Safe failure	Red <code>.zg-callout-error</code> "Something went wrong. Please try again." + Retry; entered values preserved

3. Screens

Modes per screen are listed as **view / create / edit** where the screen has them.

3.0 Application Shell (header) — all roles

Element	Specification
Background	<code>--zg-primary</code> , full width, sticky top (unchanged)
App name	Left, on-primary; links to the role's home
Navigation	Requester: My Tickets, Create Ticket. IT Staff: Queue. Administrator: Users, Queue. Only the current role's links render; active item underlined in <code>--zg-secondary</code>
Profile menu	Right: avatar initials, user name, role badge (<code>RoLeBadge</code> , on-primary outline variant), chevron. Opens a menu with "Change password" and "Log out"

Element	Specification
Log out	Calls <code>POST /api/auth/logout</code> , clears client state, navigates to <code>/login</code> with <code>replace</code> ; the browser Back button lands on <code>/login</code> again because every guarded route re-checks <code>/api/auth/me</code>
Removed	The Development Requester block and the Change Requester button (FR-05)
Mobile	Nav collapses into a hamburger; profile menu becomes a full-width sheet with name, role badge and the two actions; all targets ≥ 44 px
Role home	Requester $\rightarrow$ <code>/tickets</code> ; IT Staff $\rightarrow$ <code>/staff/queue</code> ; Administrator $\rightarrow$ <code>/admin/users</code>
Route guards	<code>RequireAuth</code> redirects unauthenticated users to <code>/login?from=<path></code> ; a user with <code>mustChangePassword</code> is sent to <code>/change-password</code> from any route except <code>/login</code> , <code>/change-password</code> ; <code>RequireAuth roles={ [...]}</code> renders the Forbidden state when the role does not match (AC-11)

3.1 Login (/login) — mode: create session

Element	Specification
Layout	Single centred <code>.zg-card</code> (max 420 px) on <code>--zg-bg</code> ; app name and clock icon in a <code>--zg-primary</code> band at the top of the card (as the handout mockup)
Heading	"Sign in to your account"
Fields	Email address (type <code>email</code> , autocomplete <code>username</code>), Password (autocomplete <code>current-password</code> , show/hide toggle with <code>aria-pressed</code>)
Client validation	Email required and well-formed; password required. Shown under the field on submit, cleared on edit
Submit	Primary "Sign In", full width; busy state "Signing in..."
Invalid credentials (401)	Red callout above the button: "Invalid email or password. Please try again." Password field cleared, email kept, focus to password
Inactive account (403 ACCOUNT_INACTIVE)	Amber callout: "This account is inactive. Please contact an administrator." No further detail
Throttled (429)	Amber callout: "Too many failed attempts. Try again in a few minutes."; button disabled for 30 s
Safe failure	Red callout with Retry; values preserved
Success	If <code>mustChangePassword</code> $\rightarrow$ <code>/change-password</code> ; else $\rightarrow$ <code>from</code> param if it belongs to the role, otherwise the role home
Already signed in	Visiting <code>/login</code> with a valid session redirects to the role home
Forgot password	Not offered (X-01); a short muted line says "Contact an administrator to reset your password."

3.2 Change Password (/change-password) — mode: edit

Element	Specification
Layout	Same centred card as Login
Heading	"Change Your Password"; sub-line "You must change your password to continue." when <code>mustChangePassword</code> , otherwise "Choose a new password."
Fields	Current (temporary) password · New password · Confirm new password; each with show/hide
Rules panel	Pale card listing the BR-08 rules; each rule gets a check mark live as the new password satisfies it (<code>aria-live="polite"</code>)
Client validation	All three required; new $\neq$ current; confirm = new; rules satisfied. Server <code>400 fields</code> are mapped onto the same three fields
Submit	Primary "Continue" (forced mode) / "Save password" (voluntary); busy state
Success	Forced mode: navigate to the role home. Voluntary mode: success callout and stay
Shell	In forced mode the header shows only the app name and Log out — no navigation, because none of it is reachable (AC-02)
Cancel	Voluntary mode only: returns to the previous screen

3.3 Requester Ticket Detail (/tickets/:id) — additions to Lab 2 §3.4

Element	Specification
Header additions	<code>ItPriorityBadge</code> , owner name or <i>Unassigned</i> , and, once set, the "Requester reports resolved" indicator
"Problem appears resolved"	Secondary button in the header, shown while status $\notin$ {Resolved, Closed, Cancelled} and <code>requesterResolvedAt</code> is null. Opens the confirmation dialog ("Tell IT Staff this looks fixed?"). On success the button is replaced by the indicator with the timestamp (AC-15)
Public Comments panel	Below attachments. Composer (textarea, 2000-char counter, "Post Comment") then the list newest-first: avatar initials, author name, <code>RoleBadge</code> , relative time with full timestamp on hover, body. Empty: "No comments yet."
Validation	Empty/whitespace $\rightarrow$ "Comment cannot be empty." under the textarea; $> 2000 \rightarrow$ counter turns red and submit disabled
Not offered	Internal Notes, owner, IT priority, status controls — none render for a Requester, and the API refuses them anyway
Access denied / not found	Unchanged Lab 2 behaviour

3.4 IT Staff Ticket Queue (/staff/queue) — mode: view

Element	Specification
Toolbar	Search input (placeholder "Search by ticket number or summary...", debounced 300 ms) · "Filters" toggle revealing: Status (multi-select chips), IT Priority, Owner (Anyone / Me / Unassigned / each active IT Staff), Category · Sort select · "Clear filters"
Result line	"Showing 1 to 10 of 87 tickets"
Desktop table (≥ 992 px)	Columns in order: Ticket No. · Created · Summary · Category · Req. Priority · IT Priority · Status · Owner · Updated · Open. Sortable headers (Ticket No., Created, IT Priority, Status, Updated) show a sort icon; <code>aria-sort</code> set. Summary truncates to two lines with full text on hover/focus. Requester-resolved rows show the check icon before the status badge
Why these nine	Ticket No. and Summary identify the work; Created and Updated order it; Category routes it; the two priorities show what was asked vs what IT decided; Status and Owner say whether it is being handled and by whom. Requester name is left to the detail screen: the queue is about work, not people, and a tenth column pushes the table past the container
Tablet (768 – 991 px)	Table keeps all columns and scrolls inside its wrapper (Lab 2 rule)
Mobile (< 768 px)	Card per ticket: first line Ticket No. + Status badge; second line Summary (two lines max); third line IT Priority badge, Owner; footer Created / Updated. Whole card is the tap target
Open action	Table: "Open" text button; card: whole card. Navigates to <code>/staff/tickets/:id</code>
Pagination	Same component as My Tickets: Prev / Next, ≤ 5 numbered buttons, page-size 5 / 10 / 25 / 50, default 10; any filter change returns to page 1
Ownership at a glance	Owner column shows the name, or <i>Unassigned</i> in italic muted text; rows owned by the current user get a small "You" tag after the name
States	Loading (skeleton rows), Empty ("No tickets in the system yet."), No-results, Forbidden (Requester visiting the URL), Safe failure with Retry
Administrator	Same screen, read-only; the toolbar is identical and the Open action leads to the read-only detail

3.5 IT Staff Ticket Detail (/staff/tickets/:id) — modes: view (Administrator), edit (IT Staff)

Element	Specification
Breadcrumb	"Queue > Ticket Detail" and a "Back to Queue" outline button that preserves the queue's query string
Header	Ticket No., Summary, <code>StatusBadge</code> , <code>PriorityBadge</code> (requested), <code>ItPriorityBadge</code> , requester-resolved indicator
Read-only group	Ticket No., Category, Related System, Requester (name, email, department), Requested Priority, Summary, Description, Created, Updated — rendered as read-only values (§1)
Operational group (IT Staff)	Three controls on one row at desktop, stacked on mobile: <code>Ticket Owner select</code> (Unassigned + active IT Staff from <code>/api/staff/assignees</code>) with a "Claim" button beside it when the current user is not the owner; <code>IT Priority select</code> ; <code>Current Status select</code> listing only <code>permittedTransitions</code> from the API plus the current value. Each control saves on change (optimistic, with busy indicator on that control) and reverts with an inline conflict callout on <code>409</code>
Confirmations	Status → Resolved / Closed / Cancelled and reassigning a ticket that already has a different owner open the confirmation dialog first
Owner required	Choosing In Progress or Resolved while unassigned is blocked client-side with the hint "Assign an owner first"; the server rule is the real guard (AC-22)
Tabs	Public Comments (count) · Internal Notes (count) · Attachments (count). Tab panels follow WAI-ARIA tabs (arrow-key navigation)
Public Comments tab	As §3.3, composer visible to IT Staff
Internal Notes tab	Amber panel per §2; composer visible to IT Staff only
Attachments tab	Lab 2 attachment list, read-only: Download on active files, removed files muted with reason; no upload area and no Remove control (AC-24)
Administrator view	Operational controls render as read-only values (owner name, IT priority badge, status badge); both composers hidden; a muted line "Administrators can view but not change tickets."
States	Loading, Not found (<code>404</code>), Forbidden (Requester), Conflict (inline, per control), Safe failure (per action, entered comment/note text preserved)
Mobile	Read-only group becomes a single-column definition list; operational controls stack full-width; tabs become a scrollable tab strip

3.6 Administrator User Management (/admin/users) — modes: view list, create, edit

Element	Specification
Layout	Desktop: two columns — list (60 %) and side panel (40 %). Tablet: list full width, panel as a modal sheet. Mobile: list as cards, panel as a full-screen sheet
Toolbar	Heading "Users" · primary "Create User" · Search (name or email, debounced) · Role filter select (All roles / Requester / IT Staff / Administrator)
List (desktop/tablet)	Table: Name · Email · Role (<code>RoleBadge</code>) · Status (<code>ActiveBadge</code>) · Edit. Sorted by name; no pagination (X-12)
List (mobile)	Card: Name, Email, Role badge, Status badge, Edit button
Row for the current user	Name suffixed with "(you)"
Create panel	Heading "Create New User"; fields Full Name*, Email Address*, Role* (select), Active (toggle, default Yes), Initial Password* (with show/hide and the BR-08 rules panel). Actions: primary "Save User", secondary "Cancel". Server <code>409</code> on email shows under the Email field
Edit panel	Heading "Edit User"; fields Full Name*, Email Address*, Role*, Active (toggle). Actions: "Save Changes", "Cancel". A separate "Set new initial password" section with one password field and an outlined "Set Initial Password" button; success callout "Password set — the user must change it at next login."

Element	Specification
Deactivate	The Active toggle turned off then Save opens the confirmation dialog ("Deactivate this user? They will be signed out immediately."). For the current user the toggle is disabled with the hint "You cannot deactivate your own account." For the last active Administrator the toggle and the Role select are disabled with the hint "At least one active administrator is required." The server guard (409) is still shown inline if reached (AC-29)
No delete	No delete control anywhere (BR-27)
Not offered	Email invitation, "send reset email" checkbox, department, photo — the handout mockup's "Send password reset email" is deliberately absent (X-01)
States	Loading, Empty ("No users yet" cannot occur — the current Administrator always exists — so only No-results: "No users match."), Forbidden (non-Administrator), Not found (edit of a deleted-by-migration id), Validation, Conflict, Safe failure

4. Responsive Breakpoints

Unchanged from Lab 2: Desktop ≥ 992 px, Tablet 768 – 991 px, Mobile < 768 px; no horizontal page overflow; wide tables scroll inside their wrapper; 44 px tap targets below 768 px.

Lab 3 additions:

Screen	Tablet	Mobile
Login / Change Password	Same centred card	Card fills width with 16 px gutters; keyboard does not cover the submit button (card scrolls)
Queue	Table scrolls in wrapper; filters wrap to two rows	Cards; filters in a collapsible sheet
Staff Ticket Detail	Read-only group two columns; operational controls one row	Everything single column; tabs scroll horizontally
Users	List full width; panel as modal sheet	Cards; panel full screen
Shell	Nav inline; profile shows initials + chevron	Hamburger + profile sheet

5. Visual Inspection Checklist

Checked on 2026-09-26 against the running stack on a freshly reset and seeded database, at 1280 px, 820 px and 375 px. Every row names the evidence behind its ticks: an automated check in `e2e/lab-03/visual.spec.ts` (E2E-07) or a component test where one exists, otherwise the screenshots under `artifacts/Lab-03/screenshots/` listed in `tests.md` §4.

#	Item	Desktop	Tablet	Mobile	Evidence
V-01	Font family, sizes and weights match the theme on all new screens	☑	☑	☑	One stylesheet (<code>zen-green.css</code>) for every screen; R-01 ... R-20 screenshots
V-02	Consistent card/table padding; new screens reuse <code>.zg-card</code> / <code>.zg-table</code>	☑	☑	☑	Queue, staff detail and Users all use <code>.zg-card</code> / <code>.zg-table-wrap</code> / <code>.zg-table</code> ; R-08, R-12, R-17
V-03	No horizontal page overflow (<code>scrollWidth === innerWidth</code>)	☑	☑	☑	Asserted on every screen at all three widths by <code>visual.spec.ts</code> . Found and fixed in this pass: the queue at 820 px scrolled to 1009 px (a visually-hidden column label escaping the table wrapper) and the open mobile header sheet to 466 px (non-wrapping header row)
V-04	No clipped or truncated badges, buttons, or the nine queue columns	☑	☑	☑	R-08 (all ten columns inside 1066 px), R-09 (table scrolls inside its wrapper, not the page), R-10 (cards)
V-05	Focus ring visible on every interactive element, including tabs and the profile menu	☑	☑	☑	<code>visual.spec.ts</code> walks the first 25 tab stops on Login, Queue, staff detail and Users and asserts an outline or focus shadow on each; the tabs and profile button use <code>--zg-secondary</code> rings
V-06	Every input has an accessible label; password toggles have <code>aria-pressed</code>	☑	☑	☑	<code>visual.spec.ts</code> checks every <code>input</code> / <code>select</code> / <code>textarea</code> for a label and every password toggle for <code>aria-pressed</code> on the same four screens (Users with the create panel open)
V-07	Contrast ≥ 4.5:1 for all new badge colours and the amber Internal Note panel	☑	☑	☑	<code>visual.spec.ts</code> computes WCAG contrast for every badge on the queue (all eight statuses), staff detail, Internal Notes tab and Users. Found and fixed: Cancelled measured 4.39:1; its text is now <code>#4B5563</code> (§2)
V-08	Validation messages sit under the correct field on Login, Change Password, Create/Edit User, comment and note composers	☑	☑	☑	<code>p5-05-forced-change-validation</code> , <code>p8-04-invalid-input</code> , <code>users-conflict</code> (R-20), <code>p7-08-note-validation</code> ; UI-03, UI-06, UI-19, UI-22
V-09	Busy state visible on Sign In, Continue, Post Comment, Add Internal Note, Save User, Set Initial Password, Confirm	☑	☑	☑	Each button has a component test that holds the request open and asserts the busy label and disabled state (Login, ChangePassword, StaffTicketDetail, UserManagement suites); <code>p5-03-busy-signing-in</code>
V-10	Role navigation: only the current role's links and destinations are rendered	☑	☑	☑	<code>visual.spec.ts</code> asserts the exact link list per role (R-06); E2E-03; forbidden states <code>p7-14</code> , <code>p8-13</code>
V-11	Editable vs read-only styling is unambiguous on the staff detail (three selects vs the rest)	☑	☑	☑	R-12 ... R-14: the three selects sit in their own "Ticket operations" card; the rest is a definition list; <code>p7-13</code> shows the Administrator's values-only version
V-12	Public Comments and Internal Notes are visibly distinct (heading, colour, composer)	☑	☑	☑	R-15 (<code>notes-vs-comments</code>); UI-18 asserts the amber classes and that the two composers are never on screen together
V-13	Status, Requested Priority, IT Priority and Role badges are consistent across queue, detail, My Tickets and Users	☑	☑	☑	One <code>Badges.tsx</code> for every screen (UI-25); <code>requester/my-tickets-*</code> , R-08, R-12, R-17

#	Item	Desktop	Tablet	Mobile	Evidence
V-14	No overlap between the sticky header, profile menu, modal sheets and page content	☒	☒	☒	R-06 (profile menu open), R-07 (mobile sheet), R-16 (dialog on mobile), R-18 (Users panel on tablet)